



GBBC
Global Blockchain
Business Council

OLIVER WYMAN
A MARSH BUSINESS

Proposed Risk Mitigation Framework for Non-Financial Risks of Blockchain Infrastructures

Phase 2 Infrastructure (L1/L2) - April 2026

Core Industry-Leading Working Group

Ava Labs

Euroclear Group

Canton Network

Global Blockchain Business Council (GBBC)

Cardano Foundation

Hedera

Chainlink

Kinexys by J.P. Morgan

The Depository Trust & Clearing Corporation (DTCC) Oliver Wyman

Digital Asset Holdings

We would like to extend our sincere gratitude to the policymakers and financial institutions that are not named yet participated in RMF. Your contributions are greatly appreciated.

Contact

Comments from financial industry stakeholders and regulators are actively encouraged to inform and refine future phases of this initiative. Please contact rmf@gbbc.io to share feedback and ask questions.

Frequently Asked Questions (FAQs)

[Click here to access the full announcement, including FAQs.](#)

Contents

Executive Summary.....	5
Five key takeaways	6
1. Context and scope	7
1.1. Overview	7
1.2. Objective.....	8
2. Layer 1 and Layer 2 architecture primer	9
2.1. Architecture in scope	10
2.2. Illustrative risk tradeoffs in L2 design	10
3. Reference methodology for managing non-financial risks	11
4. Adapting non-financial risk management frameworks to incorporate public blockchain risks	12
4.1. Risk framework.....	12
4.2. Approach	13
4.3. Risk mitigation capabilities.....	15
5. Novel risks	16
5.1. Technology risk.....	16
5.1.1. Public blockchain risks and mitigation strategies	16
5.2. Information security risk	24
5.2.1. Public blockchain risks and mitigation strategies	24
5.3. Financial crime risk.....	31
5.3.1. Public blockchain risks and mitigation strategies	32
5.4. Business continuity risk	36
5.4.1. Public blockchain risks and mitigation strategies	37
5.5. Third-party risk	39
5.5.1. Public blockchain risks and mitigation strategies	39
6. Adapted risks	42
6.1. Legal risks	42
6.1.1. Public blockchain risks and mitigation strategies	42
6.2. Transaction and process execution	44
6.2.1. Public blockchain risks and mitigation strategies	44
6.3. Data management	46
6.3.1. Public blockchain risks and mitigation strategies	46

7.	Standard risks	48
8.	Private permissioned blockchains	50
9.	Path forward	51
Appendix A.	Risk and mitigation matrices	52
A.1.	Technology risks and mitigations approaches	52
A.2.	Information security risks and mitigations approaches	62
A.3.	Financial crime risks and mitigation approaches	72
A.4.	Business continuity risks and mitigations approaches.....	80
A.5.	Third-party risks and mitigations approaches	83
A.6.	Legal risks and mitigation approaches	86
A.7.	Transactions and process execution risks and mitigations approaches.....	88
A.8.	Data management risks and mitigations approaches.....	90
Glossary		91

Executive Summary

The financial industry and regulators recognize the transformational potential of blockchain technology to reshape legacy operations and business models within the financial services sector. Indeed, over the past decade, leading institutions and central banks across the world have worked on a broad set of experiments and initiatives which have demonstrated the profound benefits blockchain technology can bring to the financial system. The following work focuses on public permissionless and public permissioned blockchain infrastructures (“public blockchains”) as their associated risks are not adequately addressed by existing risk management frameworks.

Public blockchains need to be seen within the context of ever-increasing levels of technology-infrastructure externalization by financial institutions—a continuation of a trend that has already given rise to the communication infrastructure of the internet and cloud-based services. At the same time, open-source software development models have gained acceptance and have proven to be not only resilient, but in some cases superior to traditional closed software development models.

Public blockchains represent a natural extension of these broader macro trends. A critical gap impeding the wider adoption of blockchain infrastructure is the absence of recognized risk management frameworks and corresponding regulatory acceptance, particularly by financial institutions. A clear Risk Mitigation Framework (RMF) addressing public blockchains can be established by expanding and adapting existing risk management frameworks designed for externalized infrastructure, such as cloud, and open-source software development. Significant advancements in the resilience and security of public blockchains suggest these infrastructures can now offer reliable solutions suitable for institutional use.

Yet, despite blockchain's maturity, broad institutional adoption of public blockchains still faces challenges. Unlike modern traditional technologies where Service Level Agreements (SLAs) can clarify operational responsibilities and liability, public blockchains typically implement intrinsically more complex operating and governance models. Conversely, the decentralized structure of public blockchains mitigates certain traditional digital infrastructure risks, such as single points of failure or single-operator dependence.

Financial institutions seeking to use public blockchains must adapt their risk frameworks to identify, assess, and mitigate these new risks. Additionally, public blockchain communities should support these efforts to enable adoption at scale. Recognizing these challenges, the RMF proposal presents a structured, actionable approach to integrate the non-financial risks of public blockchains into established risk management standards and tools, such as the Operational Risk Reference Taxonomy introduced by the Operational Riskdata eXchange Association (ORX). The RMF aims to advance public blockchain infrastructure by providing a concise and adaptable standard for integration into existing frameworks, facilitate regulatory endorsement to advance harmonized policy development, and remove institutional obstacles to adoption.

The RMF acknowledges the complexity of this multidisciplinary challenge and recognizes that further iteration and improvement are required.

Five key takeaways

Blockchain introduces specific novel risks requiring targeted risk frameworks

Blockchain technology offers significant advantages—such as decentralized network with built-in redundancies, immutable records, and continuous (24/7) operations—that enhance transparency, operational efficiency, and resilience. However, these same features introduce novel risks that do not fit neatly into traditional risk management frameworks. A clearly defined categorization into three categories where 1) novel risk mitigation strategies need to be defined, 2) risks requiring adaptation to existing standards, and 3) where standard risk mitigation strategies are sufficient is important to enable financial institutions and regulators to prioritize their risk management efforts, while maximizing the benefits that blockchains bring to the financial system.

Public blockchain governance differs fundamentally from traditional operating models

Unlike traditional digital infrastructure services that are centrally governed and where risks are contractually distributed, public blockchains leverage various decentralized governance models and rely significantly on open-source quality assurance mechanisms. Public blockchain ecosystems should endeavor to clearly define such governance structures, including their risks and challenges. Simultaneously, financial institutions must adapt their own internal governance and decision-making processes to their public blockchains of choice, ensuring governance visibility and adequate reaction capability.

Public blockchain adoption demands new resiliency strategies

Financial institutions should consider public blockchain adoption in conjunction with complementary support services (e.g., third-party node operators, failover systems to traditional service providers, etc.) to achieve resilience. Furthermore, financial institutions must move from being passive users of software services to actively participating in public blockchain ecosystems. Institutions can further strengthen public blockchain robustness and resilience by directly or indirectly participating in their operations (e.g., running nodes) and contributing to underlying codebases (e.g., participating in open-source development).

Layer 2 systems improve performance but increase cross-layer operational complexity

Layer 2 (L2) systems are an architectural response to base-layer constraints under high volumes and can materially improve throughput, latency, and fee predictability, and in some cases enable more controlled operating patterns for specific workflows. However, L2s remain dependent on the underlying L1 for settlement assurances and recovery, and they introduce additional critical components and operators, including sequencers, bridges, data-availability mechanisms, and upgrade or emergency controls. As a result, non-financial risk often shifts rather than disappears, and institutions need broader capabilities to monitor and manage L1 conditions, L2 conditions, and the pathways between them, with tested playbooks for exits, withdrawal delays, and recovery in stressed scenarios.

Blockchain requires a structured approach to risk management

Institutional blockchain adoption should be accompanied by empirical validation processes, adversarial network, and load tests to ensure operational resilience and continuous improvement. Ongoing public-private collaboration, leveraging community-driven and open-source mechanisms, is essential. Financial institutions should actively participate in and provide resources for such work. Continuous improvements to existing open-source risk frameworks and standards should be pursued to ensure relevance and responsiveness.

1. Context and scope

1.1. Overview

The RMF is an industry-led effort, facilitated by Global Blockchain Business Council (GBBC) and Oliver Wyman, to give financial institutions guidelines to analyze and control for the non-financial risks that arise when they use public blockchain infrastructure. A cross-sector working group—comprising financial-market infrastructures, global systemically important banks, multilateral development banks, and leading L1 protocol teams—has collaborated to provide a common reference that is rooted in their practical experience of managing risks or blockchain implementations and provide an overview of how the new technology can be incorporated into established risk management frameworks.

While blockchain, akin to the internet, is inherently use-case agnostic and supports numerous non-financial applications, the cross-sector working group identifies its transformative potential to drive a new wave of financial innovation with a potential to fundamentally reshape financial services. The Bank for International Settlements (BIS) believes tokenization will enhance the capabilities of the monetary and financial system by enabling new ways to serve end users and by removing the traditional separation of messaging, reconciliation, and settlement¹. Similarly, the Executive Order issued by the President of the United States 'Ensuring Responsible Development of Digital Assets' recognizes that advances in technology and the rapid growth of digital asset markets are shaping the future of finance².

Public blockchains extend these potential benefits beyond traditional financial services, offering new infrastructure rails for exchanging information and value over a shared database layer. This expansion requires the adaptation and evolution of existing risk management practices. Just as cloud services and the internet have become foundational for financial institutions, blockchain technology represents the next step in the evolution of the infrastructure. Financial institutions must therefore engage with these technologies, contribute to their development and governance, and adopt new responsibilities essential to managing shared public infrastructures.

Financial institutions have an opportunity to leverage blockchain technology to offer integrated financial services, improve financial inclusion, modernize legacy systems, and reduce risks associated with interconnected infrastructures and processes. Blockchain's potential has gained widespread recognition, with regulated institutions accumulating considerable experience designing and operating public and private blockchain systems. However, to move from proof-of-concept stages to scaled production-level deployments, clearer regulatory guidance and industry standardization is necessary. Financial institutions must also systematically integrate these emergent infrastructures into established risk management practices.

The RMF focuses on two archetypes of public blockchains: public permissionless and public permissioned. These two types present distinct characteristics and risk profiles, necessitating tailored approaches to identify, assess, and mitigate risks effectively. The RMF deliberately deprioritizes private permissioned blockchains from its scope, as their governance typically resembles conventional outsourced IT, which is adequately covered by existing cloud, outsourcing, and third-party risk management standards. The RMF focuses primarily on public blockchains, characterized by shared and open infrastructure maintained by a global community rather than bilaterally contracted vendors.

The RMF leverages established globally recognized financial industry standards, frameworks, and taxonomies³ to ensure seamless and appropriate mitigations for public blockchain use into existing non-financial risk management frameworks.

¹ BIS, The next-generation monetary and financial system

² The White House, Strengthening American Leadership in Digital Financial Technology

³ Frameworks, standards, and taxonomies leveraged include: Committee of Sponsoring Organisations (COSO) of the Treadway Commission, NIST Cybersecurity Framework, Cloud Controls Matrix, Digital Asset Securities Control Principles, Digital Operational Resilience Act, Markets in Crypto-Assets Regulation, Basel BCBS44, Identity and Access Management, Principles for Financial Market Infrastructure

1.2. Objective

The RMF targets three key objectives to advancing public blockchain infrastructure adoption:

- Provide a concise, adaptable, baseline standard by designing seamless integration into existing risk management frameworks. The RMF should accommodate financial institutions at any stage of public blockchain adoption, intended to be applied alongside established standards and controls.
- Facilitate regulatory feedback through active dialogue with policymakers and regulators to support harmonized policy development and rulemaking.
- Remove institutional obstacles by addressing operational uncertainties and regulatory ambiguities with mitigants and controls, enabling confident and risk-aware interactions with public blockchains.

The RMF will be developed in phases, progressively expanding its risk-based mitigation focus across asset classes and use cases. This version of the RMF incorporates feedback received from stakeholders and extends to Layer 2 systems, reflecting additional control points and cross-layer dependencies introduced by modern architectures.

Exhibit 1: Risk mitigation framework phases



2. Layer 1 and Layer 2 architecture primer

The blockchain industry has developed a diverse set of architectures to balance competing design objectives. Early public blockchains prioritized open participation and strong settlement assurances, but faced trade-offs in throughput, latency, and cost. More recent blockchains prioritize transaction throughput and user experience while selectively trading off decentralization and security guarantees.

Public L1 blockchains observed rapid growth in activity, which illustrated different structural trade-offs in their designs (e.g., high volumes leading to fee volatility, latency, or throughput limitations). L2 systems emerged as an architectural response to these challenges, and to support additional design goals such as lower fees, improved user experience, and, in some designs, stronger privacy. Rather than processing all activity directly on the L1, L2s execute transactions in a separate execution environment and periodically anchor outcomes back to the L1. This can allow for improvements to targeted L1 performance characteristics (e.g., transaction throughput scaling, fees, transaction privacy, interoperability.) while still relying on the L1 for certain security assurances. This dependency on the L1 is imperative as disruptions at the L1 can cascade into L2 processing, exits, and recovery. L2s typically adopt their own, often more centralized operating and governance models compared to L1s.

The design choices of L1s and L2s can impact performance outcomes and how non-financial risks manifest across the technology stack of a given deployment. Architecture decisions should not be interpreted as removing risk. More commonly, they reduce exposure in one area while introducing or relocating exposure elsewhere, often from the base layer into additional operators, services, or integration points. A practical way to frame the design trade-offs is to extend the traditional blockchain trilemma⁴ to a set of five questions:

- **Decentralization:** How broadly is control distributed across independent operators and participants (e.g., validator diversity, client diversity)?
- **Security:** How are ledger integrity and transaction outcomes assured (e.g., double spend, manipulation, censorship)?
- **Scalability:** How performant is an infrastructure at higher volumes (e.g., throughput, latency, fee predictability under congestion)?
- **Privacy:** How is the exposure of sensitive information limited while maintaining integrity and auditability (e.g., minimizing on-chain sensitive data, privacy-preserving mechanisms)?
- **Interoperability:** How can assets and messages be exchanged with other infrastructures without vulnerabilities across pathways (e.g., dependence on bridges, routing layers)?

In practice, design choices amongst these dimensions always involve trade-offs. Improvements in scalability and interoperability, for example, frequently introduce additional operators, interfaces, or governance dependencies. Similarly, privacy enhancements can reduce exposure of sensitive information while increasing compliance complexity and operational control requirements. These trade-offs are central to understanding why new solutions are created and how non-financial risk often changes or shifts rather than being outright eliminated across layered designs.

⁴ Blockchain trilemma refers to the trade-off between decentralization, security, and scalability, where improving one often weakens one or both of the others

2.1. Architecture in scope

Two public blockchain architecture families are in scope of the RMF: public permissionless and public permissioned blockchain infrastructures L1, and L2 systems that are anchored to a L1.

Layer	L1	L2
Overview	• Base networks providing consensus, shared data availability, and settlement • Maintain the authoritative record of transactions and define security model	• Execution environments that process transactions outside the L1 but rely on the L1 for settlement and recovery assurances • Periodically anchor outcomes back to the L1, which can enable users to recover funds or exits under defined conditions

2.2. Illustrative risk tradeoffs in L2 design

L2 design parameters can be used to anticipate where risk is likely to be amplified or reduced, subject to respective design choices:

- **Decentralization**-oriented designs can reduce concentration risk and increase robustness against unilateral control. They can also increase coordination complexity and slow change management, particularly during incidents or upgrades.
- **Security**-oriented designs can strengthen settlement assurances and reduce manipulation risk. They may raise cost and latency or constrain flexibility for upgrades and emergency response, and any emergency controls can create concentrated privileges that must be governed as material control points.
- **Scalability**-oriented designs can reduce fee pressure and throughput constraints under demand. They can increase reliance on specialized operators, infrastructure, and software components, amplifying third-party dependency risk and shifting constraints to data handling and exit paths where throughput is not the primary objective.
- **Privacy**-oriented designs can reduce exposure of sensitive information and mitigate confidentiality concerns. They can increase complexity for monitoring and investigation, shifting risk toward policy enforcement, access control design, auditability, and governance for exceptional access.
- **Interoperability**-oriented designs can reduce fragmentation and improve cross-domain workflows. They can amplify integration risk where cross-domain activity relies on shared infrastructure, messaging layers, or complex routing logic, increasing the importance of operational controls, monitoring, and correlation risk management.

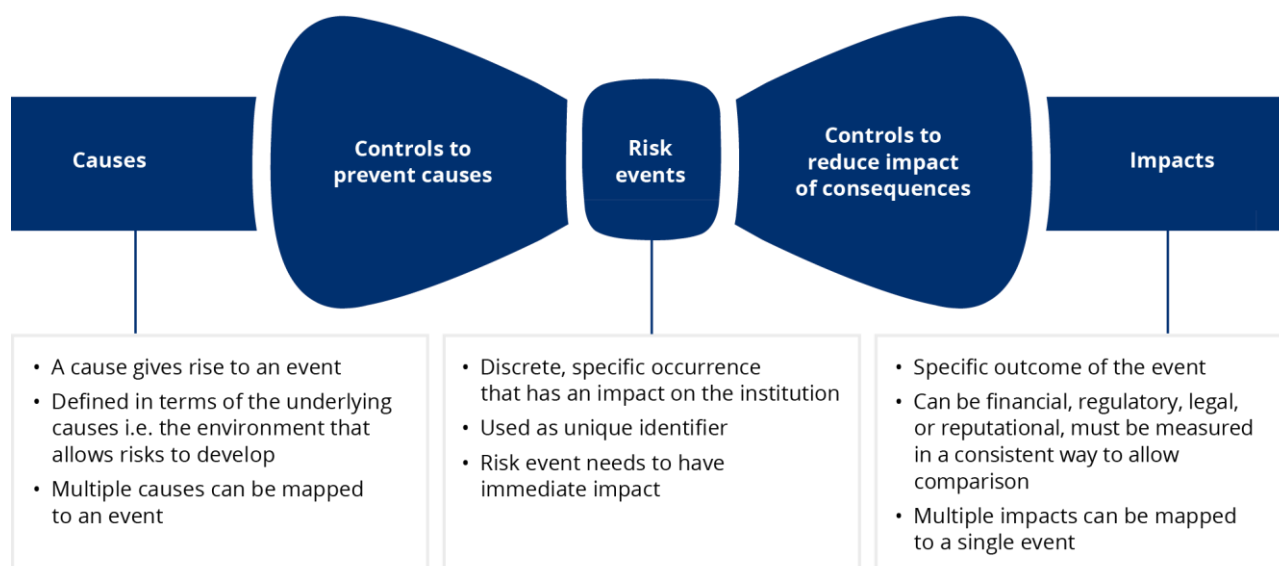
3. Reference methodology for managing non-financial risks

Established in the early 2000s, the Operational Riskdata eXchange Association (ORX) has evolved its Reference Event Taxonomy since 2019 into a globally recognized framework for classifying non-financial risks. It provides a structured, hierarchical model that organizes risk types into consistent categories. The taxonomy adopts a bow-tie methodology to standardize and deepen the analysis of risk, enabling consistent, insightful, and benchmarkable risk management practices. Several regulators, like the European Banking Authority (EBA), explicitly reference or align their guidance broadly with ORX taxonomy principles.

While the ORX framework's taxonomy remains broadly applicable to blockchain technologies, certain blockchain-specific characteristics alter the nature and impact of underlying risks. Consequently, tailored mitigation strategies are necessary to effectively manage these risks within institutional risk appetite. Therefore, this RMF uses the ORX taxonomy as its foundational structure, adapting it to address blockchain-specific risk scenarios and mitigation strategies.

The ORX taxonomy is based on an event-driven structure that draws from the bow-tie method. This method maps risk scenarios across three core dimensions: causes (the underlying drivers or conditions that make risk events possible), events (the actual incidents), and impacts (the resulting consequences)⁵. It also emphasizes the importance of linking these dimensions to mitigation strategies presented through preventive, detective, and corrective actions. This structure supports a dynamic approach to non-financial risk management and is widely used by financial institutions.

Exhibit 2: Bow-tie methodology



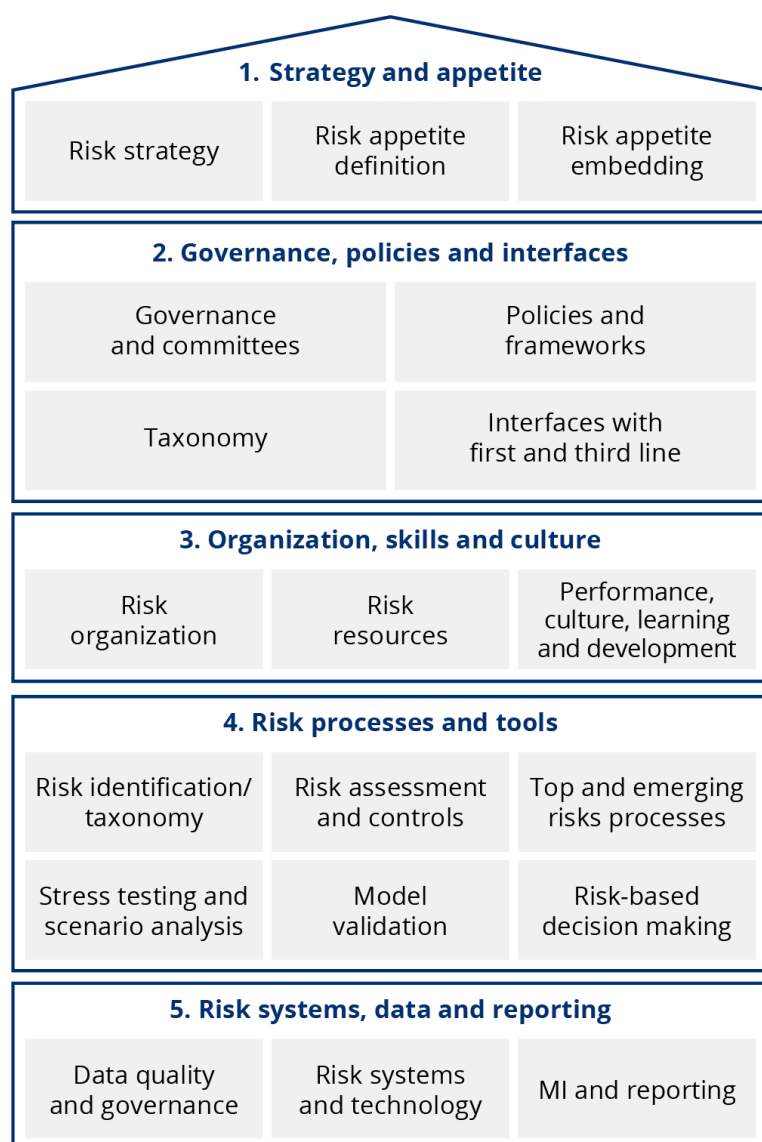
⁵ ORX, ORX Reference Taxonomy for operational and non-financial risk

4. Adapting non-financial risk management frameworks to incorporate public blockchain risks

4.1. Risk framework

The RMF focuses on the successful incorporation of non-financial risks and mitigations into standard risk taxonomy and strategies. Financial institutions typically have existing Enterprise Risk Management (ERM) and Non-Financial Risk (NFR) frameworks. It is crucial that blockchain-related risks are managed in an integrated rather than isolated manner; thus, this RMF is intentionally designed to align seamlessly with standard ERM and NFR structures used by financial institutions, facilitating straightforward adoption and integration.

Exhibit 3: Standard risk management framework structure



While not falling directly under the rubric of this RMF, for the purpose of completeness we have outlined how a financial institution could incorporate public blockchain-related risk management practices:

1. **Strategy and appetite:** Financial institutions must clearly articulate how the usage of public blockchains aligns with their overall risk strategy. As public blockchains become integrated into core business processes, the risk appetite must explicitly reflect this shift, ensuring clear thresholds, tolerances, and escalation criteria for blockchain-related risks. Risk appetite should be network-specific and evidence-based with results from technical and governance due diligence (e.g., code quality, sustainability profile, validator concentration, upgrade history, bug-bounty scope, oracle dependencies).
2. **Governance, policies, and interfaces:** Financial institution governance structures must explicitly recognize and incorporate public blockchain-related activities, especially if they become strategically significant. Public blockchains operate 24/7 and are often highly automated. Therefore, they require mechanisms that are more in line with trading-related governance processes. Policies and procedures should be reviewed and updated to clearly define public blockchain-specific roles, responsibilities, and escalation paths, ensuring effective oversight and integration with existing governance processes.
3. **Organizational skills and culture:** Public blockchain as a modern technology necessitates specialized expertise. Institutions should proactively embed knowledge into their risk functions through dedicated training and targeted augmentation of the skill set. The transparent nature of public blockchain data may also require adaptation of the internal code of conduct to ensure teams understand and effectively address the unique challenges. Software risk-control mechanisms need to be systematically embedded in business processes that use smart contracts, requiring that the respective team's skills are adequate.
4. **Risk processes and tools:** Represents the primary area of focus and adaptation. Central to effective non-financial risk management is the development of a structured risk taxonomy that explicitly incorporates public blockchain-related risks. This taxonomy should be built upon and integrate with standard industry frameworks, ensuring consistency and comprehensive oversight. This includes identifying unique public blockchain risks, assessing their specific nature, and implementing robust blockchain-specific mitigation strategies.
5. **Risk systems, data, and reporting:** Must accommodate blockchain's continuous (24/7) operating environment. Systems should seamlessly integrate blockchain data streams, ensuring real-time risk detection, monitoring, and timely reporting. Enhancing infrastructure to manage continuous data flows and providing effective, real-time management information reporting will be essential to maintaining operational resilience and robust risk oversight.

4.2. Approach

As outlined above, public blockchains differ in several significant ways from traditional digital infrastructures, particularly within the financial market domain. Many of these differences stem from the distributed, multi-party operational and governance models that public blockchains adopt. While select non-financial risks can be addressed through conventional governance and controls, a subset of threats calls for broader structural changes in institutions' risk mitigation strategies and appropriate governance mechanisms that reflect the shared responsibility among network participants. These challenges are intrinsic to how blockchain systems operate – for instance, vulnerabilities in consensus mechanisms or governance shortfalls in decentralized networks – which no single institution can mitigate on its own.

The RMF analyzes known public blockchain risks and compares them with existing ORX risk types and established risk management positions, identifying three distinct categories: novel risks requiring entirely new mitigation strategies, risks requiring adaptations of existing standards, and standard risks manageable using established frameworks.

Table 1: Risks assessed

Risk type	Relevant ORX Risk	Specific risks assessed	
Novel risks	Technology risk	Hardware risk	- Limited node diversity - Third-party dependencies
		Software risk	- Code vulnerabilities - Data corruption due to software or configuration errors
		Network risk	- Protocol upgrade and hard fork risk - Finality lag and transaction rollback risk - Protocol governance risk - Weakness in consensus design - Scalability constraints - Inter-chain connection disruption risk - Interoperability mechanism failure risk
	Information security risk	Risk of data loss	- Private key loss and inadequate key management practices - Compromised data integrity
		Cyber risk events	- Consensus attacks - Denial of service (DoS) - Cryptographic vulnerabilities - Smart contract errors and exploits
		Risk of data privacy breach / confidentiality mismanagement	- De-anonymization through public transaction data analysis - On-chain exposure of sensitive or confidential data
		Risk of improper data access	- Misuse of data transparency and roles - Privilege misconfiguration
	Financial crime risk	Risk of money laundering and terrorism financing	- Obfuscation of transaction origin through complex multi-step activity - Illicit fund integration - Terrorist and proliferation financing
		Risk of sanctions violation	- Sanctions evasion risk - Insufficient screening of on-chain transactions and counterparties
		Bribery and corruption	
		KYC / KYT / Transaction monitoring control failure	
	Business continuity risk	Inadequate business continuity planning / event management	
		Dependency on external governance for network recovery	
	Third-party risk	Reliance on public blockchains	
		Inability to effectively manage providers	
Adapted risks	Legal risks	Lack of attributable counterparty (ORX Level-2 risk category - mishandling of legal processes)	
		Risks that arise from contractual rights / obligations failure	
	Transaction and process execution	Processing/execution failure relating to clients and products	
	Data management	Inadequate data architecture/IT infrastructure	
Standard risks	Security and safety		
	People		
	Conduct		
	Internal fraud		
	External fraud	<i>Out of scope as traditional frameworks sufficiently cover these risks.</i>	
	Regulatory compliance		
	Model		
	Statutory reporting and tax		

4.3. Risk mitigation capabilities

For effective management of non-financial risks in public blockchains, financial institutions should consider adopting and integrating comprehensive risk mitigation capabilities across the following three dimensions:

- **Technological risk mitigation:** Financial institutions have made substantial advances in developing sophisticated mitigants, most recently for cloud-based services—implementing real-time monitoring, automated alerts, redundancy strategies, and cyber-resilient infrastructures. Significant progress has also been made regarding open-source code risks, including automated vulnerability scanning, vulnerability databases, strategies for immediate patching, pinning specific code versions, and software composition analysis (SCA) tooling. Public blockchains represent an evolution of this trend, and these existing technological solutions and approaches can be leveraged as part of an institution's evolving blockchain risk management practices.
- **Process-oriented mitigation:** Financial institutions typically invest substantial efforts in defining rigorous internal processes, including formalized policies and operating procedures. Institutions should classify underlying networks and supporting services by criticality and calibrate due diligence, resilience requirements, and monitoring accordingly. However, the inherently distributed operational model and multi-stakeholder environment of public blockchains challenge the traditional internally focused approaches. Institutions considering public blockchains may need to contemplate modification of their process environments, to ensure alignment with blockchain-specific operational dynamics. These adaptations might include processes such as asset-freezing mechanisms, on-chain contingency procedures, and rapid response protocols for incidents.
- **Governance mitigation:** Traditional outsourcing arrangements alleviate governance-related risks, such as change management and escalation processes, through contractual agreements incorporating clearly defined SLAs. In contrast, public blockchains typically rely on decentralized governance mechanisms that often involve community-based structures, such as decentralized autonomous organizations (DAOs), and collective decision-making among asset holders, node operators, or users. Governance decisions in these decentralized settings are usually guided by community consensus or majority vote rather than explicit contractual obligations, which provide transparency and collective oversight but rely heavily on voluntary coordination and alignment among stakeholders rather than binding mandates. Financial institutions can analyze decentralized blockchain governance structures and their coordination dynamics and decide whether those fall within their stated risk appetite and, if they choose to engage, participate in these governance frameworks to shape them to better suit their needs. Where operations are sufficiently centralized and identifiable (e.g., L2 operators or route providers), institutions may apply traditional third-party governance controls (e.g., contractual SLAs, escalation timelines, audit rights) to the extent practicable.

The proposed mitigation strategies are presented from two distinct perspectives: the public blockchain ecosystems and the financial institutions. The ecosystem perspective reflects actions that can be taken collectively by protocol developers, node operators, governance participants, and other involved actors through open standards, voluntary coordination, and protocol design. This perspective aims to capture the diverse and distributed group of actors and stakeholders involved in the development, maintenance, and operation of a public blockchain infrastructure. In contrast, the financial institution perspective focuses on what regulated entities can do independently—such as technical integration, monitoring, and fallback planning—to manage their exposure to public blockchains. This dual view enables a realistic and comprehensive approach to risk mitigation by aligning controls with where agency and accountability reside and provide supportive delimitations.

5. Novel risks

Risks in this category encompass novel risks introduced by public blockchains and decentralized architectures, requiring expansion or enhancement of existing controls and governance frameworks. These risks oblige institutions to rethink their control frameworks.

5.1. Technology risk

As with any digital infrastructure, the integrity and availability of public blockchains determines whether data can be processed reliably and safely. One key category impacting this is technology risk. The architecture and operating model of public blockchains can reduce certain traditional technology risks (such as data redundancy and system availability). At the same time, though, this also can introduce novel risks. Public blockchains are interconnected infrastructures—meaning that, even more so than in the traditional financial infrastructures space, a vulnerability in a blockchain could affect a large user base. Robust technology risk management by financial institutions is therefore essential.

An important mitigation strategy, unique to blockchain, is the governance mechanisms that support and maintain the network. Financial institutions should determine where they can directly participate in blockchain protocol operations and governance. Institutions may proactively contribute to codebase development and directly operate or sponsor key blockchain utilities (such as APIs, node infrastructures, and block explorers), thereby enhancing security and operational resilience across the ecosystem.

5.1.1. Public blockchain risks and mitigation strategies

See Appendix for detailed matrix: **Table A.1**

Hardware risk					
Ability to mitigate (1 = low ability to mitigate; 5 = high ability to mitigate)					
	1	2	3	4	5
L1s					Ecosystems can encourage multiple clients, node setups and infrastructure providers. Institutions can multi-home RPC, run their own nodes, and design failover. They cannot fully control global validator/hosting dispersion, but they do have meaningful levers.
L2s					L2s inherit L1 settlement/security assurances but add L2-critical services (e.g., sequencing, DA/proving where applicable, and canonical bridge/submission pathways). As a result, L2 liveness and user access can fail at the service layer even when the L1 is healthy, so institutions must monitor and manage both layers in parallel. While L2 roles are often more identifiable, the added dependencies keep mitigation broadly similar to L1, with different control points and more potential single points of failure.

Limited node diversity: Public blockchains rely on distributed nodes for data validation and redundancy. Potentially, some node operators can be concentrated with a few hosting providers or in geographic regions based on community origins and operational efficiencies. Such concentration increases the risk that provider outages, regional failures, or natural disasters could simultaneously impact a critical number of nodes, causing processing degradation or, at worst, network downtime.

For L2s, the same concentration risk as L1 can occur at the L2 service layer, where a small set of operators or infrastructure dependencies support core functions (e.g., sequencing, DA providers/committees, proving where applicable, and canonical bridge/submission pathways), introducing additional single points of failure and requiring parallel monitoring of both L1 and L2 operations.

Mitigation strategies for L1s

- For public blockchain ecosystems: incentivizing diversified node hosting, concentration monitoring and disclosure, and providing tools and guidance to lower the cost of hosting.
- For financial institutions: prioritizing blockchains with demonstrated node distribution, continuously monitoring node metrics, running a set of their own distributed nodes, and maintaining documented failover plans.

Mitigation strategies for L2s

- For public blockchain ecosystems: promoting diversity of sequencers and other critical L2 operators across regions and providers, monitoring and disclosing concentration across sequencers, verifiers, and DA providers, and designing credible fallback mechanisms.
- For financial institutions: prioritizing L2s with transparent and diversified operator structures, monitoring exposure to single sequencers or shared infrastructure and DA providers, and maintaining documented failover plans.

Third-party dependencies: Public blockchain networks may rely on external infrastructure providers such as Remote Procedure Call (RPC) endpoints, node gateways, and indexing services, which can create centralization risks and potentially unexpected single points of failure. Outages, degradation or cyberattacks on such providers could significantly disrupt data processing and access.

For L2s, the same dependency pattern as L1 can arise across L2 services and cross-layer routes (e.g., L2 RPC/gateways, sequencer endpoints, DA services where applicable, and bridge/route operators), so disruption in either L1 or L2 providers can impair end-to-end processing, access, withdrawals/exits, or recovery and should be managed together.

Mitigation strategies for L1s

- For public blockchain ecosystems: encouraging diversification of infrastructure providers, striving towards more decentralized architectures, supporting and incentivizing self-hosting, monitoring third-party providers' health, and implementing robust failover mechanisms.
- For financial institutions: employing multiple independent providers for redundancy, assessing provider resilience during due diligence, continuously monitoring service availability, and maintaining documented failover plans.

Mitigation strategies for L2s

- For public blockchain ecosystems: clarifying roles and responsibilities for critical L2 service providers and route operators, encouraging diversity of implementations and operators publishing service-health telemetry and incident communications for critical services, and designing architectures to tolerate failure of single operator.
- For financial institutions: mapping full dependency chain across L1 and L2, assessing resilience and governance of critical operators and providers, monitoring performance and incident across both layers, and maintaining documented failover plans.

Software risk					
Ability to mitigate (1 = low ability to mitigate; 5 = high ability to mitigate)					
	1	2	3	4	5
L1s					L1s have mature open-source processes, audits and bug-bounty culture, but change is slow and consensus-driven. However, institutions can choose blockchains with good practices and adjust their own integration/testing, remaining cognizant of limited control over core protocol code.
L2s					L2s add L2-specific software components beyond the underlying L1 (e.g., sequencing, proving and DA where applicable, and canonical bridge/message-passing logic), expanding the attack surface and upgrade dependencies. While these components are often maintained by smaller, identifiable teams that can patch faster, institutions must monitor vulnerabilities, upgrades, and operational health across both layers. As a result, mitigation capacity is broadly similar to L1, with more control points and greater testing and monitoring requirements.

Code vulnerabilities: Public blockchain networks rely on complex decentralized consensus protocols and node code, which can introduce undiscovered vulnerabilities. Such flaws may be exploited by attackers to disrupt node operations, compromise consensus mechanisms, or gain unauthorized access, leading to operational failures or security breaches. Exploitation of these vulnerabilities can lead to reduced network integrity, transaction errors, and unintended forks.

For L2s, additional critical code can expand the attack surface (e.g., sequencing logic, proving systems where applicable, canonical bridge contracts, and L1–L2 interaction and exit logic), so vulnerabilities can disrupt processing, create inconsistent state assumptions, or impair exits and recovery to the underlying L1, requiring monitoring and response across both layers.

Mitigation strategies for L1s

- For public blockchain ecosystems: rigorous code reviews, formal verification, continuous static and dynamic analysis, real-time anomaly monitoring, adversarial testing infrastructures, multiple competing node implementations, third-party or community audits, rapid patching teams, and coordinated disclosure processes.
- For financial institutions: selecting networks with secure coding practices and third-party audits, continuously monitoring vulnerability disclosures and network performance, testing preproduction environments prior to integration, documented plans for suspending transactions, and documented failover plans to backup infrastructure.

Mitigation strategies for L2s

- For public blockchain ecosystems: rigorous assurance to L2-specific components, including, L1-L2 interaction and exit-path testing, bug bounty and coordinated disclosure practices that account for cross-layer dependencies, and clearly governed upgrade and emergency response mechanisms for critical L2 contracts and infrastructure.
- For financial institutions: selecting L2s with transparent development practices and independent audits, reviewing stress-testing results and incident history as part of due diligence, testing integration and failure scenarios, including bridge and exit conditions, and maintaining documented failover plans to backup infrastructure or alternative routing.

Data corruption: Public blockchains rely on consistent software implementations and correct configuration of sufficient nodes to ensure expected blockchain infrastructure behavior. Software bugs, version mismatches, or misconfigurations can cause degraded performance, delayed transactions, and, at worst, involuntary operational disruptions such as temporary forks.

For L2s, the same corruption risk as L1 can arise in L2 components (e.g., sequencer, nodes, bridge contracts, DA services or proving where applicable), leading to inconsistent state views, failed or inconsistent L1 submissions, or disrupted exits/withdrawals; where less data is posted to L1, integrity risk may shift from the L1 data layer to the L2's own data handling, availability, and recovery mechanisms.

Mitigation strategies for L1s

- For public blockchain ecosystems: standardizing node implementations, incentivizing configuration compatibility checks, providing node operators with automated deployment tools, real-time monitoring for divergence, and providing rapid node recovery and emergency configuration updates.
- For financial institutions: using validated node software, rigorous configuration management, continuous node monitoring, promptly reinitializing nodes from trusted snapshots, verifying ledger integrity, and coordinating with protocol maintainers.

Mitigation strategies for L2s

- For public blockchain ecosystems: hardening L2 software components, providing automated deployment and configuration tooling, monitoring divergences between L2 and L1 submissions, defining resynchronization and rollback procedures, and documenting where transaction data is retained and how recovery operates in privacy-enhancing L2 designs.
- For financial institutions: using validated L2 client and infrastructure software, applying the same configuration and change-management controls across L1 and L2 environments, monitoring L2 node, bridge and data-availability behavior for anomalies, and testing recovery and exit procedures as part of operational readiness.

Network risk

Ability to mitigate (1 = low ability to mitigate; 5 = high ability to mitigate)

	1	2	3	4	5	
L1s						Consensus and governance parameters are structurally hard to change; institutions can vote (if they run validators) and choose which L1s to use, but they cannot easily steer governance, fork policies, or finality behavior. Ability to mitigate (1 = low ability to mitigate; 5 = high ability to mitigate) is mostly via selection, monitoring, and internal buffers, not direct control.
L2s						L2s inherit L1 network characteristics but introduce additional network-level control points (e.g., L2 governance, sequencing policies, and bridge operating models) that can be more accessible for direct engagement. However, layered deployments compound network risk across both L1 and L2, requiring institutions to manage governance, upgrades, stability, and recovery assumptions across both layers in parallel, which keeps overall mitigation capacity broadly similar to L1 but with more control points and more coordination required.

Protocol upgrade and hard fork risk: Public blockchains can require network-wide upgrades, often in the form of hard forks, to introduce new features, enhance security, or address vulnerabilities. If poorly coordinated or communicated across the validator pool, these changes can cause operational misalignment or inconsistent network behavior. For financial institutions, insufficient visibility or preparation for upgrades may result in incompatible systems, node failures, service disruptions, and transaction discrepancies.

For L2s, upgrades to L2 contracts, bridges, and supporting infrastructure (e.g., sequencer/prover software where applicable) add coordination and compatibility risk across layers and can disrupt processing or impair exit paths to the underlying L1.

Mitigation strategies for L1s

- For public blockchain ecosystems: establishing transparent upgrade governance, advanced communication, monitoring upgrade adoption, and providing emergency patches.
- For financial institutions: active monitoring of governance forums, testing upgrades and their interaction with their own systems in preproduction environments, maintaining communication with development teams, auditing post-upgrade transactions, preparing fallback infrastructure, and delaying critical transactions during upgrade uncertainties.

Mitigation strategies for L2s

- For public blockchain ecosystems: establish incentives to drive clear governance and change processes, coordinating upgrade timelines with the underlying L1, providing test environments, and defining rollback, pause, and recovery procedures for L2 and bridge components.
- For financial institutions: active monitoring of L2 roadmap changes, testing combined L1/L2 and bridge upgrades in preproduction, planning windows to pause or limit higher-risk activity, and maintaining documented failover procedures.

Finality lag and transaction rollback risk: Public blockchains may rely on probabilistic finality, meaning transaction irreversibility becomes less likely with the amount of data validated after the transaction in question. During periods of network degradation, this can lead to delayed finality or, at worst, blockchain reorganizations, reversing confirmed transactions.

For L2s, finality depends on both the underlying L1 and the L2 protocol (e.g., sequencer pre-confirmations vs. L1-anchored finality), so instability at either layer can potentially delay settlement expectations, revert previously “confirmed” outcomes, and disrupt exits.

Mitigation strategies for L1s

- For public blockchain ecosystems: modifying consensus mechanisms for deterministic finality, transparently communicating finality thresholds and risks, monitoring network forks, implementing checkpointing solutions, enabling rapid node reconciliation, and providing clear guidance on reorg handling, confirmation expectations, and recovery procedures.
- For financial institutions: selecting blockchains with appropriate finality models, adopting conservative probabilistic thresholds for critical transactions, real-time monitoring of blockchain stability, designing resilient internal systems to handle reorganizations, maintaining documented plans to promptly reconcile or pause affected transactions during reorganization events, and defining confirmation thresholds, rollback procedures, and conditions for pausing activities.

Mitigation strategies for L2s

- For public blockchain ecosystems: clearly defining L2 finality guarantees and how they relate to L1 finality, communicating guidelines for pre-confirmations and exits, monitoring for instability, and designing L2 and bridge components to tolerate L1 reorganizations and delayed finality.
- For financial institutions: selecting L2s with transparent finality models, defining combined L1/L2 confirmation policies, monitoring both layers for instability, designing systems to handle reverted batches, and maintaining documented procedures to pause activity or reroute flows during elevated finality risk.

Protocol governance risk: Public permissionless blockchains, in particular, can rely on governance mechanisms that are determined by community decisions. These governance processes can be slow, result in stakeholder disputes, create unexpected outcomes, and in rare cases, end in a community split with two competing infrastructure versions (e.g., Ethereum and Ethereum Classic). Such events may trigger operational disruptions, increased integration complexity, diminished predictability, and higher maintenance costs. Where a foundation or coordinating entity exists, transparency on mandate, funding, representation, and decision processes can strengthen governance confidence.

For L2s, governance decisions over contracts, bridges, and operators create the same change-volatility risk as L1, and misalignment between L1 and L2 governance or change cycles can increase operational complexity and weaken exit and recovery assumptions. Where L2 operations are highly centralized or controlled by a small, identifiable operator set, institutions may need to treat governance and change-management like a service provider (e.g., with explicit SLAs, escalation paths).

Mitigation strategies for L1s

- For public blockchain ecosystems: establishing transparent and technically enforceable governance frameworks, structured proposal and voting processes, pre-voting and other intent-signaling methods, and proactive governance monitoring.
- For financial institutions: active monitoring of governance proposals and voting, participation or partnership with ecosystem contributors, governance robustness assessment during infrastructure selection, operational buffers for protocol-driven changes, and documented failover plans.

Mitigation strategies for L2s

- For public blockchain ecosystems: establishing clear and transparent governance arrangements for L2 protocols, contracts, and bridges, aligning L2 change processes with the underlying L1 where relevant (e.g., establishing SLAs where possible), and providing advance visibility on planned changes, emergency powers, and decision criteria.
 - For financial institutions: actively monitoring L2 governance forums and decision processes, assessing the robustness of change and emergency mechanisms, engaging where appropriate, and maintaining documented failover plans.
-

Weakness in consensus design: Public blockchain networks rely on consensus protocols designed to decentralize validation power. However, economic incentives or technical constraints can unintentionally encourage centralization of such activities, creating structural vulnerabilities such as lower-than-expected fault or collusion tolerance or, at worst, consensus instability. This can disrupt transaction processing and weaken network resilience.

For L2s, weaknesses in the underlying L1 consensus or in L2 operator arrangements (e.g., sequencing or committee models) can reduce effective fault tolerance, increase censorship risk, or lead to extended halts and delayed exits.

Mitigation strategies for L1s

- For public blockchain ecosystems: designing incentive structures that promote validator diversity, implementing safeguards against concentration (e.g., staking caps, validator rotation, slashing mechanisms), continuously monitoring validator concentration, and enabling governance-driven validator rebalancing.
- For financial institutions: continuously monitoring validator decentralization, participating in validation, and maintaining documented failover plans.

Mitigation strategies for L2s

- For public blockchain ecosystems: designing sequencing and committee arrangements to promote diversity and avoid single points of control, monitoring operator concentration and liveness, and enabling operator rotation or fallback mechanisms where risk becomes excessive.
 - For financial institutions: monitoring sequencer and operator concentration and underlying L1 conditions, assessing effective decentralization, and maintaining documented procedures to pause activity and execute exits where required.
-

Scalability constraints: Public blockchain networks inherently face scalability constraints due to design choices prioritizing decentralization and security over throughput. Protocol limitations on block sizes, transaction speeds, or finality can cause network congestion during periods of high transaction demand. Resulting transaction delays, increased fees, and backlogged workflows to disrupt dependence on timely settlements.

For L2s, scalability constraints may be reduced where designs target throughput, but bottlenecks can shift to L2 execution and operating layers (e.g., sequencer capacity, DA throughput where applicable, or bridge/exit infrastructure), and some designs may not materially improve throughput under stress.

Mitigation strategies for L1s

- For public blockchain ecosystems: protocol upgrades to enhance throughput, support for L2 scaling solutions (such as rollups and sharding), optimization of block propagation, transaction compression, and dynamic fee mechanisms.
- For financial institutions: evaluating network scalability and transaction performance during due diligence, continuous real-time monitoring of transaction latency and fee volatility, designing workflows with fallback or batching capabilities, and preparing contingency measures for migrating workflows during sustained network congestion.

Mitigation strategies for L2s

- For public blockchain ecosystems: dimensioning sequencer, data availability, and bridge capacity for expected usage, monitoring queue lengths, fees, and latency, transparently communicating congestion conditions, and stress testing under load.
- For financial institutions: selecting L2s with transparent performance characteristics and demonstrated capacity that fits the specific application use cases, monitoring congestion and bridge delays, and maintaining procedures to batch, pause, or revert to L1 where necessary.

Inter-chain connection disruption risk: Multi-chain deployments rely on cross-domain connectivity (e.g., routing layers, bridges, relays, and other connection pathways) to move assets and messages between domains. Outages, degradation, or operator failures in these connections can delay transfers, strand liquidity, interrupt workflows, and create operational breaks that require manual reconciliation and client remediation.

For L2s, the core cross-domain dependency is the L1/L2 connection pathway (e.g., deposits, withdrawals, and message posting), where disruption can delay transfers, strand liquidity, and materially degrade exit and settlement flows.

Mitigation strategies for L1s

- For public blockchain ecosystems: not typically a core L1 protocol risk in single-chain operation; where ecosystem-supported cross-domain routes exist, provide clear operational status telemetry and incident communications for those routes and encourage resilient connection designs.
- For financial institutions: not typically applicable for single-chain L1 usage; where cross-domain routes are used, treat the connection pathway as a critical dependency with explicit monitoring, reconciliation, and client-impact playbooks.

Mitigation strategies for L2s

- For public blockchain ecosystems: designing cross-domain connectivity to tolerate failure of a single critical operator or route, providing health monitoring and incident communications for connection pathways, and documenting recovery expectations and operational procedures under degraded conditions.
- For financial institutions: restricting critical activity to approved routes, monitoring route health, maintaining playbooks to pause or reroute flows when connections degrade, and implementing reconciliation and client communication procedures.

Interoperability mechanism failure risk: Cross-domain interoperability mechanisms can introduce failures where assets and messages are represented, transferred, or interpreted inconsistently across domains. Weaknesses in interoperability design or operation can result in incorrect routing, inconsistent outcomes across domains, or loss events that propagate across multiple chains, increasing contagion and complexity of remediation.

For L2s, interoperability failures can arise in bridging and cross-layer messaging (e.g., inconsistent representations or routing), creating mismatches between L1 and L2 expectations, impairing exits, and increasing the operational burden to reconcile and remediate cross-layer outcomes.

Many institutional workflows span more than one ledger domain, including L1 to L2 routing and transfers across multiple L1s using bridges or native interoperability. In these settings, connection pathways and interoperability mechanisms become critical infrastructure. Failures can strand assets, create inconsistent representations, or propagate disruption across domains. Diversification only reduces risk when routes, operators, and data paths are genuinely independent.

Mitigation strategies for L1s

- For public blockchain ecosystems: not typically a core L1 protocol risk in single-chain operation; where ecosystem-supported interoperability exists, encourage standardized patterns, strong assurance practices, and transparent change management for interoperability mechanisms.
- For financial institutions: not typically applicable for single-chain L1 usage; where interoperability is used, define explicit risk limits and governance for supported routes and representations and require clear operational recourse and escalation expectations.

Mitigation strategies for L2s

- For public blockchain ecosystems: promoting well-defined cross-domain standards, publishing clear assumptions and operating models for interoperability mechanisms, and maintaining change management and incident response processes for shared cross-domain components.
- For financial institutions: limiting exposure to approved routes and mechanisms, performing enhanced due diligence and ongoing monitoring, enforcing strict routing and exception-handling controls, and maintaining tested procedures to suspend and resume cross-domain activity.

Technology risk: Key Differences for Public Permissioned Blockchains

The mitigation strategies operate slightly differently for public permissioned blockchains, where validator roles are often centrally administered and controlled. Such blockchain networks, typically governed by consortia, member associations, or trusted entities, can explicitly mandate and typically also contractually enforce deployments aligned with financial institution regulatory standards. Furthermore, permissioned participation enables stricter orchestration and can include legally binding service level commitments. Where an L2 is deployed in a permissioned model, the same operating model can extend to L2-specific control points (e.g., sequencing, bridge, operations, upgrade authority), while any anchoring to a L1 remains a dependency for settlement and recovery. It can, however, reintroduce degrees of concentration risk when oversight, or other critical roles, rest with a single or a coordinated set of organizations.

5.2. Information security risk

Blockchain introduces security challenges with specific operational, legal, and reputational implications. Blockchains are connected data domains, and it is therefore important to not only secure the data and information shared on-chain, but also to ensure that sensitive information is not shared in the first place to avoid potential leakage to third parties. Privilege risks may also arise from the configuration and governance of administrative roles used for upgrades and emergency actions. In addition, public blockchains are permanently exposed to potential malicious actors, and while encryption and blockchain architecture provide safeguards, specific elements related to interoperability (such as bridges) remain vulnerable and need to be carefully protected and utilized with due care.

Blockchains are permanently interconnected; vulnerability in one area can have cascading effects across others. A holistic network-wide approach is therefore required to manage these risks.

5.2.1. Public blockchain risks and mitigation strategies

See Appendix for detailed matrix: **Table A.2**

Risk of data loss					
Ability to mitigate (1 = low ability to mitigate; 5 = high ability to mitigate)					
	1	2	3	4	5
L1s					
					Institutions have strong, well-understood control levers for key custody (e.g., HSMs, dual control, multi-sig/threshold schemes, backup and recovery processes) and can independently validate ledger state through their own infrastructure. Residual exposure remains where loss events involve end-user keys, third-party custodians, or ecosystem-level dependencies outside the institution's direct control.
L2s					
					Data-loss risk broadens on L2s to additional privileged keys and operational roles, requiring institutions to monitor and manage both L1 and L2 conditions in parallel. Mitigation is primarily through strong key governance and operational controls, with recovery assumptions varying by L2 design depending on how data availability and recovery are implemented.

Private key loss and inadequate key management practices: Public blockchains require the use of cryptographic keys to authorize transactions and other uses. The responsibility of safely administering and utilizing these keys falls on users or their custodians. Inadequate management or loss of these keys can permanently prevent access to and usability of the associated data, causing financial loss, operational disruptions, and reputational damage.

For L2s, the key-management expands to include additional privileged roles and operational keys (e.g., sequencer/batcher keys, bridge and contract-admin keys, and prover/DA roles where applicable), meaning compromise or loss can affect L2 operations and the ability to exit or recover via the underlying L1.

Mitigation strategies for L1s

- For public blockchain ecosystems: promoting secure key-management standards, enabling multi-signature or threshold schemes, encouraging robust backup practices, and supporting protocol-level key recovery solutions.

Mitigation strategies for L2s

- For public blockchain ecosystems: defining and enforcing key-management expectations for L2 privileged roles (sequencing, bridging, upgrades, and DA/proving where applicable), encouraging multi-signature/threshold controls, scoped keys and rotation, and designing upgrade and recovery procedures that minimize dependence on any single key or operator.

- For financial institutions: adopting institutional-grade custody solutions incorporating hardware security modules (HSMs), enforcing dual-control access policies, monitoring key usage in real-time for anomalies, establishing clear procedures for key revocation, and maintaining structured key recovery processes.
- For financial institutions: applying the same institutional-grade controls to L2-related keys and roles (including bridge/admin interactions), segregating duties across L1 and L2 operations, continuously monitoring privileged-role changes/events on L2 and bridges, and maintaining tested procedures to revoke, rotate, or migrate keys and to shift to approved fallback routes during key incidents.

Compromised data integrity: Data on public blockchains depends on secure peer-to-peer communications and consensus among distributed nodes. Malicious nodes or network-level attacks such as message tampering or relay hijacking could inject corrupted data, disrupt consensus, or cause temporary ledger forks, leading to operational disruption and delayed or rejected transactions.

For L2s, integrity risk extends to cross-layer communications and services (e.g., L2 nodes, sequencers, data-availability providers as applicable, data withholding, and bridge pathways), where disruption or tampering can create inconsistent L2 state, failed submissions to the L1, or impaired withdrawal and settlement flows.

Mitigation strategies for L1s

- For public blockchain ecosystems: enforcing secure peer communication protocols, promoting node diversity, conducting regular protocol hardening, and continuous monitoring for fork anomalies and ledger inconsistencies.
- For financial institutions: maintaining redundant validation infrastructure, performing off-chain reconciliations, continuously monitoring ledger consistency and node performance, automated node shutdown, and documented failover plans when ledger integrity is impacted.

Mitigation strategies for L2s

- For public blockchain ecosystems: enforcing secure communication and integrity checks for L2 networking, bridge, and DA channels, hardening L1–L2 and intra-L2 message validation, and monitoring for divergence between L2 views and L1 submissions (and across any DA/bridge providers).
- For financial institutions: maintaining independent views of L1 and L2 state where critical, reconciling positions across L2 and bridge pathways back to L1, monitoring for inconsistencies or delayed updates, and maintaining automated response and exit/failover playbooks when L2 or cross-layer integrity is in doubt.

Cyber risk events					
Ability to mitigate (1 = low ability to mitigate; 5 = high ability to mitigate)					
	1	2	3	4	5
L1s					Institutions have meaningful control levers to reduce cyber risk exposure through selection, defensive engineering, monitoring, and operational playbooks (e.g., pausing or rerouting activity during instability). However, the most material cyber event drivers at L1, consensus concentration, protocol-level vulnerabilities, and cryptographic dependencies, are structurally hard to change quickly, so mitigation is often achieved through buffers and response readiness rather than direct control.
L2s					L2s add additional cyber-relevant control points (e.g., narrower governance and clearer operational ownership over sequencing, bridges, and upgrades), which can improve responsiveness to incidents. However, layered deployments compound exposure across L1 and L2, and disruption in either layer can impair processing, access, or exits. Institutions therefore need parallel monitoring and response playbooks across both layers; improved L2 telemetry and exercise evidence can strengthen readiness but does not remove L1-derived cyber exposure.

Consensus attack: Public blockchain networks depend on decentralized validator sets to ensure secure and accurate transaction processing. Excessive concentration of mining or staking power amongst a coordinated set of validators could enable malicious actors to achieve majority control (51% attack), potentially allowing them to manipulate transaction ordering, censor legitimate transactions, or reorganize the blockchain. Such attacks compromise transaction integrity and disrupt network reliability.

For L2s, the same risk as L1 can manifest as effective majority control over critical roles (e.g., sequencing, validation/committees, or DA where applicable), where concentrated operator control, not classic “51%” dynamics, can enable censorship, ordering manipulation, or prolonged halts and delayed exits.

Mitigation strategies for L1s

- For public blockchain ecosystems: incentivizing decentralized validator participation, implementing staking caps and slashing or other incentive mechanisms, continuous monitoring of validator distribution and consensus behavior, and rapidly activating governance-driven interventions.
- For financial institutions: selecting networks with robust decentralization and active governance, continuously monitoring validator concentration and consensus health, diversifying exposures across blockchain networks, pausing transactions during consensus instability, and maintaining plans for migration in cases of compromise.

Mitigation strategies for L2s

- For public blockchain ecosystems: designing sequencing, validation, and data-availability roles to avoid single-operator or tightly concentrated control, monitoring concentration and liveness across critical operators, and defining governance interventions for observed collusion or abuse.
- For financial institutions: selecting L2s with credible paths to reduced operator concentration, monitoring sequencer and liveness, diversifying exposures where appropriate, pausing L2-dependent activity during instability, and maintaining documented failover plans to shift activity.

Denial of service (DoS) attacks: Public blockchain nodes are inherently susceptible to DoS attacks, which overwhelm them with excessive traffic or transaction requests, causing network congestion, latency, and operational disruption.

For L2s, DoS can target L2 entry points and supporting services (e.g., sequencers, L2 RPC/gateways, DA services where applicable, or bridge infrastructure), halting or degrading processing and delaying exits, with impact often more acute where critical services are centralized or off-chain.

Mitigation strategies for L1s

- For public blockchain ecosystems: implementing protocol-level rate limiting, spam protection, and DoS mitigation solutions, continuously monitoring transaction and traffic volumes, and providing emergency rerouting or prioritization capabilities.
- For financial institutions: evaluating network resilience during infrastructure selection, monitoring real-time memory pool (mempool), congestion, transaction delays, and fee volatility, establishing operational buffers, postponing or rerouting critical transactions, and maintaining alternative processing pathways and response protocols.

Mitigation strategies for L2s

- For public blockchain ecosystems: implementing DoS mitigation across L2 entry points, monitoring traffic and queue buildup, providing controlled degradation and prioritization for critical transactions and exits, and ensuring L2 disruption does not prevent users from exiting or recovering via L1 mechanisms where applicable.
- For financial institutions: assessing L2 resiliency during selection, monitoring L2 congestion and bridge delays alongside L1 conditions, defining playbooks to pause or reroute activity away from impacted L2s or routes during sustained attacks, and maintaining alternative pathways (including direct L1 processing) for critical transactions.

Cryptographic vulnerabilities: Public blockchain networks rely heavily on cryptographic algorithms such as ECDSA or EdDSA, which may become vulnerable to future quantum computing advancements or cryptanalytic breakthroughs. Exploitation of these vulnerabilities could compromise private keys, enabling unauthorized transactions, theft, or network-wide loss of trust.

For L2s, cryptographic dependency extends beyond transaction authentication to additional primitives and privileged keys used by the L2 and its bridges (e.g., proof systems where applicable and committee/operator signing), meaning a weakness can compromise L2 operation and affect assets and routes anchored to the underlying L1.

Mitigation strategies for L1s

- For public blockchain ecosystems: integrating quantum-resistant cryptographic schemes into future protocol upgrades, reducing public key exposure through transaction design, continuous monitoring of cryptographic research, and rapid emergency upgrade pathways.
- For financial institutions: adopting quantum-resilient key management practices, minimizing public key reuse and exposure, actively monitoring for unusual wallet activity, and maintaining contingency procedures for rapid key rotation or asset quarantining in case of suspected compromise.

Mitigation strategies for L2s

- For public blockchain ecosystems: assessing and hardening cryptographic components used in L2 protocols (including proof systems and bridge or committee schemes), minimizing exposure and lifespan of operator keys, identifying quantum-resistant tooling, and defining coordinated emergency-upgrade procedures aligned with the underlying L1 where relevant.
- For financial institutions: applying quantum-resilient practices to keys used for L2 access and operations (including bridge and contract-admin keys), monitoring activity across both layers, and maintaining tested procedures to rotate keys, adjust routing, or move assets away from affected L2s or bridges if vulnerabilities are identified.

Smart contract errors and exploits: Due to their complexity and immutability upon deployment, blockchain smart contracts and core protocol code carry inherent risks of irreversible logical errors or vulnerabilities that could cause permanent adverse consequences. Errors discovered post-deployment could result in permanent transaction failures, unauthorized asset transfers, or severe operational disruptions. Increased availability of automated tooling (e.g., artificial intelligence) may shorten the time between vulnerability introduction and exploitation, increasing the importance of continuous testing and rapid response.

For L2s, the attack surface expands to additional system and bridge contracts (e.g., rollup core and data-availability/system components where applicable), where defects can disrupt L2 processing, impair exits to the underlying L1, and create cross-layer state inconsistencies.

Mitigation strategies for L1s

- For public blockchain ecosystems: rigorous coding standards, comprehensive pre-deployment audits and formal verification, supporting upgradable contract frameworks, real-time anomaly detection, and emergency contract upgrade or halt mechanisms activated via community governance with clear controls over upgrades and pause authority.
- For financial institutions: relying on strictly audited libraries and upgradable designs for critical contracts, implementing multiparty authorization processes, real-time monitoring for execution anomalies, and rapid activation of predefined emergency patches or migration to secure contract versions upon detection of vulnerabilities, and strengthening secure-development pipelines with continuous automated testing and monitoring.

Mitigation strategies for L1s

- For public blockchain ecosystems: applying the same assurance standards to L2-specific contracts and components (e.g., rollup, bridge, data-availability and system contracts), rigorously testing L1–L2 interactions and exit paths, clearly documenting upgrade and emergency-action authority over L2 contracts, and coordinating incident response and disclosure across both layers when vulnerabilities are identified.
- For financial institutions: selecting L2s with independently audited core contracts and transparent upgrade and emergency-action mechanisms, monitoring for anomalies in L2 and bridge behavior, and maintaining clear procedures to pause L2-dependent products, adjust routing, or migrate to patched contract versions or alternative routes if vulnerabilities are discovered.

Risk of data privacy breach/confidentiality mismanagement

Ability to mitigate (1 = low ability to mitigate; 5 = high ability to mitigate)

	1	2	3	4	5	
L1s						Institutions can materially reduce privacy and confidentiality exposure through architectural and procedural controls (e.g., keeping sensitive data off-chain, metadata hygiene, and disciplined address management), but the underlying transparency of public chains means de-anonymization and metadata leakage remain structurally difficult to eliminate. Once sensitive data is recorded on-chain, remediation is limited, which makes preventive controls and ongoing monitoring central to mitigation.
L2s						L2s add architectural and operating levers that can reduce what is exposed (including on the underlying L1), but institutions must manage cross-layer linkability and bridge metadata because combined L1/L2/bridge analysis can still reveal patterns. Mitigation capacity can be higher than L1 due to greater design choice, but risk may concentrate in L2 data handling, access control, and recovery assumptions, requiring stronger due diligence and monitoring.

On-chain exposure of sensitive or confidential data: Public blockchains create inherent risks of permanently exposing sensitive, personal, or confidential data if inadvertently recorded directly or via metadata leakage due to their immutable and transparent nature. Such exposure can cause irreversible privacy violations, regulatory breaches, and misuse risks.

For L2s, the same exposure risk as L1 arises where sensitive data is included in L2 transactions or state (e.g., payloads/logs or data layers where applicable), and privacy-enhancing designs may reduce what is posted to L1 while concentrating confidentiality risk in L2's own data handling, access controls, and recovery mechanisms.

Mitigation strategies for L1s

- For public blockchain ecosystems: promoting off-chain data handling, supporting privacy-enhancing architectures, scanning for improper data uploads, and facilitating smart contract proxy mappings.
- For financial institutions: strict internal controls against on-chain transmission of sensitive data, employing privacy technologies, continuous monitoring of transaction metadata, regular privacy audits, promptly migrating business logic away from affected contracts.

Mitigation strategies for L2s

- For public blockchain ecosystems: promoting L2 designs that keep sensitive data off-chain or in controlled environments (including how data is posted to L1 for availability), supporting privacy-enhancing mechanisms at L2, scanning L2 and associated L1 calldata for improper uploads, and providing guidance and tooling for embedding sensitive data.
- For financial institutions: applying the same controls to L2 and bridge interactions (including prohibiting sensitive or personal data in L2 payloads and bridge metadata), selecting L2s and routes that support appropriate privacy features, monitoring metadata and usage patterns across L1 and L2 for inadvertent exposure, and migrating or restricting routes if confidentiality risks are identified.

De-anonymization through public data analysis: Public blockchain transparency enables advanced analytics, potentially linking pseudonymous addresses to identifiable individuals or institutions, exposing sensitive financial activities and operational details. Such de-anonymization can compromise privacy, lead to regulatory scrutiny, and erode institutional trust.

For L2s, combined analysis of L1, L2, and bridge activity can link identifiers and flows across domains, including activity assumed to be isolated to a specific L2 or application, increasing linkability risk unless address management and routing controls are applied consistently.

Mitigation strategies for L1s

- For public blockchain ecosystems: integrating privacy-enhancing mechanisms like zero-knowledge proofs and stealth addresses, actively monitoring analytics tools for de-anonymization attempts, and supporting robust pseudonymity features.
- For financial institutions: using privacy-focused wallets and transaction methods, avoiding address reuse, auditing transaction patterns regularly, monitoring public analytics platforms, updating address management policies proactively, and considering transitions to networks with stronger privacy provisions if needed.

Mitigation strategies for L2s

- For public blockchain ecosystems: integrating privacy-enhancing mechanisms and routing options at the L2 and bridge layer, minimizing unnecessary linkage between L1 and L2 identifiers, monitoring analytics and research for cross-domain de-anonymization techniques, and providing guidance on avoiding patterns that make L2 activity linkable.
- For financial institutions: designing address and account-management practices that consider cross-layer linkability (L1, L2, and bridges), using privacy-aware routing or batching where appropriate, periodically reviewing how institutional patterns appear in public data and analytics, and adjusting the use of particular L2s or routes if de-anonymization risk exceeds risk appetite.

Risk of improper data access

Ability to mitigate (1 = low ability to mitigate; 5 = high ability to mitigate)

	1	2	3	4	5	
L1s						Institutions can reduce improper access and ordering-abuse exposure through venue selection, protective execution methods (e.g., private relays and batching), monitoring, and escalation playbooks. However, MEV incentives and transaction transparency are structural features of many public L1 environments, so mitigation is often achieved through controls and routing choices rather than eliminating the risk.
L2s						L2s concentrate ordering and access dynamics in additional roles and routes, which can amplify misuse risk where sequencing or relaying is centralized. Mitigation relies on protected execution paths, monitoring, and route/venue controls, but cross-layer linkability and operator discretion mean institutions must manage L1 and L2 conditions together.

Misuse of data transparency and roles: The inherent data transparency of public blockchains can allow actors that have an information advantage or that have an operator role (e.g., relayer of transaction data) that influences transaction ordering to extract value from third-party transactions. Sometimes referred to as “maximal extractable value” (MEV), this encompasses various forms of front-running, sandwich attacks transaction diversion before settlement, which can cause losses to users.

For L2s, the same MEV-style misuse risk as L1 arises where sequencing and cross-domain roles can observe and influence order flow (e.g., sequencers, shared sequencing layers, and bridge relayers), with risk often more concentrated where sequencing is centralized.

Mitigation strategies for L1s

- For public blockchain ecosystems: privacy-preserving and fair-ordering features such as commit-reveal or encrypted mempool designs, alternatives to account-based data architectures, protocol-level sequencing protections, and real-time analytics to flag ordering anomalies and isolate offending relayers.
- For financial institutions: thorough due diligence on MEV mitigations of public blockchains, submitting orders through private relays or batched channels, restricting internal access to client order flow, continuously monitoring execution timing and slippage for front-running signatures, and triggering immediate investigations, account freezes, and client notifications when anomalies surface.

Mitigation strategies for L2s

- For public blockchain ecosystems: implementing fair-ordering and privacy-preserving sequencing where feasible, supporting protected order-submission paths (e.g., private or batched channels), monitoring sequencer and relayer behavior (e.g., for MEV), and publishing transparency metrics on ordering outcomes.
- For financial institutions: selecting L2s and bridge routes with transparent MEV and ordering protection mechanisms, routing sensitive flows through protected / private order-submission channels, monitoring execution quality and slippage across L1/L2 venues for MEV, and applying investigation / escalation procedures for suspected cross-layer ordering abuse.

Privilege misconfiguration: Improperly configured smart contract permissions or decentralized application roles can enable unapproved actions, resulting in unauthorized transactions, asset mismanagement, or operational disruptions. Such misconfigurations arise from overly permissive settings, incorrect role assignments, or inadequate decentralized governance controls.

For L2s, privilege misconfiguration in roles controlling upgrades, bridges, or system parameters can enable unilateral changes to critical settings or asset flows, disrupting L2 operations and affecting assets and recovery paths anchored to the underlying L1.

Mitigation strategies for L1s

- For public blockchain ecosystems: integrating automated privilege-linting in deployment processes, clearly defining permission standards, designing upgrade keys with multi-party approval and timelocks, and enforcing best coding practices in smart contracting languages.
- For financial institutions: internal privilege audits adhering to least-privilege principles, continuous real-time monitoring of privilege usage, periodic access log reviews, immediate revocation of compromised privileges, and prompt reconfiguration and stakeholder communication after incidents.

Mitigation strategies for L2s

- For public blockchain ecosystems: extending privilege-linting and permission standards to L2 system and components, minimizing the scope of administrative and emergency roles, using multi-party and time-delayed controls for upgrade or pause authorities, and publishing clear privilege models.
- For financial institutions: mapping privileges across L2 system contracts and bridge dependencies, applying least-privilege and segregation of duties to keys and accounts that can alter L2 or bridge behavior, monitoring privileged actions for anomalies, and maintaining tested procedures to revoke, rotate, or migrate away from affected integrations.

Information security risk: Key Differences for Public Permissioned Blockchains

Validator selection in public permissioned environments typically allows for more tightly controlled patch rollouts and contractual uptime guarantees but concentrates trust in a finite operator set. To balance security and transparency, consortium charters embed validator-rotation schedules, independent code-audit obligations, mandatory incident disclosures, and performance dashboards, while members still operate geographically distributed nodes and independent threat monitoring. Where L2 components are used, the same dynamic applies to sequencers, bridge operators, and administrative roles, explicit controls are easier to define and enforce, but these roles become concentrated control points that require strong key governance, access monitoring, and independent oversight.

5.3. Financial crime risk

Financial crime risk presents distinct challenges within the blockchain ecosystem due to the global and immediate nature of blockchain-based settlements. While financial crime risks exist on all rails and can manifest differently on blockchain infrastructures compared to traditional systems, the transparent nature of public blockchains can enhance detection and mitigation when supported by adequate controls.

Transactions executed on public blockchains are atomic, borderless, and irreversible, introducing specific vulnerabilities related to money laundering, terrorist financing, proliferation financing, sanctions evasion, and corruption. While public blockchains offer transaction-level transparency due to their openly accessible ledgers, the pseudonymous nature of users complicates identity verification and transaction attribution.

To address these challenges, financial institutions can consider supplementary solutions designed to incorporate advanced anti-money laundering (AML) analytics, digital identity verification, controlled environments, and enhanced transaction monitoring capabilities.

This section consolidates mitigation strategies for financial crime risks due to the substantial overlap in control measures, focusing on shared preventive, detective, and corrective practices for both public blockchain ecosystems and financial institutions.

5.3.1. Public blockchain risks and mitigation strategies

See Appendix for detailed matrix: **Table A.3**

Risk of money laundering and terrorism financing					
Ability to mitigate (1 = low ability to mitigate; 5 = high ability to mitigate)					
	1	2	3	4	5
L1s					Institutions have well-established levers to mitigate AML/TF exposure through KYC/KYT, allowlisting, transaction monitoring, analytics-driven investigations, and rapid escalation and reporting. However, the baseline environment remains pseudonymous and globally accessible, and typologies such as layering through multiple venues and intermediaries persist, meaning mitigation is meaningful but not complete.
L2s					AML/TF risk can broaden on L2s through higher transaction velocity and cross-layer routing, requiring monitoring across both L1 and L2 and the pathways between them. Some L2 environments add operational control points (e.g., clearer operator roles, route policies, or controlled participation patterns) that can improve mitigation within a defined perimeter, but overall mitigation capacity is typically similar to L1 with greater operational complexity. Privacy-enhancing designs and high-risk bridge routes can reduce observable signals and accelerate dispersion, increasing reliance on route controls and cross-layer tracing.

Obfuscation via complex multistep transfers: Public blockchain networks enable complex transaction flows involving multiple wallets, decentralized exchanges, bridges, mixers, and smart contracts without consistent identity linkage. These features significantly enhance layering, allowing rapid asset movement that obscures transaction origins, complicating transaction monitoring and AML compliance.

For L2s, layering can intensify through high-velocity transfers and cross-layer bridging (e.g., rapid routing between L2 venues and back to L1), requiring monitoring across L1, L2, and the bridge pathways between them to preserve end-to-end traceability.

Illicit-fund(s) integration: Weaknesses in customer due diligence and inconsistent transaction monitoring during asset issuance, token trading, or use of on/off-ramps allow illicit actors to introduce funds into legitimate financial systems through blockchain assets. This undermines AML effectiveness, hampers traceability of illicit funds, and increases regulatory exposure.

For L2s, additional entry points can create uneven screening (e.g., bridges, L2-native venues, and operator-mediated routes), allowing illicit funds to enter on an L2 and later surface on an L1 through bridging, increasing containment and remediation complexity.

Terrorist and proliferation financing: Public blockchains offer pseudonymous participation and privacy-enhancing mechanisms, such as mixers, privacy coins, and stealth addresses, potentially enabling covert financial transfers. These features complicate the detection and monitoring of illicit fund flows, heightening the risk of regulatory breaches and exposure to terrorist financing and proliferation financing.

For L2s, privacy-enhancing designs or operator-mediated pathways can reduce observable signals, and bridges can accelerate dispersion across domains, increasing reliance on cross-layer tracing and route controls; where controlled participation or screened gateways exist, exposure can be reduced within that perimeter, but boundary activity can reintroduce the same typologies.

Mitigation strategies for L1s

- For public blockchain ecosystems: promoting open transaction transparency standards, encouraging ecosystem wide integration of optional compliance tooling, and enabling blockchain data accessibility to support analytics and community-driven anomaly detection. Public blockchain ecosystems can also provide mechanisms for optional tagging and rapid isolation of suspicious assets, facilitating responsive governance interventions and community-based response frameworks.
- For financial institutions: strict implementations of robust KYC and KYT procedures, restricting interactions primarily to pre-vetted or whitelisted counterparties, and leveraging transaction profiling tools. Institutions should conduct real-time analytics monitoring to swiftly detect suspicious transaction patterns and anomalous fund flows. When suspicious activity is identified, financial institutions may freeze implicated assets, initiate forensic investigations, escalate incidents internally, and fulfill regulatory reporting obligations without delay.

Mitigation strategies for L2s

- For public blockchain ecosystems: promoting equivalent transparency and data accessibility for L2 and bridge activity so compliance tooling and analytics can operate end-to-end, standardizing identifiers and metadata for bridged representations, and supporting effective flagging and escalation processes as assets move across layers. Where privacy-enhancing designs or screened gateways are used, auditability and access control expectations should be clearly defined and observable in practice (e.g., service-health telemetry, incident logs, and post-event reviews).
- For financial institutions: extending KYC, KYT, and transaction monitoring to treat L2s and bridge routes as explicit risk objects, including cross-layer tracing, route controls (e.g., approved venues/routes and higher-risk thresholds for bridging and privacy pathways), and due diligence on L2-specific mitigation features (including how they behave under L1 degradation). Institutions should maintain playbooks to contain suspected activity across layers, including pausing impacted routes, tightening allowlists, escalating to relevant operators/providers where applicable, and fulfilling regulatory reporting obligations without delay.

Risk of sanctions violations

Ability to mitigate (1 = low ability to mitigate; 5 = high ability to mitigate)

	1	2	3	4	5	
L1s						Institutions have meaningful levers to mitigate sanctions exposure through rigorous onboarding and transaction screening, wallet and counterparty allowlisting, and continuous use of blockchain analytics and internal watchlists, supported by clear escalation, freezing, and reporting playbooks. However, pseudonymity, indirect exposure through intermediaries, and fast-moving typologies mean screening is effective but not complete.
L2s						Sanctions risk can broaden on L2s through cross-layer routing and bridging, where exposure may be introduced on one layer and realized on another, requiring screening across L1, L2, and bridge pathways. Some L2 deployments can support more controlled routing or permissioning patterns for regulated domains, improving mitigation within that perimeter, but overall mitigation capacity is typically similar to L1 with added operational complexity.

Sanctions evasion risk: Public blockchain networks can enable sanctioned individuals or entities to bypass international financial restrictions more easily through pseudonymous transactions, privacy-enhancing tools, and decentralized exchanges. This lack of embedded identity verification complicates traditional sanctions screening, increasing regulatory risk and the potential for enforcement actions against institutions.

For L2s, evasion can be accelerated through high-velocity transfers and bridging, and screening must account for assets and identifiers moving between L1 and L2 and across bridged representations to avoid cross-layer coverage gaps.

Insufficient screening of on-chain transactions and counterparties: The pseudonymous nature and global accessibility of blockchain transactions complicate effective sanctions and compliance screening, allowing sanctioned actors to interact undetected with institutional or client-controlled assets. Limited integration of analytics and screening mechanisms into financial market applications using public blockchain exacerbates the challenge, increasing the risk of prohibited transactions.

For L2s, uneven screening coverage across bridges, L2-native venues, and cross-layer flows can create gaps where sanctioned exposure is introduced on one layer and realized on another, increasing the likelihood of prohibited activity before detection and containment.

Mitigation strategies for L1s

- For public blockchain ecosystems: include promoting standardized address-screening mechanisms for financial market use cases, transaction metadata standards, and integrations with third-party compliance providers. Public blockchain ecosystems could also assist detection efforts and enable community-driven identification and flagging of suspicious transactions for rapid intervention.
- For financial institutions: performing rigorous, real-time sanctions screening during onboarding and transaction processing, inclusive of wallets, restricting interactions to pre-screened wallets and counterparties, screening of jurisdictions watchlists, and continuously leveraging blockchain analytics and internal watchlists. Institutions should swiftly freeze implicated assets, halt prohibited transactions, escalate incidents internally, and ensure prompt reporting to relevant regulatory authorities.

Mitigation strategies for L2s

- For public blockchain ecosystems: extending standardized address-screening and transaction-metadata patterns across major L2 venues and bridge routes for financial market use cases, including consistent identifiers for bridged representations, enabling community-driven identification and flagging suspicious transactions for intervention, and supporting opt-in screening or allowlisting hooks where regulated domains use controlled participation.
- For financial institutions: extending real-time screening and analytics coverage across L1, L2, and bridge activity, treating bridging and cross-layer routing as explicit screening objects, restricting activity to pre-screened wallets and approved routes, and using allowlisted / controlled domains where appropriate. Institutions should rapidly freeze implicated assets, halt prohibited transactions, escalate incidents internally, and ensure prompt reporting to relevant regulatory authorities, including playbooks for cross-layer containment (e.g., pausing specific bridge routes or L2 pathways).

Risk of bribery and corruption

Ability to mitigate (1 = low ability to mitigate; 5 = high ability to mitigate)

	1	2	3	4	5	
L1s						Institutions have meaningful levers to mitigate bribery and corruption exposure through governance and control design (e.g., segregation of duties, multiparty approvals, enhanced due diligence, and PEP screening), supported by monitoring and investigation workflows. However, bribery typologies often rely on off-chain context and can be structured to appear economically “normal” on-chain, limiting the effectiveness of blockchain-only signals and making prevention and internal controls central to mitigation.
L2s						Bribery and corruption risk can broaden on L2s through higher transaction velocity and cross-layer routing, including bridging, which can accelerate layering and reduce observability across venues and routes. Some L2 deployments can support more controlled operating environments (e.g., allowlisted participation or screened gateways for regulated domains), strengthening mitigation within that perimeter, but overall mitigation capacity is typically similar to L1 with added operational complexity and more routes and operators to manage.

Crypto-facilitated bribery: Pseudonymous blockchain transactions can facilitate covert cross-border transfers, enabling bribery payments to public officials or corporate insiders. The inherent anonymity and global accessibility make detecting these illicit payments challenging, making it easier for allowing such transactions to bypass traditional financial controls and anti-corruption oversight.

For L2s, rapid transfers and bridging can accelerate layering and fragment activity across venues, reducing observability and requiring monitoring across L1, L2, and the bridge routes between them to detect and contain bribery-linked flows.

Mitigation strategies for L1s

- For public blockchain ecosystems: providing infrastructure to integrate analytical tools to detect unusual patterns and enabling community-based flagging.
- For financial institutions: implementing multiparty authorizations and enhanced transaction due diligence, politically exposed person (PEP) scans; using specialized analytics tools for real-time monitoring of payment flows, freezing suspicious transactions, initiating internal investigations, and reporting incidents to regulatory authorities.

Mitigation strategies for L2s

- For public blockchain ecosystems: enabling bribery-typology analytics and community-driven flagging with coverage for major L2 venues and bridge routes, and where regulated/allowlisted domains are supported, providing opt-in perimeter controls (screened access points and route policies) that strengthen monitoring and enforcement.
- For financial institutions: extending enhanced due diligence, PEP screening, and multiparty approvals to L2 and bridge workflows, applying route controls for higher-risk venues and pathways, monitoring cross-layer payment patterns in real time, and where concerns arise, freezing or quarantining assets, initiating investigations, and reporting to relevant authorities without delay.

Risk of KYC/transaction monitoring control failure					
Ability to mitigate (1 = low ability to mitigate; 5 = high ability to mitigate)					
	1	2	3	4	5
L1s					Institutions can mitigate control failure through strong perimeter controls (KYC/KYT onboarding, allowlisted counterparties, and continuous monitoring and escalation), but identity and monitoring are not embedded at the network level. Where institutional activity must interact with open addresses, public venues, or permissionless smart contracts, screening becomes probabilistic and dependent on analytics coverage, leaving meaningful residual exposure.
L2s					Control failure can be mitigated more strongly where L2 deployments support controlled environments (e.g., allowlisted participation, gated venues, or policy-constrained routes), improving KYC coverage within that perimeter. However, L2s introduce additional entry/exit points (notably bridges) and higher-velocity flows, so institutions must manage screening and monitoring across both L1 and L2 pathways to avoid gaps.

Absence of KYC and adequate monitoring: The accessible nature of public blockchains allows transactions without formal identity checks, which can lead to illicit activities like money laundering, fraud, and sanctions evasion. The absence of embedded identity verification and transaction monitoring can allow illicit transactions to enter financial institutional systems if not addressed.

For L2s, control gaps can be amplified by higher transaction velocity and additional access points (e.g., bridges and L2-native venues), requiring monitoring across both L1 and L2 pathways; where an L2 enforces permissioning (e.g., allowlisted participants or applications), KYC coverage can improve within that domain, but risk shifts to admission controls, perimeter enforcement, and boundary activity.

Mitigation strategies for L1s

- For public blockchain ecosystems: promoting optional identity verification standards, facilitating integration of transaction monitoring solutions, and enabling community-driven reporting mechanisms for suspicious activities.
- For financial institutions: strict KYC/KYT onboarding processes, robust real-time transaction monitoring and analytics-driven auditing, immediate suspension of suspicious transactions, account isolation, and prompt regulatory reporting.

Mitigation strategies for L2s

- For public blockchain ecosystems: enabling equivalent compliance integration at L2 entry points and dominant venues (including bridge pathways) through optional identity and monitoring hooks, consistent metadata for cross layer tracing, and transparent logging and incident communications to support investigation and escalation.
- For financial institutions: extending KYC and KYT and transaction monitoring to cover L2s and bridge routes as explicit risk objects, enforcing route and venue controls (including allowlists and higher scrutiny for boundary activity), and maintaining playbooks to pause activity, isolate exposures, and escalate and report promptly where monitoring indicates suspected breaches.

Financial crime risk: Key Differences for Public Permissioned Blockchains

In public permissioned environments, validator admission and user access are often curated, allowing networks to enforce policy requirements (including KYC and transaction monitoring expectations) more directly at the perimeter and to support contractual accountability through consortium arrangements. This can materially strengthen controls for in scope activity, but it concentrates reliance on governance, list management, and operator discipline, so consortium charters should define independent oversight, change controls, audit rights, and incident disclosure expectations, while institutions continue to operate their own compliance stack to manage residual and boundary risks.

5.4. Business continuity risk

Public blockchains can serve as the ultimate source of transaction and ownership truth for asset ownership and transaction settlement—any outage, attack, or fork can freeze transaction activity and cast doubt on asset records. Ensuring continuity under stress is therefore critical to protect users and maintain market confidence. Robust Business Continuity Planning (“BCP”) can mitigate such risks, providing actionable mitigation strategies at both the level of financial institutions and public blockchain ecosystems.

It is vital to set impact tolerances for disruptions, defining how long and under what conditions individual participants can tolerate outages or errors. Impact tolerances and recovery plans should reflect the criticality of underlying networks and key service dependencies.

5.4.1. Public blockchain risks and mitigation strategies

See Appendix for detailed matrix: **Table A.4**

Inadequate business continuity planning/event management					
Ability to mitigate (1 = low ability to mitigate; 5 = high ability to mitigate)					
	1	2	3	4	5
L1s					
Business continuity risk is materially mitigatable through institutional controls via integrating blockchain disruption scenarios into BCP/DR, maintaining redundant infrastructure and monitoring, defining pause and reroute procedures, and using alternative rails or networks where required. Residual exposure persists because institutions cannot control the timing, severity, or governance response of ecosystem-level incidents, and some disruption modes will still impair settlement, reconciliation, and client service.					
L2s					
Business continuity planning must cover both the underlying L1 and the L2 stack, including additional operational dependencies and recovery assumptions, which increases complexity and expands the set of critical failure points. Mitigation is achievable through parallel monitoring, predefined reroute/fallback paths, and tested incident playbooks, but disruptions in sequencing, bridging, or other critical components can halt processing or delay recovery even when the L1 remains stable.					

Inadequate business continuity and recovery planning: Financial institutions face significant risks if unable to promptly recover critical operations following public blockchain disruptions, due to inadequate business continuity and disaster recovery plans. Limited integration of blockchain-specific disruptions into existing frameworks, coupled with unclear recovery protocols and dependencies on infrastructures without robust fallbacks, can severely impact transaction processing, settlements, compliance, and reputation.

For L2s, disruption scenarios broaden to include L2-specific operational dependencies (e.g., sequencer liveness, DA liveness where applicable, bridge/withdrawal pathways, and pause/upgrade controls), implying recovery planning must cover both layers and cross-layer assumptions for exits and reconciliation, including how internal ledgers are resynchronized after restoration.

Mitigation strategies for L1s

- For public blockchain ecosystems: advanced communication of upgrade schedules, promotion of modular node architectures, diversity of node implementation, proactive and freely available blockchain monitoring, development of community-driven disaster recovery plans, incentivization of associated node operator responsibilities, and tools for rapid node redeployment.
- For financial institutions: incorporating blockchain scenarios into business continuity plans, maintaining fallback systems and documented plans, operating own nodes, continuous monitoring of network dependencies, transaction rerouting, and joining community-driven disaster recovery efforts.

Mitigation strategies for L2s

- For public blockchain ecosystems: defining clear incident and recovery procedures for critical L2 components (e.g., sequencing, DA, and canonical bridging/withdrawal pathways), publishing service-health telemetry and incident communications, designing credible degraded-mode behavior (including how exits behave under stress), providing institutions resynchronization guidance, and exercising recovery scenarios with transparent outcomes.
- For financial institutions: incorporating L2 outages and exit-path delays into BCP/DR, monitoring L1 and L2 conditions in parallel, defining playbooks to pause intake and reroute activity, and testing recovery, reconciliation, and client communication under L2-specific failure modes (sequencer outage, DA outage, bridge pause, forced-exit conditions).

Dependency on external governance for network recovery: Financial institutions face risks when relying on decentralized blockchain governance structures without formal escalation or recovery procedures. Distributed community governance processes can delay decision-making during critical incidents like protocol bugs, security breaches, or operational failures, leading to potentially extended network downtime and transactional disruptions.

For L2s, recovery dependencies broaden to include both L2 governance and emergency controls (e.g., contracts, bridges, operator roles) and the underlying L1's incident and governance response, which can delay resolution even when the institution's own infrastructure is healthy.

Mitigation strategies for L1s

- For public blockchain ecosystems: implementing transparent and proactive governance frameworks, clear emergency protocols, regular incident responsiveness monitoring, development of community-driven disaster recovery plans, incentivization of associated node operator responsibilities, expedited patch distribution, and coordinated recovery tools.
- For financial institutions: conducting due diligence on governance maturity, maintaining active participation or relationships within governance communities, closely tracking governance activities for delays, and establishing robust internal fallback infrastructure and contingency processes for managing extended disruptions.

Mitigation strategies for L2s

- For public blockchain ecosystems: clearly defining emergency authority and escalation paths for L2 contracts/bridges, publishing recovery playbooks and decision criteria, coordinating incident assumptions with the underlying L1 where relevant, and exercising incident drills that include critical operators and cross-layer dependencies.
- For financial institutions: assessing L2 governance and emergency-action mechanisms as part of onboarding, establishing escalation channels with key L2 stakeholders, monitoring L1 and L2 incident signals in parallel, and maintaining predefined playbooks to pause activity, constrain routes, and shift processing while governance recovery is underway.

Withdrawal delay / exit-queue risk: Timely withdrawals are critical for liquidity management, settlement obligations, and client servicing. In layered deployments, withdrawals and exits can be delayed by operational disruption, congestion, or throttling at key pathways (e.g., bridging, sequencing), resulting in queued exits and prolonged time to recover assets or complete transfers.

For L2s, withdrawal and exit risk is structurally more material because the practical exit path depends on L2-specific components and cross-layer routing (e.g., sequencer/bridge processing and protocol-defined latency), so exit delays and queued withdrawals can occur even when the underlying L1 remains live.

Mitigation strategies for L1s

- For public blockchain ecosystems: not typically a distinct L1 risk; comparable delay dynamics are generally addressed through congestion management and resilience mechanisms reflected in scalability and finality controls.
- For financial institutions: not typically a distinct L1 risk; mitigate through conservative confirmation policies, monitoring, and operational buffers aligned to transaction processing and settlement needs.

Mitigation strategies for L2s

- For public blockchain ecosystems: defining and publishing expected withdrawal/exit behavior under normal and degraded conditions, providing transparent monitoring for withdrawal pathways and queue health, designing operating models that prevent a single component failure from blocking exits, and ensuring recovery procedures are workable under stress.
- For financial institutions: treating exit pathways as critical dependencies, monitoring queueing and route health alongside L1 and L2 liveness and finality, maintaining playbooks to pause intake and reroute flows when exit delays breach impact tolerances, and sizing liquidity and settlement buffers to withstand credible exit delays.

Business continuity risk: Key Differences for Public Permissioned Blockchains

Public permissioned blockchains leverage controlled validator and node management to establish continuity strategies. By embedding defined governance roles, formalized recovery frameworks, and proactive monitoring protocols, these environments may be able to minimize downtime and maintain operational stability. Furthermore, public permissioned blockchains can enforce stringent business continuity standards, such as hybrid deployment models (combining on-premises, private cloud, and regulated public cloud infrastructure), and real time monitoring. Consortium-led governance provides the ability to establish clear SLAs between participants and providers, dedicated secure network connections, and clearly defined impact tolerances and recovery processes.

5.5. Third-party risk

The question of whether public blockchains should be categorized as third parties within existing risk management frameworks remains subject to ongoing debate, primarily due to their decentralized nature and lack of clearly identifiable operators. This section includes considerations for financial institutions and regulators seeking to apply traditional third-party risk management standards to mitigate risks associated with public blockchains. Additionally, the use of public blockchains commonly involves interactions with more traditional third parties, including data oracles and custodial service providers, which institutions must also factor into their risk management approaches.

5.5.1. Public blockchain risks and mitigation strategies

See Appendix for detailed matrix: **Table A.5**

Public blockchain brings about new, systemic third-party risks requiring redesign of operating models and mitigation strategies, particularly across two critical categories					
Ability to mitigate (1 = low ability to mitigate; 5 = high ability to mitigate)					
	1	2	3	4	5
L1s					
Third-party risk is partially mitigatable through selection, monitoring, and architectural controls (e.g., multi-chain exposure management, independent node operation, multi-provider connectivity, and documented failover procedures). Residual risk remains because the public network itself is not a traditional vendor: contractual accountability is limited, incident response is community-driven, and systemic events can affect multiple dependencies simultaneously.					
L2s					
Third-party exposure broadens on L2s to the underlying L1 plus higher-layer operators and route dependencies, some of which are identifiable and therefore more amenable to due diligence and operational expectations. However, the dependency chain compounds across layers and disruption in either layer can impair processing, access, or recovery, requiring institutions to manage providers and routes across L1 and L2 in parallel. Shared operators and infrastructure can also create correlation risk across multiple L2s, reducing the effectiveness of surface-level diversification unless dependencies are truly independent.					

Reliance on public blockchains: While the decentralized operational model of public blockchains inherently provides a degree of resilience, and many public blockchains have a strong performance track record, it simultaneously limits control and direct accountability over infrastructure performance through traditional means such as contracting. Traditional third-party risks such as operational disruption, which also apply to public blockchains, therefore cannot be mitigated in the traditional ways.

For L2s, reliance broadens to the underlying L1 plus additional higher-layer control points (e.g., sequencing, bridging, DA services where applicable, and route policies), which can increase accountability for specific operators but compounds dependency across layers.

Mitigation strategies for L1s

- For public blockchain ecosystems: promoting validator decentralization and diversity, transparent governance processes, continuous performance monitoring and publication of service-health indicators.
- For financial institutions: proactively developing or deploying multi-chain architectures with failover systems, continuously monitoring performance and availability, maintaining documented failover plans, and applying tiered third-party requirements and monitoring based on criticality.

Mitigation strategies for L2s

- For public blockchain ecosystems: publishing service-health telemetry and incident communications for critical L2 operators and routes (e.g., sequencer, DA, bridge), disclosing material dependencies, and designing L2 operating models that tolerate failure of a single critical operator or route without breaking recovery assumptions.
- For financial institutions: mapping the full dependency chain across L1 and L2 routes, monitoring material dependencies in parallel, and maintaining tested procedures to pause, reroute, or fall back when an upstream operator or pathway degrades

Inability to effectively manage providers: Financial institutions utilizing public blockchains often rely on specialized third-party providers (e.g., oracle data providers, node-filtering solutions, and wallet providers), whose operational failures or compliance issues could create significant risks. While some of these vendors are traditionally organized and governed, others may operate in a partially or wholly decentralized manner, leveraging techniques similar to those used by public blockchains (e.g., a network of data providers for an oracle), thus limiting the deployment of traditional third-party risk management approaches.

For L2s, provider exposure expands to additional services and route components (e.g., bridge operators, sequencer infrastructure, and DA services where applicable), increasing concentration and correlation risk where providers are shared across venues.

Mitigation strategies for L1s

- For public blockchain ecosystems: encouraging or incentivizing standardized operational transparency for ecosystem builders and defining own or leveraging existing best practices for providers in the ecosystem.
- For financial institutions: rigorous upfront due diligence assessments of third-party blockchain service providers, establish appropriate SLAs where possible, diversifying engagements across multiple providers to reduce single points of failure, continuously monitoring provider compliance and performance metrics, and developing documented contingency and provider-replacement strategies.

Mitigation strategies for L2s

- For public blockchain ecosystems: extending operational transparency expectations and best-practice guidance to higher-layer operators and route providers, including clear incident reporting and dependency disclosure for sequencing, DA, and bridge pathways.
- For financial institutions: extending third-party risk management to L2 operators and cross-domain routes, monitoring incident history and dependency concentration, and maintaining tested contingency plans to replace providers or reroute flows without weakening operational controls or client outcomes.

Shared infrastructure correlation risk: Even where institutions diversify across networks, applications, or service providers, underlying infrastructure and operator dependencies can be shared (e.g., common hosting, connectivity gateways, node/access services, or other critical providers). This can create correlated failure modes in which a single incident (outage, cyber event, misconfiguration, or operator disruption) degrades multiple venues simultaneously, reducing the effectiveness of “simple” redundancy and complicating recovery.

For L2s, correlation risk can be more pronounced where multiple L2s share critical operators or service layers (e.g., a common sequencer stack, data availability provider, or bridge pathway), creating scenarios where disruption propagates across multiple L2s and routes at once.

Mitigation strategies for L1s

- For public blockchain ecosystems: encouraging diversity of critical infrastructure and service dependencies, monitoring and publishing service-health indicators, and disclosing material shared dependencies where they create ecosystem-wide correlation risk.
- For financial institutions: conducting due diligence on dependency mapping to identify shared providers across access, connectivity, and operational tooling, setting correlation limits where dependencies are shared, and maintaining tested failover procedures that do not rely on the same underlying providers.

Mitigation strategies for L2s

- For public blockchain ecosystems: disclosing shared-dependency concentrations across critical operators and routes (e.g., sequencer, data availability provider bridge), publishing route-level telemetry and incident communications, and designing operating models that support substitution and recovery when a shared dependency fails.
- For financial institutions: validating that redundancy is truly independent (not just multi-vendor “on the surface”), monitoring shared dependencies across L1/L2/routes in parallel, and maintaining playbooks to pause, reroute, or reduce exposure when correlated incidents breach impact tolerances.

Third-party risk: Key Differences for Public Permissioned Blockchains

Public permissioned blockchain environments can combine contractual accountability with blockchain redundancy by using consortium governance, defined operating standards, and enforceable service expectations (e.g., SLAs and incident reporting). This can strengthen third-party controls through clearer escalation, audit, and remediation pathways, but it can also increase concentration risk because critical roles are assigned to a finite set of operators, making independent oversight, diversification of providers, and resilience testing central to effective risk management.

6. Adapted risks

Risks in this category require targeted adaptations of traditional non-financial risk management practices to address specific blockchain complexities like decentralization, irreversibility of transactions, immutability of records, 24/7 operations, and cross-jurisdictional global nature of blockchains.

6.1. Legal risks

Legal risks when utilizing public blockchains are driven primarily by uncertainties in how laws, regulations, and contractual obligations are enforced. These uncertainties arise from regulatory ambiguity across jurisdictions and the inherently borderless nature of blockchain, complicating the determination of applicable laws and jurisdictional authority.

Consequently, mitigating against legal risks continues to require proactive governance, clear roles and responsibilities, and a current understanding of the evolving legal landscape. Where cross-border disputes are plausible, these agreements should specify governing law, venue, and an agreed dispute-resolution mechanism.

6.1.1. Public blockchain risks and mitigation strategies

See Appendix for detailed matrix: **Table A.6**

Legal risk management control failure					
Ability to mitigate (1 = low ability to mitigate; 5 = high ability to mitigate)					
	1	2	3	4	5
L1s					Legal risk is partially mitigatable through legal due diligence, disclosures, internal governance, and contractual “wrappers” around ancillary services, but the base network itself typically lacks an attributable counterparty and conventional enforcement or escalation pathways. As a result, recourse is often indirect and depends on documentation quality, operational evidence, and regulatory expectations rather than enforceable obligations against a single accountable operator.
L2s					Legal risk is often more mitigatable on L2s because higher-layer deployments introduce more identifiable roles and operational control points that support clearer escalation, documentation, and dispute-resolution terms. Controlled or allowlisted domains can materially improve attribution and contractual recourse within the perimeter. However, layered execution introduces cross-layer boundary conditions and mismatch risk between legal intent and technical outcomes, requiring explicit allocation of responsibilities, incident recourse, and dispute processes across the L1–L2 stack.

Lack of attributable counterparty (ORX Level-2 risk category - Mishandling of legal processes):

Public blockchains’ operational and governance models can make it infeasible to derive or enforce obligations and resolve disputes resulting from unexpected public blockchain behavior.

For L2s, identifiable roles and control points can improve practical attribution (e.g., operators, contract administrators, and bridge pathways), but also introduce cross-layer dispute cases around operator actions and emergency controls that require clear boundary conditions and documented recourse; allowlisted domains can strengthen enforceability within the perimeter, while the underlying L1 dependency still limits recourse for base-layer disruptions.

Mitigation strategies for L1s

- For public blockchain ecosystems: publishing clear governance charter frameworks, exploring community governance escalation mechanisms, and providing monitoring logs, and supporting opt-in dispute-resolution mechanisms (including arbitration arrangements where feasible).
- For financial institutions: thorough legal risk and governance due diligence, identifying and utilizing contractable counterparties for ancillary services where possible, assessing the views of prudential regulators where applicable, and documenting dispute-resolution expectations (e.g., arbitration clauses) with those counterparties.

Mitigation strategies for L2s

- For public blockchain ecosystems: documenting governance, escalation, and emergency-action authority for L2 components (including bridges), and publishing reliable transparency artefacts (for example, incident reporting and operational logs) to support cross-layer investigation and dispute handling.
- For financial institutions: extending legal due diligence to the full L1–L2 dependency chain and using contractual “wrappers” where identifiable parties exist to specify responsibilities, governing law, escalation, and dispute-resolution processes, alongside clear customer disclosures that cover cross-layer boundary events.

Risks that arise from contractual rights / obligations failure: Smart contracts can act as an execution tool for contractual rights and obligations means of algorithmic code executable on a blockchain. Blockchain's immutability can cause challenges in correcting errors or bugs when using such tools, limiting the ability to implement traditional legal remedies.

For L2s, contractual outcomes can depend on additional system components and cross-layer routes (e.g., L2 system contracts and bridges), increasing mismatch risk between legal intent and technical execution and increasing the importance of predefined pause, rollback (where possible), and migration procedures.

Mitigation strategies for L1s

- For public blockchain ecosystems: encouraging development of standardized audited smart contract templates, promoting pre-deployment audits, and maintaining agile, community-driven governance processes that facilitate rapid response to misalignments.
- For financial institutions: conducting rigorous pre-deployment legal reviews, employing continuous real-time monitoring of smart contract executions, maintaining clearly defined contingency plans for rapid migration or replacement of compromised or misaligned contracts, ensuring contracts are well defined.

Mitigation strategies for L2s

- For public blockchain ecosystems: encouraging standardized, audited templates for common components and cross-domain patterns (including routing/bridging pathways where applicable), and documenting expected behavior, upgrade authority, and emergency actions to reduce ambiguity between rights and actual execution.
- For financial institutions: extending legal reviews and contractual documentation to explicitly cover cross-layer execution dependencies (including defect handling, emergency interventions, and settlement/exit assumptions) and maintaining playbooks to pause activity, adjust routing, or migrate when legal obligations and technical outcomes diverge.

Legal risk: Key Differences for Public Permissioned Blockchains

Public permissioned blockchain networks can reduce legal ambiguity by establishing structured governance and clearer accountability, including explicit dispute-resolution mechanisms, jurisdictional guidelines, and legally binding operating frameworks. This can strengthen attribution and recourse, but it can also concentrate reliance on the governing entities, so consortia should define transparent escalation, incident reporting, and change-management obligations and participants should maintain their own legal and compliance oversight to manage residual risk.

6.2. Transaction and process execution

Transaction processing and execution risk involves failures or delays in the accurate handling of transactions, arising from system errors, misconfigured smart contracts, procedural breakdowns, or inadequate operational oversight. In the context of public blockchains, these risks can be heightened due to the irreversible nature of transactions and the complexity and comparative novelty of underlying technology (including 24/7 operation). Managing these risks demands control mechanisms across client interactions, transaction execution logic, and internal operational processes.

6.2.1. Public blockchain risks and mitigation strategies

See Appendix for detailed matrix: **Table A.7**

Transaction and process execution risk control failure					
Ability to mitigate (1 = low ability to mitigate; 5 = high ability to mitigate)					
	1	2	3	4	5
L1s					Execution failure is materially mitigatable through institutional controls (e.g., dual authorization, interface validation, training, and monitoring) and through strong operational procedures for exception handling and client communication. Residual exposure remains because transactions are typically irreversible and there is no central operator to reverse erroneous execution, making preventive controls and rapid detection central to mitigation.
L2s					Execution failure remains largely irreversible within the L2 domain and can propagate across layers through bridging and cross-domain routing, increasing the likelihood of delayed detection and more complex recovery paths. Cross-layer routing errors can create compounding failure modes (e.g., partial completion or misrouting), making strict route allowlists, confirmation thresholds, and exception playbooks particularly important. Some L2 designs introduce protocol withdrawal latency that can create liquidity freezes under stress, which institutions can buffer and manage but cannot eliminate through operational controls alone.

Processing/execution failure relating to clients and products: Public blockchain transactions and asset transfers are typically irreversible, significantly amplifying the impact of errors made through client-facing interfaces or validation misconfigurations. Unlike traditional financial systems, there is no operator that can provide remediation, significantly amplifying the impact of user or technical errors.

For L2s, the same irreversibility as L1 applies within the L2 domain, and errors can propagate across layers through bridging and cross-domain routing (e.g., partial completion, misrouting, or delayed settlement finality across the L1–L2 boundary), increasing the likelihood of delayed detection and more complex recovery paths.

Mitigation strategies for L1s

- For public blockchain ecosystems: establishing clearly defined transaction formats and standards, developing and encouraging best practices for data checks, and providing real-time monitoring to enable financial institutions to promptly identify transaction anomalies or errors.
- For financial institutions: implementing dual-authorization controls for transaction submissions, rigorous user training and interface validations, and developing off-chain correction procedures and immediate client-notification processes to address errors.

Mitigation strategies for L2s

- For L2s, similar irreversibility applies within the L2 domain and errors can propagate across layers through bridging and cross-domain routing, increasing the risk of delayed detection and more complex recovery paths (including partial completion, mis-routing, or delayed settlement finality across the L1/L2 boundary).

-
- For financial institutions: extending dual-authorization, interface validation, and user training to L2 and bridge workflows, using pre-execution simulation and strict route allowlists, defining cross-layer confirmation and exception-handling policies, and maintaining playbooks to pause affected routes, reconcile outcomes across L1/L2, and notify clients promptly when execution errors occur.
-

Challenge-window liquidity freeze risk: Protocol designs can impose a defined delay before withdrawals are finalized to the underlying L1 (e.g., to preserve dispute and recovery assurances). This can create temporary liquidity freezes, especially under stress, where exit demand concentrates and queueing or route constraints delay access to funds.

For L2s, the practical impact is heightened because liquidity management depends on cross-layer routes and operational pathways (e.g., bridging and exit processing), so delayed exits can impair settlement obligations and client servicing even when the underlying L1 remains stable.

Mitigation strategies for L1s

- For public blockchain ecosystems: not typically applicable as a distinct L1 execution risk; delay dynamics are addressed through broader congestion, finality, and operational resilience mechanisms.
- For financial institutions: not typically applicable as a distinct L1 execution risk; manage liquidity and settlement risk through conservative confirmation policies, monitoring, and operational buffers aligned to business impact tolerances.

Mitigation strategies for L2s

- For public blockchain ecosystems: establishing clear transaction and message standards for L2 and bridge workflows, publishing guidance on confirmation expectations and error handling, and supporting pre-execution checks and real-time monitoring to help institutions detect anomalies early.
- For financial institutions: defining product terms and liquidity planning that reflect exit latency assumptions, maintaining calibrated liquidity buffers and impact tolerances, monitoring cross-layer exit conditions and queues, and maintaining playbooks for reconciliation and client communication when exit delays breach tolerance thresholds.

Transaction and process execution risk: Key Differences for Public Permissioned Blockchains

Public permissioned networks can apply stricter operational controls over transaction processing (e.g., standardized submission formats, curated client interfaces, stronger validation policies, and contractual incident response expectations), which can reduce execution error frequency and improve response coordination. However, execution can still be effectively irreversible at the transaction layer, so prevention, monitoring, and predefined exception handling remain central, and concentration in a finite operator set becomes a key dependency to govern.

6.3. Data management

Data management risk involves ensuring data—such as transaction records, asset ownership, compliance documentation, and other sensitive information—is accurate, secure, well-structured, and compliant. Public blockchains improve certain risks, such as data quality through consensus-driven accuracy, real-time 24/7 availability, and immutable records, alongside cryptographically verified external data inputs where oracle infrastructure is integrated. However, public blockchains can also introduce distinct challenges related to integration with existing IT infrastructures, interoperability across different infrastructures, and compliance with data retention, destruction, privacy regulations, and data localization restrictions. Financial institutions adopting public blockchain need to reconsider and likely adapt their data management practices and governance frameworks.

6.3.1. Public blockchain risks and mitigation strategies

See Appendix for detailed matrix: **Table A.8**

Data management risk control failure.					
Ability to mitigate (1 = low ability to mitigate; 5 = high ability to mitigate)					
	1	2	3	4	5
L1s					Institutions can materially mitigate data-architecture risk through privacy-by-design controls (classification, minimization, off-chain handling, and strict prohibitions on embedding sensitive data on-chain), supported by monitoring, audits, and governance. Residual risk persists because disclosures on transparent systems are difficult to remediate once published, making preventive design and disciplined operating controls central.
L2s					L2s provide additional architectural levers to reduce what is exposed to the base layer, and institutions can apply the same data-governance controls across L1 and L2 interactions. However, cross-layer activity and bridge pathways can introduce additional metadata leakage, and privacy-enhancing L2 designs can shift and concentrate confidentiality risk into L2 data handling, access controls, and recovery assumptions, requiring explicit governance and monitoring.

Inadequate data architecture/IT infrastructure: The transparent nature of public blockchains creates new challenges for how financial institutions typically think about data risks. If not duly considered and addressed, it can result in inadvertent leaking of personal data, data subject to banking secrecy or similar confidentiality, or contractually confidential data, including trade secrets.

For L2s, the same data-exposure risk as L1 arises where sensitive data is embedded in L2 transactions or state (e.g., payloads, logs/events, DA layers where applicable, or bridge messages), and cross-layer activity can increase metadata leakage; where data is posted to the underlying L1 for availability, any sensitive content becomes publicly exposed at the L1 layer, while privacy-enhancing designs that reduce L1 exposure can instead concentrate confidentiality risk in the L2's own data handling, access controls, and recovery procedures.

Mitigation strategies for L1s

- For public blockchain ecosystems: best practices and guidelines for data risk management, tooling and standards for safe anonymization and other privacy tools (e.g., hashing, zero-knowledge proofs), and development of private batch-processing solutions.

Mitigation strategies for L2s

- For public blockchain ecosystems: publishing clear guidance on safe L2 and cross-layer data handling (including what data is posted to the underlying L1 and what remains off-chain), supporting privacy-preserving processing patterns, and providing or encouraging monitoring and scanning approaches that detect and discourage improper data publication in L2 payloads and bridge messages.

-
- For financial institutions: analysis of data risks in public blockchain use cases, due diligence on specific data risks of public blockchains, use of private batch-processing solutions, and documented failover plans.
 - For financial institutions: extending privacy-by-design controls across L2 and bridge workflows (classification, minimization, strict prohibitions on embedding sensitive data, and metadata hygiene), performing due diligence on L2 data exposure and recovery assumptions (including data-availability and access controls where relevant), implementing privacy-preserving processing solutions, and maintaining playbooks to contain exposure and migrate workflows if improper disclosure is detected.

Data management risk: Key Differences for Public Permissioned Blockchains

Public permissioned environments can enforce standardized data formats, admission controls, and contractual governance that reduce accidental disclosure risk (including policy controls at gateways/validators). However, immutability and shared visibility among participants still require strict minimization and prohibitions on sensitive data on-chain, and if a permissioned environment anchors data or proofs to a public chain, any posted payload and metadata should be treated as publicly observable.

7. Standard risks

Risks in this category closely resemble those associated with traditional infrastructure, and existing risk management frameworks – such as cybersecurity standards and audit controls – remain effective without significant adjustments. This section summarizes key risk categories, highlighting limited blockchain-specific considerations that institutions may evaluate as deemed necessary.

- **Security and safety:** Involves protecting critical infrastructure, assets, personnel, and transactions from compromise or loss. For public blockchains, this can encompass securing nodes, managing cryptographic keys, and ensuring system integrity. Established IT security frameworks (such as ISO 27000, NIST Cybersecurity Framework) remain relevant, though institutions may require incremental adjustments, such as cryptographic key management protocols. Additionally, this risk category is addressed in the Technology and Information Security Risk sections of this framework, which include detailed mitigation strategies for novel risks.
- **People risk:** Concerns human error, negligence, or unethical behavior adversely impacting operations. For public blockchain environments, examples include mismanagement of private keys or erroneous transaction execution by employees. Standard controls such as role-based access controls, dual authorizations, comprehensive training, background checks, and defined roles remain effective.
- **Conduct risk:** Relates to behaviors by employees or institutions causing harm to clients or undermining market integrity (for example, mis-selling, insider trading, and market manipulation). Traditional conduct frameworks—such as codes of ethics, surveillance systems, conflict-of-interest management, whistleblower policies, and compliance oversight—remain applicable. However, institutions may benefit from enhanced transaction monitoring and, potentially, oversight of employee-controlled wallets to ensure alignment with established conduct standards.
- **Internal fraud:** Concerns deliberate misconduct by employees or insiders resulting in asset theft, unauthorized transactions, or manipulation of blockchain-based systems. Controls such as segregation of duties, multi-party authorization, rigorous monitoring, background checks, and strong internal governance remain fully effective. Established internal fraud frameworks require minimal adjustments, primarily enhanced monitoring of private-key usage and employee-controlled digital wallets, aligning with measures already used in traditional financial infrastructures.
- **External fraud:** Involves malicious acts by external entities, including cyberattacks, phishing, theft of cryptographic keys, and fraudulent impersonations. Established cybersecurity measures (such as multi-factor authentication, network segmentation, and endpoint security) combined with continuous monitoring and anti-fraud processes (such as fraud analytics and real-time alerts) effectively address these threats. Furthermore, external fraud risks are addressed in both the Third-Party, and Information Security risk sections, reinforcing comprehensive controls, vendor assessments, and secure system architectures.
- **Regulatory compliance:** Covers risks from violations or non-conformance with applicable laws and regulations governing financial markets. Regulatory authorities typically adopt technology-neutral approaches; thus, blockchain remains subject to existing regulatory frameworks (such as AML/KYC, investor disclosures, and securities laws). Established compliance frameworks, governance processes, and audit mechanisms apply directly with minimal additional measures, such as integrating blockchain analytics for enhanced regulatory reporting. Institutions should also remain attentive to evolving blockchain-related regulations, proactively updating policies to sustain compliance.

- **Model risk:** Primarily addresses risks arising from incorrect outcomes or inaccuracies due to flawed analytical models and valuation methodologies. These risks are not inherently blockchain-specific, and existing model risk management frameworks—covering governance, independent validation, testing, and documentation—continue to comprehensively address such concerns without significant blockchain-related adjustments.
- **Statutory reporting and tax:** Encompasses risks related to errors or non-compliance in financial, regulatory, and tax reporting obligations. Blockchain platforms largely fit into established reporting frameworks, utilizing existing controls like internal control over financial reporting, reconciliations, audit trails, and established accounting standards (although some may be under development in select jurisdictions). Institutions may require minor enhancements, such as integrating blockchain-derived transactional data and providing additional training on digital asset-specific taxation or reporting obligations.

8. Private permissioned blockchains

In exploring blockchain technology, most regulated financial institutions have historically implemented private permissioned blockchains, which are characterized by centralized governance, defined accountability, purpose-built operations, and closed-loop compliance and risk management.

The risks of private blockchain applications can be managed using traditional enterprise risk management frameworks—including management of private blockchain systems (for example, ITU-T M.3366), robust cybersecurity controls (for example, ISO 27001 and NIST standards), formal business continuity plans, and established third-party risk management procedures. Defined roles, structured governance models, and enforceable contractual arrangements help to ensure effective incident response, legal recourse, and management of data privacy, transaction validation, and compliance obligations. Financial institutions should remain cognizant of new expressions of certain risks, such as smart contract-specific risks, which may require enhanced mitigations or tailored monitoring.

Furthermore, in practice, institutions deploying on private permissioned networks also may interface with public blockchain infrastructure for issuance, settlement, interoperability, or liquidity. In these hybrid deployments, institutions should recognize the “permissioned-on-public” middle ground, public networks used with robust permissioning and policy controls at the asset and application layer, and ensure the same governance, access control, monitoring, and third-party risk frameworks are extended to those implementations.

Due to their centralized nature, private permissioned networks benefit from reduced exposure to public blockchain-related risks as detailed in this RMF. However, the practical challenge for such solutions remains clarifying their value proposition compared to traditional infrastructures. Additionally, institutions should consider well-known operational challenges related to scalability at mass-production levels, interoperability and liquidity limitations, and the ongoing costs associated with maintaining private permissioned distributed ledgers.

9. Path forward

The RMF aims to provide a foundational step towards enabling the safe adoption of public blockchains within regulated financial services, providing supervisors and regulatory bodies with an overview of how the industry has adopted active risk management practices for blockchain infrastructures.

To further develop the RMF, a dedicated community initiative is planned to curate and analyze real-world examples, case studies, and best practices related to blockchain risk management. Central to these efforts is an ongoing commitment to foster continuous public-private sector collaboration, integrating market feedback to ensure that the RMF remains up to date.

Looking ahead, we are extending our work on security tokens to stablecoins and deposit tokens. In the future, the application-specific framework will further extend to core cryptoassets use cases. We welcome market participants, regulators, policymakers, technology providers, and infrastructure operators to provide comments based on their practical experience and insights regarding effective blockchain risk management practices.

If you would like to apply to join the RMF core working group, please contact RMF@gbbc.io.

Appendix A. Risk and mitigation matrices

A.1. Technology risks and mitigations approaches

Table A.1

		Mitigation strategies	
Risk		Public blockchain ecosystems	Financial institutions
Hardware risk			
Limited node diversity	Description: Risk that concentrated infrastructure or critical operators on a public blockchain (or an L2 anchored to it) create single points of failure, leading to degraded performance, service disruption, or impaired recovery.		
Layer 1s	Driver: The public blockchain network is operationally dependent on nodes concentrated in a few cloud providers or geographic regions, often due to cost-efficiency, technical maturity, or lack of enforced decentralization standards. Event: A major cloud provider outage, regional power failure, or natural disaster leads to simultaneous node failures across the network. Impact: Transaction delays, reduced network availability or reliability, inability to settle or validate transactions in a timely manner, and—in severe cases—temporary disconnection from the blockchain or full protocol halt, with potential downstream effects on institutional operations and customer obligations.	Preventive: Incentivize diverse node hosting through protocol incentive economics; enforce decentralization thresholds via governance; support multi-platform node deployments; enable and promote non-cloud self-hosting with accessible tooling. Detective: Support monitoring node distribution by region and provider; track decentralization metrics and issue alerts on threshold breaches; perform regular resilience and concentration audits. Corrective: Provide tools for automated node migration; enable protocol-level failover mechanisms; publish fallback configurations; support fast resynchronization after outages.	Preventive: Select blockchains with proven infrastructure decentralization and node distribution; require hosting diversity in vendor and blockchain due diligence; run own nodes in diverse regions or providers. Detective: Continuously monitor node health and distribution in supported blockchains; assess validator and infrastructure concentration risks; review decentralization reports and community metrics. Corrective: Switch to alternative RPC or data providers during outages; failover plans, including failover to backup nodes or internal infrastructure; adjust exposure or pause transactions until network stability is restored.
Layer 2s	Driver: The L2 depends on a concentrated set of operators and infrastructure (e.g., sequencer, data availability, and canonical bridge), often run by a small number of entities and/or hosted in a small number of providers or regions. Event: An outage, cyber event, or operational failure at a dominant operator or shared infrastructure provider results	Preventive: Design for diversity across operators and hosting for core services; support multi-instance or multi-operator architectures with clear degraded/fallback modes; reduce hard reliance on any single provider or region.	Preventive: Select L2s with transparent operator structures and clear fallback modes; map sequencer/DA/bridge dependencies in due diligence; multi-home endpoints where practical and enforce approved-route policies for critical workflows.

Mitigation strategies

Risk	Public blockchain ecosystems	Financial institutions
in loss of liveness; in some cases, multiple L2s are impacted due to shared dependencies. Impact: L2 transaction processing halts or degrades; deposits/withdrawals and exits are delayed; bridge operations may be paused or congested; institutions may be unable to complete workflows or reliably access/settle assets via the L2 until recovery (even if the underlying L1 remains live).	Detective: Track and disclose operator/infrastructure concentration; publish sequencer/DA/bridge health telemetry; define thresholds and alerting for liveness degradation and shared-dependency exposure. Corrective: Maintain credible failover and recovery procedures (including communications); support rapid resynchronization and safe restarts; publish recovery timelines and dependency status during incidents.	Detective: Monitor L2 liveness and bridge health alongside underlying L1 conditions; track operator concentration and shared dependencies; review telemetry, incident history, and recovery performance. Corrective: Execute playbooks to pause or reroute activity away from impacted L2s/routes; fail over endpoints/providers; use documented exit/withdrawal procedures where needed; maintain client-impact and reconciliation procedures until stability is restored.
Third-party dependencies	Description: Risk that reliance on third-party infrastructure and access services introduces centralized points of failure, reducing resilience and disrupting connectivity, data availability, or transaction routing across L1s and L2s.	
Layer 1s	Driver: Dependence on a limited set of external infrastructure providers (such as public RPC nodes, API services, block explorers) without redundancy or internal alternatives; lack of direct control over uptime and service configuration. Event: A critical provider suffers an outage, degradation, or targeted attack, resulting in the unavailability or malfunctioning of core blockchain connectivity or data services. Impact: Inability to submit or verify transactions, halted application workflows, degraded user or system performance, and potential financial or reputational harm due to service-level disruptions.	Preventive: Encourage ecosystem diversity in RPC and indexing providers; promote open-source reference implementations and incentivize self-hosting; design protocols to minimize reliance on centralized access points. Detective: Monitor usage concentration across third-party infrastructure; track service health and latency patterns; conduct dependency mapping across core services. Corrective: Provide fallback endpoints and client failover logic; support emergency relay or data source switching; coordinate with providers to restore critical infrastructure rapidly. Preventive: Use multiple, independent RPC and data providers; evaluate provider risk during vendor onboarding; where no direct counterparty exists, apply architectural and open-source assessments in place of legal assurances; evaluate decentralization as a resilience feature during due diligence; maintain critical components internally or establish partnerships with anchor contributors (such as reliable node operators, indexers); initiate risk-based fallback actions where feasible. Detective: Continuously monitor provider uptime, latency, and data consistency; implement service-level alerting; review provider audits and status feeds. Corrective: Failover plans including failover to alternate providers or internal nodes; pause transaction flows if data integrity is compromised; reprocess delayed or missed submissions once service is restored.

Mitigation strategies

Risk		Public blockchain ecosystems	Financial institutions
Layer 2s	Driver: Dependence on a small set of L2-specific operators/services (sequencer endpoints, DA providers where applicable, prover services where applicable, bridge/route operators), plus upstream reliance on the underlying L1's access layer. Event: Failure, degradation, or compromise of an L2 critical service (or correlated outage across shared providers) disrupts sequencing, data availability, or bridge routing. Impact: L2 processing halts or degrades; deposits/withdrawals and exits are delayed or paused; institutions may be unable to access or recover assets via expected L2 pathways until services restore.	Preventive: Encourage diversity of access providers and implementations; promote self-hosting and open reference tooling; design L2 architectures and routes to tolerate failure of a single operator/provider, including credible fallback and exit behavior. Detective: Monitor and publish service-health and concentration metrics (availability, latency, provider share); provide route-level telemetry for sequencing and canonical bridge pathways (and DA where applicable). Corrective: Provide fallback endpoints and client-side failover logic; coordinate incident response and recovery communications; support safe pausing and restoration procedures, including re-enabling exit/withdrawal pathways.	Preventive: Use multiple independent providers and/or internal nodes; map dependencies across L1, L2, and bridge routes; select L2s with transparent operator models and credible fallback assumptions; establish SLAs and escalation channels where identifiable counterparties exist. Detective: Continuously monitor uptime, latency, and data consistency across providers and layers; track sequencer/bridge (and DA where applicable) health and route queueing; maintain alerting tied to impact tolerances. Corrective: Execute provider and route failover plans (including fallback to internal nodes or alternative routes); pause or reroute activity (including reverting to L1 where appropriate); reconcile and backfill once services stabilize.
Software risk			
Code Vulnerabilities	Description: Risk that exploitable flaws in protocol or system code cause unintended behavior, security breaches, or operational failures across L1s and L2s (including cross-layer and bridge/exit logic where relevant).		
Layer 1s	Driver: High complexity of decentralized consensus protocols and networking logic; insufficient test coverage across diverse runtime conditions. Event: An attacker exploits a code vulnerability to disrupt node operations, alter consensus behavior, or gain unauthorized access to protocol functions. Impact: Loss of network integrity or availability, transaction processing errors, unanticipated forks, or reputational and legal consequences.	Preventive: Adopt rigorous code review and testing standards; implement formal verification and fuzzing for critical components; promote modular and well-documented architecture; support multiple competing node implementations. Detective: Conduct continuous static and dynamic code analysis; monitor for abnormal network behavior or node crashes; support third-party or community-led vulnerability disclosure programs and audits. Corrective: Develop rapid patching and coordinated disclosure processes; maintain emergency release channels and upgrade paths; provide tooling and documentation for safe node recovery or resynchronization.	Preventive: Select networks with a strong track record of secure development practices; require evidence of third-party audits and testing; testing components in sandbox / preproduction environments before integration. Detective: Monitor upstream code changes, Common Vulnerabilities and Exposures (CVEs), and protocol disclosures; run infrastructure observability tools to detect irregular performance or behaviors; maintain watchlists of security advisories. Corrective: Suspend transaction submission during exploit windows; failover plans including switch to alternative infrastructure if needed; validate ledger state post-incident and implement compensating controls for affected workflows.

Mitigation strategies

Risk		Public blockchain ecosystems	Financial institutions
Layer 2s	Driver: Expanded attack surface from L2 components and cross-layer interfaces, where defects in sequencer/bridge/verification logic (or their upgrades) can propagate into L1–L2 assumptions and exit behavior. Event: A vulnerability in L2 system code or L1–L2 interaction logic is exploited, or an upgrade introduces a defect that breaks processing or bridging/exits. Impact: L2 processing halts or behaves unexpectedly; exits and recovery to L1 are disrupted; institutions may need to pause routes or products while fixes propagate and cross-layer state is validated.	Preventive: Apply secure-development practices (e.g., review, audits, formal verification, bug bounties); test L1–L2 interaction and exit paths under adversarial and degraded conditions; establish clearly governed upgrade / emergency controls for contracts. Detective: Continuous static/dynamic analysis and adversarial testing; anomaly monitoring for unexpected behavior; coordinated disclosure processes that account for cross-layer dependencies and shared components. Corrective: Rapid patching and coordinated upgrade procedures; safe rollback/pause mechanisms and incident communications; ensure emergency actions preserve user recourse and restore credible exit and recovery behavior.	Preventive: Select networks with strong security track records and independent audits; test integrations in pre-production; for L2s, review audits of core system contracts and L1–L2 pathways, understand upgrade authority/emergency powers, and test failure and exit scenarios. Detective: Monitor disclosures, advisories, and abnormal network indicators; maintain observability across both layers and bridge events; track incident history and patch adoption where relevant. Corrective: Suspend or constrain activity during exploit windows; shift to alternative routes/infrastructure where feasible; validate state post-incident and re-enable workflows only after controls, patches, and exit assumptions are stable.
Data corruption	Description: Risk that software defects, version mismatches, or misconfiguration cause inconsistent processing or interpretation of blockchain data, degrading reliability and requiring resynchronization, rollback, or other recovery actions.		
Layer 1s	Driver: Bugs in client implementations, version mismatches, or incorrect node configuration parameters affecting block validation or state transitions. Event: Nodes process blocks differently due to software or configuration errors, leading to data inconsistencies, temporary forks, or invalid local state. Impact: Operational uncertainty, degraded network performance, delayed transaction processing, and the need for corrective actions such as node resynchronization or emergency patches, with potential disruption to dependent services.	Preventive: Standardize and document supported node implementations and configurations; incentivize compatibility checks for protocol upgrades; promote use of automated deployment and validation tools. Detective: Monitor node behavior and ledger state divergence across nodes; implement network-level consistency checks and telemetry; detect version drift and configuration anomalies in real time. Corrective: Support fast node resynchronization and snapshot recovery; release emergency patches or configuration overrides; coordinate network-wide responses to restore consensus and correct state.	Preventive: Use only validated node software from trusted sources; maintain configuration management and change control procedures; run test environments for upgrade and configuration validation. Detective: Monitor node performance, state alignment, and peer behavior; track logs for signs of desynchronization or state errors; alert on configuration drift or unexpected runtime conditions. Corrective: Reinitialize affected nodes using trusted snapshots; verify ledger integrity before resuming operations; escalate and coordinate with protocol maintainers.
Layer 2s	Driver: Additional L2 components and cross-layer interfaces introduce more configuration and version-drift surfaces; concentration in these components can amplify the effect of a single defect.	Preventive: Harden and standardize L2 software and configuration; provide automated deployment and validation tooling; clearly document data-retention, replay, and recovery assumptions, especially where data availability is not fully on the L1.	Preventive: Use validated L2 clients and infrastructure; apply consistent change-management controls across L1 and L2; test recovery and exit procedures (including DA-dependent recovery).

Mitigation strategies

Risk		Public blockchain ecosystems	Financial institutions
	Event: A bug, misconfiguration, or upgrade drift causes L2 nodes to diverge, L1 submissions to fail or become inconsistent, or bridge/exit logic to operate against incorrect assumptions. Impact: Inconsistent L2 state views, degraded processing, delayed or halted exits/withdrawals, and reconciliation burden across L1 and L2 records, potentially requiring emergency resynchronization or rollback procedures.	Detective: Monitor divergence between L2 nodes and between L2 state and L1 submissions; publish telemetry and alerts for sequencing, DA (where applicable), and bridge health and submission delays. Corrective: Maintain defined resynchronization, rollback, and recovery procedures (including exit behavior under stress); coordinate incident-response assumptions with the underlying L1 where relevant.	Detective: Monitor L2 node/bridge (and DA where applicable) anomalies and submission delays; maintain independent validation signals where critical; reconcile positions across L1-anchored commitments and L2 views. Corrective: Execute playbooks to pause affected routes; resynchronize from trusted sources; complete controlled exits or rerouting where feasible; reconcile records and manage client impacts until stability is restored.
Network risk			
Protocol upgrade and hard fork risk	Description: Risk that protocol or contract upgrades are insufficiently coordinated or communicated, leading to incompatible behavior, disruption, or inconsistent outcomes from an institutional perspective.		
Layer 1s	Driver: Lack of formal coordination or institutional involvement in upgrading governance; insufficient lead time or visibility into changes. Event: Upgrade proceeds without synchronized institutional readiness, causing incompatibility across systems or node failures. Impact: Operational disruption; failed or delayed transactions; misaligned ledger views; service outages or reconciliation issues	Preventive: Establish incentives to drive transparent upgrade governance and communication processes; provide upgrade timelines and testing resources in advance; support backward-compatible transitions where feasible. Detective: Monitor upgrade adoption rates and client version diversity; track ecosystem readiness and relay stakeholder feedback; simulate upgrade conditions on testnets. Corrective: Offer emergency client patches and rollback options; coordinate through governance to pause or delay upgrades if needed; maintain compatibility tools and documentation	Preventive: Monitor protocol governance forums and roadmaps; test upcoming changes in sandbox / preproduction environments; maintain relationships with protocol teams for early insight and participate in development process (e.g., providing feedback). Detective: Track client version status across infrastructure; audit transactions and ledger behavior post-upgrade; assess divergence risk indicators; monitor open-source repositories. Corrective: Activate fallback infrastructure aligned with last-known stable state; delay high-value transactions during uncertainty; engage with providers to re-align services and data feeds.
Layer 2s	Driver: Upgrade cadence spans L2 contracts and infrastructure and is coupled to L1 behavior and assumptions, increasing cross-layer coordination burden. Event: An L2 or bridge upgrade is deployed with incomplete adoption, mis-specified parameters, or unexpected interaction with an L1 change, resulting in disruption, failed submissions, or impaired withdrawals.	Preventive: Establish clear governance and change controls for L2 contracts and infrastructure; coordinate timelines with the underlying L1; provide test environments; define rollback/pause/recovery authority for critical components. Detective: Track version adoption and post-upgrade health (sequencer, bridge, exits, L1 submissions);	Preventive: Monitor L2 roadmaps and governance; test combined L1/L2 and bridge changes in preproduction; define operational windows and confirmation policies that limit exposure during higher-risk upgrades.

Mitigation strategies

Risk		Public blockchain ecosystems	Financial institutions
	Impact: Service disruption and reconciliation breaks, delayed or impaired exit and withdrawal paths, and operational burden to manage client servicing and settlement expectations during recovery.	publish timely incident communications and postmortems. Corrective: Activate pause/rollback/safe-mode procedures and emergency patches for L2 and bridge components; coordinate cross-layer recovery steps that preserve credible exit and user recourse.	Detective: Monitor upgrade signals and post-change anomalies across both layers; audit processing and exit behavior against expected outcomes. Corrective: Pause L2-dependent flows or bridging as needed; reroute critical activity (including direct L1 processing where feasible); reconcile post-incident state; execute escalation/reporting playbooks.
Finality lag and transaction rollback risk	Description: Risk that settlement assumptions prove incorrect due to delayed finality, chain reorganizations, or cross-layer finality mismatches, resulting in rollbacks, delayed exits, or downstream reconciliation breaks.		
Layer 1s	Driver: Public blockchains often rely on probabilistic or delayed finality mechanisms; confirmation depth may be insufficient to guarantee immutability during periods of network latency, congestion, or validator misbehavior. Event: A chain reorganization or delayed finalization replaces blocks previously believed to be settled, causing legitimate transactions to be dropped, reordered, or duplicated in dependent systems. Impact: Breakdown in transactional consistency, failed or incorrect settlements, operational risk in downstream processes (e.g., reconciliation, custody, trade execution), and potential financial exposure or reputational damage for institutions relying on timely and irreversible ledger updates.	Preventive: Implement consensus mechanisms with robust finality models; introduce upgradable finality thresholds; improve propagation speed and fork-choice rules to minimize reorg depth; clear guidance on reorg handling, confirmation expectations, and operational recovery procedures. Detective: Monitor block finalization times and fork frequency; track reorg events and near-finality reversals; alert ecosystem participants to prolonged finality delays. Corrective: Implement checkpointing or delayed finality confirmation mechanisms; coordinate community response to deep reorgs; support tools to resync or reconcile impacted nodes.	Preventive: Use conservative finality thresholds before processing critical transactions; select networks with robust finality models; include reorg tolerance in integration design; implement contractual framework or rulebook addressing finality. Detective: Track network finality status and reorg indicators in real time; validate transaction finality depth before downstream processing; monitor for signs of consensus instability. Corrective: Flag and reconcile affected transactions after rollbacks; pause settlement operations during instability; coordinate with service providers to restore consistent state; pre-defined rollback/runbook procedures.
Layer 2s	Driver: Dependence on both underlying L1 finality and L2-specific finality semantics (e.g., sequencer “soft” confirmations vs. L1-anchored finality), where batching, bridging, and exits can amplify the effects of L1 instability. Event: An L1 reorg/delayed finality or L2 dispute outcome invalidates an L2 batch/state commitment previously treated as settled, causing “confirmed” L2 outcomes to be delayed or reverted.	Preventive: Define and publish L2 finality guarantees (soft vs. L1-anchored); align bridge and exit logic to L1 finality assumptions; harden sequencing/state-commitment design to tolerate realistic L1 reorg conditions; clearly specify dispute rules and the operational meaning of “final” where applicable. Detective: Provide real-time telemetry for L1 reorg/finality conditions and L2 batch inclusion/finalization; monitor dispute/challenge status and exit/withdrawal pathway health; flag when soft	Preventive: Define combined L1/L2 confirmation policies and treat sequencer confirmations as provisional for critical obligations; restrict to approved routes and exit mechanisms; set product terms and operational buffers to reflect rollback and finality-lag scenarios. Detective: Monitor L1 finality/reorg indicators alongside L2 batch/state-commitment finalization and bridge/exit conditions; reconcile books against L1-

Mitigation strategies

Risk		Public blockchain ecosystems	Financial institutions
	Impact: Reverted or delayed L2 settlements, disrupted exits/withdrawals, mismatched internal ledgers and customer records, operational breaks in downstream processes (e.g., reconciliation, custody, settlement), and potential financial or reputational exposure if institutions act on pre-final signals.	confirmations should not be relied upon for settlement. Corrective: Maintain documented reorg/dispute recovery playbooks (resync/re-execution expectations); use governed pause/rollback controls for critical components (sequencer and bridge/exit paths); publish clear incident communications while preserving credible user recourse and safe exits.	anchored L2 commitments (not only L2 RPC views); alert on divergence and prolonged finality lag. Corrective: Pause affected routes/products when finality assumptions degrade; unwind or quarantine provisional credits/exposures; reprocess and reconcile after reorg/dispute resolution; reroute critical flows to L1 or approved alternatives with documented client communication and escalation procedures.
Protocol governance risk	Description: Risk that governance processes and decision rights across a blockchain stack lead to delayed, contested, or uncoordinated changes, creating fragmentation, unexpected outcomes, or misalignment with institutional requirements.		
Layer 1s	Driver: Decentralized or informal governance mechanisms lacking clear accountability, coordination structures, or consistent upgrade planning; competing stakeholder interests and token-holder voting dynamics. Event: A governance dispute, unclear proposal outcome, or abrupt protocol change leads to hard forks, incompatible client behavior, or delayed implementation of necessary technical upgrades. Impact: Operational disruption, version fragmentation, diminished predictability of protocol evolution, and elevated integration and maintenance costs.	Preventive: Define transparent, inclusive, and technically enforceable governance processes; implement structured proposal and voting systems with clear thresholds; provide timelines and specifications for planned changes. Detective: Track governance participation, proposal activity, and voting trends (e.g., pre-voting and other intent signaling methods); monitor signals of contention or low stakeholder engagement; assess upgrade coordination maturity. Corrective: Facilitate community interventions to de-escalate governance disputes; support rollback or override mechanisms for unstable upgrade proposals; publish guidance to help nodes maintain network compatibility.	Preventive: Engage with governance forums, protocol stewards and key stakeholders to stay informed; participate in governance processes or partner with ecosystem contributors; include governance risk in blockchain diligence (e.g., mandate, funding, representation); plan operational buffers for governance-driven changes. Detective: Monitor upcoming governance proposals, voting, and stakeholder alignment; assess likelihood and impact of contentious decisions; subscribe to alerts and governance analytics tools. Corrective: Delay system upgrades until proposals stabilize; coordinate internally to adapt to protocol changes; switch or reduce exposure to networks with unstable governance if required; documented failover plan.
Layer 2s	Driver: Governance expands beyond the L1 to L2 contracts, bridges, operator policies, and emergency controls; narrower communities and misaligned L1/L2 change cycles increase coordination risk. Event: A contested or poorly communicated L2 governance decision or emergency action (upgrade/parameter change/pause/rollback/bridge policy change) occurs out of	Preventive: Define clear governance and change controls for L2 protocols / contracts / bridges (authorities, thresholds, emergency powers) and align timelines and assumptions with the underlying L1. Detective: Provide advance visibility on proposals and planned changes; publish governance/admin-action logs (including emergency actions) with monitoring	Preventive: Assess L2 governance maturity and emergency powers during onboarding; establish service-provider style commitments where possible (e.g., SLAs); set risk limits for governance-driven change; prefer L2s with clear decision rights and change controls aligned to L1 dependencies. Detective: Monitor L2 governance forums and admin-action telemetry and track L1/L2 roadmap alignment;

Mitigation strategies

Risk		Public blockchain ecosystems	Financial institutions
	sequence with L1 conditions or institutional readiness, degrading behavior or exit assumptions. Impact: Disruption to L2 processing and cross-layer flows, delayed or impaired exits, increased reconciliation burden, and higher integration and operational overhead due to governance-driven volatility.	and alerts for changes that affect operating assumptions. Corrective: Maintain documented pause / rollback / recovery procedures for L2 and bridge components; coordinate incident response and disclosures across L1/L2 dependencies; publish post-incident reviews clarifying decisions and lessons learned.	alert on changes affecting settlement, exits, or client commitments. Corrective: Execute playbooks to pause affected routes/products; adjust confirmation/settlement assumptions; reroute activity (including to L1 where appropriate); reconcile impacted positions and update client and stakeholder communications.
Weakness in consensus design	Description: Risk that technical or economic consensus design drives unintended concentration of validation or control, reducing fault tolerance and increasing exposure to censorship, instability, or protocol disruption.		
Layer 1s	Driver: Protocol-level incentive models or operational constraints that encourage aggregation of mining or staking resources (e.g., economies of scale, yield optimization, low hardware diversity); lack of decentralization safeguards such as staking caps, validator rotation, or slashing mechanisms. Event: Consensus power becomes concentrated in a small set of actors due to structural protocol dynamics or implementation design, raising the risk of unintentional dominance or enabling collusion without malicious exploitation. Impact: Reduced fault tolerance, systemic reliance on a small subset of validators, potential for network governance capture or transaction processing disruption, and diminished infrastructure resilience for institutions relying on the network.	Preventive: Design staking or mining incentives to promote validator diversity; implement safeguards against concentration such as staking caps, validator rotation, or slashing; encourage light node support and diverse node operation. Detective: Continuously monitor validator concentration and dominance metrics; track validator behavior for signs of coordination or collusion; audit consensus participation and performance across network epochs. Corrective: Enable governance-driven removal or rebalancing of dominant validators; trigger emergency changes to consensus parameters; introduce structural reforms to incentivize broader participation.	Preventive: Evaluate decentralization posture and validator distribution during blockchain selection; prefer blockchains with active governance and decentralization incentives; factor validator incentives into risk assessments. Detective: Track validator set composition and governance participation trends; monitor network health dashboards and decentralization indices; engage service providers for infrastructure exposure reports. Corrective: Reduce reliance on affected networks if validator dominance becomes material; failover plans; escalate governance concerns through formal channels.
Layer 2s	Driver: Reliance on the underlying L1's fault tolerance and liveness, combined with L2 operator roles that may be concentrated (e.g., sequencing or committees) due to performance requirements, operational complexity, or governance choices. Event: Sequencing or committee power becomes concentrated or impaired, or the underlying L1 enters instability, resulting in effective loss of fault tolerance at the	Preventive: Design sequencing and committee arrangements to promote diversity and reduce single points of control; implement credible fallback and operator-rotation mechanisms. Detective: Monitor and disclose operator concentration, liveness, and censorship indicators; track alignment between L2 liveness and L1 conditions (posting cadence, finality conditions, and degradation	Preventive: Assess sequencer/operator design, concentration limits, fallback/exit mechanisms, and governance constraints during L2 selection; set route controls and exposure limits where operator concentration is material; ensure product terms and operational buffers reflect potential halts and delays. Detective: Monitor sequencer/operator concentration and liveness alongside underlying L1 stability and

Mitigation strategies

Risk	Mitigation strategies	
	Public blockchain ecosystems	Financial institutions
L2 layer (including censorship, stalled batching, or prolonged halts). Impact: Delayed or halted L2 processing, increased censorship and ordering risk, delayed exits and recovery actions to the L1, operational uncertainty for settlement and reconciliation, and elevated client-impact risk where activity depends on timely L2 liveness.	triggers); provide transparent telemetry and incident reporting for the operator set. Corrective: Execute operator rotation or failover when concentration or liveness risk becomes excessive; activate documented degraded-mode behavior and recovery paths (including exit-path and safety mechanisms); coordinate incident response and communications across L2 and L1 dependencies.	posting/finality conditions; track governance changes that affect operator roles or emergency powers; maintain alerting for elevated censorship or halt indicators. Corrective: Pause L2-dependent activity when concentration or stability indicators breach thresholds; reroute flows or revert to L1-only processing where feasible; execute documented exit and reconciliation playbooks to restore consistent state and client servicing.
Scalability constraints	Description: Risk that throughput and fee predictability degrade under load on the base chain or an L2, causing congestion, delayed confirmations, and disrupted settlement and client workflows.	
Layer 1s	Driver: Design trade-offs prioritizing decentralization and security over throughput; protocol limitations on block size, transaction speed, or finality time; lack of dynamic resource allocation mechanisms. Event: A spike in transaction volume exceeds the network's capacity to process and confirm transactions within expected timeframes, leading to congestion and reduced service quality. Impact: Delayed transaction settlements, increased transaction fees, backlogs in business processes dependent on timely confirmations, and operational disruptions for institutions relying on the network for critical workflows.	Preventive: Implement protocol upgrades that improve throughput and finality; support alternative scaling solutions (e.g., rollups, sharding); optimize block propagation and transaction compression techniques; support Layer-2 implementations. Detective: Continuously monitor transaction backlog, block utilization, and fee volatility; perform stress testing and benchmarking under simulated high-load conditions; assess network responsiveness to congestion; simulate transaction prices for different scenarios. Corrective: Enable dynamic fee adjustment or transaction prioritization mechanisms; activate additional infrastructure capacity or alternate processing layers; coordinate community interventions to mitigate systemic congestion.

Mitigation strategies

Risk	Public blockchain ecosystems	Financial institutions
Layer 2s	Driver: L2 throughput depends on L2 execution capacity and upstream posting constraints, including sequencer capacity, data-availability throughput and pricing (including L1 posting limits where applicable), and bridge/exit pathway capacity; design choices may shift bottlenecks rather than eliminate them. Event: A spike in L2 activity saturates sequencer or DA capacity, or L1 posting costs/limits constrain batch publication, leading to queueing, fee volatility, delayed state updates, and delayed deposits/withdrawals via bridge and exit pathways. Impact: Processing delays, degraded user and system performance, increased transaction costs, delayed exits and liquidity mobility, and disruption to institutional workflows that depend on predictable timing (e.g., settlements, liquidity management, client servicing).	Preventive: Select L2s with transparent performance characteristics and proven capacity; design workflows with batching and timing flexibility; treat bridging and exits as capacity-constrained critical paths and size liquidity/operational buffers accordingly. Detective: Monitor L2 fee/latency conditions, queueing, DA and posting indicators, and bridge/exit delays in real time; set thresholds linked to business-impact tolerances for pausing or rerouting. Corrective: Pause or defer non-critical activity during congestion; reroute flows (including reverting to L1 where operationally viable); reprocess delayed operations and reconcile outcomes once performance stabilizes, with clear client communication when service levels degrade.

A.2. Information security risks and mitigations approaches

Table A.2

Risk	Description	Mitigation strategies	
		Public blockchain ecosystems	Financial institutions
Risk of data loss			
Private key loss and inadequate key management practices	Description: Risk that loss, compromise, or misuse of cryptographic keys prevents authorized control of blockchain assets or functions, causing irrecoverable loss or operational disruption, and in layered designs can also impair L2 operation and exit or recovery via the underlying L1.		
Layer 1s	Driver: Direct control of private keys by end users or internal custodians without robust recovery protocols; insufficient key backup strategies; inadequate user training or technical safeguards; lack of custodial redundancy. Event: Private keys are accidentally deleted, lost, or compromised, resulting in permanent loss of access to wallets, assets, or smart contract functions. Impact: Irrecoverable financial loss; operational disruption; client impact; increased legal and reputational risk, particularly if institutions are unable to safeguard or recover client-controlled digital assets.	Preventive: Encourage adoption of secure key management standards; promote use of multi-signature, threshold schemes, or hardware security modules; provide guidance for custodial integrations and backup architecture. Detective: Monitor for abnormal signing patterns or transaction behavior; support for tooling for anomaly detection and address tracking. Corrective: Support key rotation or revocation mechanisms where feasible; incentivize recovery solutions via social or custodial recovery; coordinate with ecosystem participants.	Preventive: Use institutional-grade custody solutions with secure enclave or HSM support; define clear key access roles, responsibilities, and separation of duties; implement encrypted key backups and dual control mechanisms. Detective: Continuously monitor for unauthorized access attempts or unusual transaction flows; validate key usage against policy thresholds; audit logs of key interactions and access patterns. Corrective: Revoke or isolate compromised keys; restore access through recovery protocols and backup keys; notify affected clients and execute incident response procedures.
Layer 2s	Driver: L2s introduce privileged operational keys (e.g., sequencer/batcher and bridge/upgrade admin), often with smaller signer sets and higher operational use, increasing exposure to compromise, misuse, or loss. Event: A privileged key is compromised or lost, enabling unauthorized upgrades/parameter changes, bridge or withdrawal-path manipulation, or sequencing/posting disruption that degrades exits and recovery to L1. Impact: Asset loss or restricted access, halted or degraded L2 processing, delayed/blocked withdrawals and exits,	Preventive: Enforce strong privileged-key standards (least privilege, separation of duties, rotation); require multi-sig/threshold controls and timelocks for high-impact actions; limit and review emergency powers. Detective: Monitor and alert on privileged actions and signer changes; publish upgrade/pause/admin-event telemetry; support independent monitoring of admin activity. Corrective: Maintain tested key-rotation/revocation and incident procedures; pause or constrain high-risk	Preventive: Apply institutional-grade controls to privileged interactions (HSM/dual control/multi-sig, backups); diligence operator key governance, timelocks, and emergency powers. Detective: Monitor L2/bridge privilege events (upgrades, pauses, signer changes) and correlate with L1 impacts; validate exit and recovery assumptions remain intact. Corrective: Revoke/rotate affected keys under control; pause L2-dependent activity and bridge routes; reroute

Mitigation strategies

Risk	Description	Public blockchain ecosystems	Financial institutions
	impaired recovery and reconciliation, and elevated client and reputational impact.	functions/routes; deploy governed recovery upgrades with clear communications.	to approved alternatives (including L1) and reconcile exposures per incident playbooks.
Compromised data integrity	Description: Risk that an attacker manipulates or injects invalid data into the public blockchain, compromising the integrity of the ledger view across nodes and potentially disrupting consensus or transaction finality.		
Layer 1s	Driver: Malicious node behavior, exploitation of protocol vulnerabilities, or network-level attacks (e.g., message tampering, relay hijacking) that alter or desynchronize data propagation across participants. Event: Corrupted or manipulated blocks or state data are propagated through the network, leading to inconsistent ledger views, rejection of valid transactions, or the formation of temporary forks. Impact: Operational disruption, degraded trust in blockchain reliability, potential financial loss from delayed or failed transactions, and reputational or regulatory consequences.	Preventive: Enforce secure peer communication protocols and message validation; promote node diversity; conduct ongoing protocol hardening and upgrade cycles. Detective: Monitor for propagation delays, fork anomalies, and ledger inconsistencies; implement consensus integrity alerts; validate incoming block and state data against protocol expectations. Corrective: Enable re-synchronization from trusted checkpoints or unaffected peers; isolate and disconnect malicious nodes; coordinate rollback or corrective consensus actions as needed.	Preventive: Use off-chain reconciliation processes to verify on-chain state; maintain redundant validation infrastructure; select blockchains with resilient consensus and peer authentication. Detective: Continuously monitor ledger consistency across connected nodes; review anomaly alerts from service providers or internal systems; validate transactions against historical snapshots. Corrective: Switch to backup infrastructure with verified ledger state; delay or cancel affected transactions; documented failover plans.
Layer 2s	Driver: Cross-layer messaging, batching/data publication, and canonical bridges introduce additional integrity dependencies; where data is not posted to L1, withholding can block independent reconstruction and exits. Event: Sequencer/DA/bridge behavior is abused or degraded (e.g., withheld or malformed data, inconsistent submissions, compromised messaging), causing divergence between L2 views and what can be verified via L1. Impact: Inconsistent L2 state views, delayed/failed anchoring to L1, impaired withdrawals and settlement workflows, inability to prove balances or exit during withholding, and increased reconciliation and remediation burden.	Preventive: Enforce strong data-publication and validation requirements; harden cross-layer message checks; avoid single-operator recovery assumptions for integrity-critical paths. Detective: Monitor publication timeliness / completeness and L2–L1 divergence; detect missing / malformed batches and bridge/message anomalies via watchers and consistency checks. Corrective: Maintain exercised playbooks for integrity incidents (including suspected withholding); restore availability and resynchronize safely; ensure exit/withdrawal handling under integrity stress is explicit and workable.	Preventive: Diligence DA and cross-layer integrity assumptions; maintain independent validation signals where critical; restrict production to approved bridges/routes aligned to risk appetite. Detective: Monitor batch publication and L1 anchoring alongside DA/bridge health; reconcile L2 positions back to L1 commitments; alert on divergence and missing-data conditions. Corrective: Pause activity and contain exposure; resynchronize from trusted sources once data is available; reconcile L1/L2 positions and execute documented exit/fallback and client-communication procedures.

Mitigation strategies

Risk	Description	Public blockchain ecosystems	Financial institutions
Cyber risk events			
Consensus attack	Description: Risk that an attacker gains disproportionate influence over a public blockchain's consensus mechanism and uses it to disrupt normal network operation, including altering transaction ordering, censor, excluding valid transactions, or rewriting recent blocks.		
Layer 1s	Driver: Open validator participation combined with concentration of mining or staking power; lack of node diversity; insufficient protocol-level safeguards to prevent coordinated control of block production or finalization. Event: An attacker or colluding group surpasses consensus control thresholds (e.g., 51% of hash power or stake), enabling manipulation of the ledger through transaction censorship, chain reorganization, or double spending. Impact: Loss of transaction integrity and finality, operational disruption, potential financial loss for affected parties, and reduced confidence in the reliability of the blockchain.	Preventive: Promote decentralized validator participation through incentive structures and staking caps; implement protocol safeguards such as slashing for collusion or malicious behavior; support diverse client and hardware setups to reduce concentration risk. Detective: Continuously monitor validator set composition, consensus voting patterns, and block production concentration; alert on signs of collusion, dominance, or validator misbehavior; analyze finality delays or suspicious chain reorganizations. Corrective: Activate governance-based removal or suspension of malicious validators; coordinate community-wide forks or protocol overrides; deploy emergency updates to restore network consensus and integrity.	Preventive: Select networks with mature decentralization practices and governance safeguards; assess consensus design and economic concentration risks during selection process; diversify exposures across multiple blockchains where feasible. Detective: Track validator concentration, network health metrics, and chain reorganizations; leverage third-party analytics to detect anomalies in consensus operations; assess block confirmation depth and timing. Corrective: Pause transaction flows during instability; escalate incident response and evaluate exposure to potentially invalidated transactions; migrate assets or workflows to unaffected networks if consensus is compromised.
Layer 2s	Driver: L2s can concentrate sequencing, validation, or data-publication roles in a small operator set (e.g., sequencer / committee), creating "effective majority control" without classic 51% dynamics. Event: A sequencer or operator set colludes or is compromised, enabling censorship, ordering manipulation, or disruption of batch production/data publication and degrading exits or cross-layer correctness. Impact: Halted or censored L2 activity, loss of fair-ordering guarantees, delayed exits and recovery to L1, and elevated operational and client impact.	Preventive: Avoid single-operator control for sequencing/critical roles; implement rotation and penalty mechanisms; publish a credible path to reduced operator concentration where applicable. Detective: Monitor operator concentration and liveness; detect censorship/ordering anomalies and withheld-data signals; publish transparency metrics and alerting. Corrective: Rotate/replace operators via defined controls; activate pause/escape-hatch mechanisms where available; coordinate cross-layer incident response aligned with the L1.	Preventive: Select L2s with credible operator-risk controls and decentralization roadmaps; diversify exposure across independent L2s/routes; set limits for high-concentration designs. Detective: Monitor sequencer/committee concentration, uptime, and censorship signals; track data-publication and bridge health; escalate on abnormal ordering or halted batches. Corrective: Pause L2-dependent activity during instability; initiate exits or reroute to L1/approved alternatives; reconcile impacted activity and execute incident reporting per playbook.

Mitigation strategies

Risk	Description	Mitigation strategies	
		Public blockchain ecosystems	Financial institutions
Denial of service (DOS) attacks	Description: Risk that public-facing nodes or transaction entry points are targeted by DoS activity (including spam transactions), degrading availability and transaction processing performance.		
Layer 1s	Driver: Public accessibility of public blockchains without network-layer protection; insufficient rate limiting or anti-spam measures in protocol design; open mempool and transaction submission mechanisms that can be abused at scale. Event: Attackers generate high volumes of transactions or traffic to overwhelm specific nodes, validators, or mempool components, leading to processing backlogs and degraded network responsiveness. Impact: Delayed or failed transaction confirmations, increased congestion and fee volatility, potential service outages for dependent applications, and reduced reliability of the blockchain for institutional operations.	Preventive: Implement protocol-level rate limiting, minimum fees, and spam protection; deploy DDoS mitigation at node and API levels; promote decentralized node infrastructure and relay networks. Detective: Continuously monitor traffic volumes, mempool activity, and validator throughput; detect spikes in invalid or redundant transactions; trigger alerts for congestion or node responsiveness degradation. Corrective: Reroute network traffic to unaffected relays; prioritize legitimate transactions through dynamic fee adjustments or temporary filters; apply emergency configuration changes or block propagation throttling.	Preventive: Assess resilience of blockchain to DoS vectors as part of selection process; establish operational buffers for time-sensitive transactions. Detective: Monitor transaction propagation times, mempool congestion, and fee volatility; detect delays in settlement and confirmation flows; leverage third-party monitoring services for real-time alerts. Corrective: Postpone or reroute critical transactions; temporarily shift activity to alternate networks or bridges; escalate incident response procedures and coordinate with potentially outsourced infrastructure providers.
Layer 2s	Driver: L2 entry points (sequencer ingress, RPC/gateways, posting paths where applicable, bridge/relay infrastructure) are often capacity-constrained and run by fewer providers, making them easier to saturate than the L1. Event: High-volume traffic or spam overwhelms sequencer ingress, RPC endpoints, posting capacity, or bridge relays, interrupting batching/posting/message delivery and creating sustained queueing or outage. Impact: L2 processing degrades or halts, exits and withdrawals are delayed, and institutions face liquidity and client-servicing disruption even if the L1 remains live.	Preventive: Implement DoS controls at entry points (rate limits, admission control, DDoS protection); distribute infrastructure across providers/regions; define degraded modes that preserve exits and critical messages. Detective: Monitor ingress traffic, queue depth, posting latency, and bridge liveness; publish service-health telemetry and alerting for congestion and impaired exits. Corrective: Activate emergency throttles and prioritization (including exits); fail over ingress/endpoints where available; execute incident playbooks to restore batching/posting/relay continuity.	Preventive: Diligence L2 capacity and resiliency (sequencer/RPC/posting/bridge); maintain multi-endpoint connectivity and route allowlists; set buffers and alternative rails for time-critical flows. Detective: Monitor L2 congestion and bridge delays alongside L1 conditions; set impact-based triggers for pausing intake, rerouting, or reverting to L1 processing. Corrective: Pause impacted routes and reroute to approved alternatives (including L1 where needed); reconcile delayed/missed submissions; execute client communications and incident playbooks.

Mitigation strategies

Risk	Description	Mitigation strategies	
		Public blockchain ecosystems	Financial institutions
Cryptographic vulnerabilities	Description: Risk that advances in cryptanalysis (including quantum computing) weaken the cryptographic primitives used for authentication and validation, enabling unauthorized actions and undermining trust in blockchain security.		
Layer 1s	Driver: Most public blockchains currently rely on quantum-vulnerable cryptographic algorithms (e.g., ECDSA, EdDSA) for transaction authentication and wallet access; long-term data immutability also exposes past transactions to eventual key recovery. Event: A sufficiently powerful quantum computer or novel decryption method is used to derive private keys from public keys, enabling malicious actors to forge transactions, redirect funds, or impersonate network participants. Impact: Widespread unauthorized access to assets, collapse of ledger trust assumptions, rapid deterioration in market confidence, and heightened regulatory and institutional scrutiny of blockchain security models.	Preventive: Integrate quantum-resistant signature schemes into protocol roadmap; minimize public key exposure by delaying key reveal until transaction execution; promote hybrid cryptography for transitional periods. Detective: Monitor for quantum computing research developments and cryptanalytic breakthroughs; conduct periodic cryptographic audits and readiness assessments; track unusual transaction patterns indicating signature forgery. Corrective: Deploy emergency upgrade paths to quantum-secure protocols; initiate coordinated key rotation or migration plans.	Preventive: Adopt post-quantum cryptographic key management for custody systems; reduce reuse and early exposure of public keys; select blockchain networks with committed post-quantum transition plans. Detective: Monitor blockchain analytics for irregular signature schemes or rapid movement from long-dormant wallets; subscribe to industry alerts on cryptographic vulnerabilities; audit transaction signing infrastructure. Corrective: Rotate or reissue vulnerable keys under institutional control; quarantine assets or access points suspected of compromise.
Layer 2s	Driver: L2s extend the cryptographic surface beyond user signatures (e.g., bridges/committees, operator keys, and proving/verification systems where applicable), increasing dependence on multiple schemes and key types. Event: A cryptanalytic or quantum breakthrough weakens a scheme used by the L2 or its bridges, enabling forged actions, compromised withdrawals, or acceptance of invalid proofs/messages. Impact: Unauthorized withdrawals or state corruption, loss of confidence in L2 correctness and settlement assumptions, emergency halts/migrations, and spillover risk to L1-anchored routes that rely on the affected mechanism.	Preventive: Audit and harden cryptographic components (signatures, proof/verification where applicable); minimize privileged-key exposure and lifetime; maintain post-quantum migration paths aligned with the L1 where relevant. Detective: Track research/advisories for relevant schemes; monitor for anomalous withdrawals, admin actions, or proof/verification failures; publish security telemetry for critical components. Corrective: Execute coordinated emergency upgrades and key rotations; pause or restrict high-risk routes during uncertainty; publish clear migration and recovery guidance.	Preventive: Apply quantum-resilient practices to operational/admin keys; limit reliance on long-lived privileged keys; prefer L2s with transparent upgrade authority and credible emergency response commitments. Detective: Monitor both layers for suspicious wallet/bridge activity and proof/verification anomalies; consume operator advisories and telemetry to tune triggers. Corrective: Rotate/revoke affected keys; adjust routing or withdraw to L1 where feasible; quarantine impacted assets and execute escalation and client-communication playbooks.

Mitigation strategies

Risk	Description	Public blockchain ecosystems	Financial institutions
Smart contract errors and exploits	Description: Risk that logical errors or exploitable vulnerabilities in smart contracts or protocol code, including higher-layer system and bridge contracts, cause irreversible failures, unauthorized transfers, or prolonged operational disruption with limited post-deployment remediation.		
Layer 1s	Driver: Inherent complexity of blockchain smart contracts; insufficient pre-deployment testing, auditing, or formal verification. Event: Undetected errors or vulnerabilities lead to unexpected behavior, permanent transaction failures, unauthorized asset transfers, or critical operational disruptions post-deployment. Impact: Irrecoverable asset loss, disruption of smart contract functions, erosion of operational reliability, and loss of stakeholder trust.	Preventive: Rigorous coding standards and audits; comprehensive pre-deployment verification; support upgradeable contract frameworks. Detective: Continuous anomaly detection in smart contract execution; active community-driven monitoring and vulnerability reporting. Corrective: Emergency contract upgrades or halts through governance; rapid security patch distribution and coordinated disclosures.	Preventive: Strict pre-deployment smart contract audits; reliance on pre-audited libraries; upgradeable design for critical contracts; multi-party authorization processes; development pipelines supported by automated stress testing (e.g., AI). Detective: Real-time monitoring for execution anomalies; continuous performance tracking; regular security disclosures review. Corrective: Rapid activation of predefined emergency halts or patches; asset isolation and stakeholder notification; swift migration to secure contract versions.
Layer 2s	Driver: L2 system and bridge contracts expand code paths and upgrade cadence, and introduce privileged upgrade/emergency controls that can be abused or misused. Event: An exploit (or misuse of upgrade/emergency authority) breaks L2 system or bridge logic, causing incorrect state transitions, unauthorized transfers, halted submissions, or broken withdrawal/exit handling. Impact: Disrupted L2 processing and exits, inconsistent L1/L2 state expectations, asset loss or lockup, emergency pauses/forced migration, and heightened legal, regulatory, and reputational exposure for L2-dependent routes.	Preventive: Apply L1-grade secure development to L2 system/bridge contracts (audits, formal methods where critical); explicitly test L1–L2 interactions and exit paths. Detective: Monitor for anomalies across L2 execution, bridge flows, and L1 submissions; maintain disclosure programs that cover cross-layer dependencies. Corrective: Maintain tested pause/patch/upgrade procedures; coordinate recovery with the underlying L1 where relevant; publish clear post-incident guidance (including exit behavior).	Preventive: Prefer L2s with independently audited system/bridge contracts, transparent upgrade and emergency authority, and documented exit/recovery assumptions. Detective: Monitor L2 and bridge behavior for execution anomalies and privilege events (upgrades/pauses); track disclosures and patch adoption. Corrective: Pause L2-dependent products and tighten route allowlists; execute exits or reduce exposure where feasible; migrate to patched contracts or approved alternative routes.

Mitigation strategies

Risk	Description	Public blockchain ecosystems	Financial institutions
Risk of data privacy breach / confidentiality mismanagement			
On-chain exposure of sensitive or confidential data	Description: Risk that sensitive, personal, or confidential information is recorded directly on-chain or leaked through metadata in an immutable and publicly observable way, causing irreversible confidentiality and regulatory exposure.		
Layer 1s	Driver: Inadvertent or uninformed use of public blockchain infrastructure for transmitting or storing sensitive data; lack of effective data minimization, encryption, or redaction controls at the application layer. Event: Personal data (e.g., identifiers, financial details, private messages) or institutional secrets are published to a public ledger, either directly or through metadata leakage, making them permanently visible and searchable. Impact: Irreversible privacy violations, breach of data protection regulations (e.g., GDPR), reputational harm, enforcement actions, and long-term exposure of individuals or institutions to misuse or profiling.	Preventive: Promote best practices for off-chain data handling and encryption at the application layer; support architecture models (e.g., rollups, hybrid chains) that separate transactional and data storage layers. Detective: Deploy network-level scanning tools and indexing services to detect common data formats or known identifiers; encourage community-led audits and flagging of inappropriate data uploads; monitor for metadata leakage patterns. Corrective: Facilitate referencing alternatives through smart contracts or proxy mappings; issue advisories and remediation guidance to ecosystem developers.	Preventive: Enforce strict internal controls prohibiting transmission of sensitive data on-chain; use privacy-preserving technologies such as zero-knowledge proofs or off-chain encryption and hashing; select platforms that support compliant data segregation. Detective: Monitor application inputs and transaction payloads for inadvertent disclosure; implement automated detection of personal or regulated data in transaction metadata; conduct regular privacy audits of blockchain integrations. Corrective: Migrate business logic away from affected contracts or addresses; notify stakeholders; replace or mask exposed data references where feasible and document exposure incidents in internal risk reporting.
Layer 2s	Driver: L2 payloads/state/logs and bridge metadata can embed sensitive data, and cross-layer linkability can widen exposure; some designs reduce L1 postings while concentrating handling risk in L2 components. Event: PII, regulated data, or confidential information is written into L2 transactions/state (or exposed via DA/bridge metadata), making it publicly observable and recoverable through indexing and analytics. Impact: Irreversible confidentiality breaches, regulatory/contractual violations, reputational damage, and costly remediation via containment and workflow migration (since deletion is generally infeasible).	Preventive: Promote L2 designs and standards that keep sensitive data off-chain or in controlled environments, including clear guidance for what is posted to L1 for availability and how metadata is handled at bridges and gateways. Detective: Scan L2 data and associated L1 calldata for improper uploads, and provide tooling and guidance that helps developers avoid embedding sensitive content in payloads and metadata. Corrective: Issue remediation guidance and migration patterns (e.g., proxy and reference approaches) for affected applications and routes, recognizing that remediation is primarily containment and forward-migration rather than deletion.	Preventive: Extend privacy-by-design controls to L2 and bridge usage; prohibit sensitive data in payloads/metadata; select routes with appropriate privacy and control features. Detective: Monitor payloads and metadata across L1/L2/bridges for exposure signals; run periodic privacy audits of applications and routing patterns. Corrective: Halt or restrict impacted routes/applications; migrate logic and identifiers away from affected contracts/addresses; execute notifications and incident reporting and tighten controls to prevent recurrence.

Mitigation strategies

Risk	Description	Public blockchain ecosystems	Financial institutions
De-anonymization through public transaction data analysis	Description: Risk that transparency of ledger activity enables clustering and correlation of pseudonymous identifiers with real-world entities, exposing sensitive financial activity, counterparties, or operational patterns and increasing surveillance, targeting, and regulatory risk.		
Layer 1s	Driver: Inherent transparency of public blockchain ledgers enables advanced analytics, clustering techniques, and offchain data correlation; lack of effective privacy-preserving mechanisms at the protocol or application layer. Event: Adversaries or third parties link addresses to identifiable entities through transaction flows, timing analysis, IP tracking, or integration with external datasets (e.g., exchanges, social platforms). Impact: Unintended exposure of client behavior, financial relationships, or business operations; privacy violations; potential regulatory concern; erosion of trust.	Preventive: Support development and integration of privacy-preserving transaction mechanisms (e.g., zero-knowledge proofs, or stealth addresses); enable optional confidentiality layers at the protocol level. Detective: Monitor for emerging de-anonymization tools, address clustering methods, and linkage analysis platforms; assess data leakage vectors via transaction graph analytics; track effectiveness of obfuscation features. Corrective: Promote migration to enhanced privacy-enabled transaction formats; release protocol updates supporting stronger pseudonymity primitives; enable users to rotate addresses.	Preventive: Use privacy-preserving wallets and transaction methods where permitted; avoid address reuse and maintain operational separation between institutional identities and transaction endpoints; implement transaction aggregation or timing strategies. Detective: Audit transaction patterns for behavioral fingerprinting risks; monitor public analytics platforms for clustering of institutional addresses; assess exposure through off-chain integrations such as exchanges or service providers. Corrective: Update key and address management policies; rotate on-chain identities or intermediaries; consider shifting to networks or layers with native privacy support if institutional requirements are not met.
Layer 2s	Driver: Combined visibility of L1 deposits/withdrawals, L2 activity, and bridge routing creates strong linkage signals; sequencer/RPC telemetry and repeated routing patterns can further reduce anonymity, especially where privacy features are limited. Event: Analysts or adversaries correlate L1/L2 bridge flows, timing, amounts, and off-chain datasets to attribute L2 addresses or activity to identifiable individuals or institutions. Impact: Exposure of activity patterns, counterparties, and strategies; increased targeting risk; heightened regulatory scrutiny; and pressure to change address management, routing, and product design to reduce linkability.	Preventive: Support privacy-enhancing mechanisms and routing options at L2/bridge layers; minimize metadata and identifier reuse; provide linkability-reducing defaults where feasible. Detective: Monitor emerging cross-domain linkage techniques and tooling; publish practical guidance and transparency on linkage created by exits, batching, or sequencing. Corrective: Provide upgrade paths and recommended patterns that reduce linkability; publish incident learnings where design or operational changes materially worsen linkability.	Preventive: Avoid address reuse across L1/L2/bridges; use batching/timing strategies where appropriate; prefer routes and L2 designs that reduce metadata exposure for sensitive flows. Detective: Periodically review how activity appears in public clustering tools across L1/L2/bridges; monitor for attribution of known wallets; assess patterns that create deterministic linkage. Corrective: Rotate addresses and revise routing policies when linkage risk exceeds appetite; adjust disclosures/controls; shift sensitive activity to routes

Mitigation strategies

Risk	Description	Public blockchain ecosystems	Financial institutions
			with stronger privacy properties where permitted and feasible.
Risk of improper data access			
Misuse of transaction data and roles	Description: Risk that transaction transparency and privileged ordering roles enable value extraction or abuse of advance transaction knowledge, resulting in unfair execution outcomes and potential client harm.		
Layer 1s	Driver: On-chain transaction flows, wallet activity, or certain instructions are visible on public blockchains before final settlement or execution; lack of internal controls around access to client trading data or custody operations. Event: An insider leverages transaction visibility or privileged access to profit from a client's trade, replicate a profitable strategy, or misappropriate digital assets prior to or during execution. Impact: Direct financial losses for clients, breach of fiduciary or contractual obligations, reputational harm to the institution, and potential regulatory or legal consequences due to failure to prevent abuse of market-sensitive data.	Preventive: Encourage development of protocol features that delay transaction visibility until finalization (e.g., commit-reveal schemes, encrypted mempools); encourage alternatives to account-based data architectures; support best practices for transaction privacy at the application layer. Detective: Facilitate integration with monitoring tools that analyze mempool activity and ordering anomalies; promote community research on front-running detection and mitigation techniques. Corrective: Enable opt-in reordering protections or fair sequencing mechanisms at the protocol level; provide documentation and tooling for relayers and developers to implement anti-front-running measures.	Preventive: Perform due diligence on blockchain MEV mitigation features, implement transaction submission strategies that reduce exposure (e.g., batching, submission via private relays); maintain strict controls on internal access to transaction intent and client trading data. Detective: Monitor execution timing, slippage, and sequencing anomalies for signs of front-running or misuse; review internal activity logs for conflicts of interest. Corrective: Trigger internal investigations and freeze impacted accounts or operations; engage service providers or ecosystem governance to address persistent ordering manipulation; update execution policies and client disclosures as needed.
Layer 2s	Driver: Sequencers, shared sequencing layers, bridge relayers, or other cross-layer operators can observe pending order flow and influence ordering across L2 processing and L1 settlement paths. Event: A sequencer or cross-domain operator reorders, inserts, or delays transactions (e.g., front-running or sandwiching), or exploits cross-layer timing to divert execution outcomes before settlement finalizes on the L1. Impact: Degraded execution quality (slippage, worse fills), direct user losses, market integrity concerns, and operational, legal, and reputational exposure where institutional clients experience systematic ordering abuse.	Preventive: Implement fair-ordering and privacy-preserving sequencing where feasible (e.g., encrypted intake); reduce sequencer discretion; support protected order-submission paths for sensitive flows. Detective: Monitor and publish sequencing and relayer behavior metrics (ordering anomalies, censorship patterns, MEV indicators); provide telemetry that enables independent verification of ordering outcomes. Corrective: Define and execute governance/operator responses for proven abuse (operator rotation, route restrictions, incident playbooks); coordinate cross-layer remediation where bridges or shared sequencers are implicated.	Preventive: Conduct due diligence on L2 sequencing and MEV controls; route sensitive flows through protected/private submission channels where available; restrict internal access to client order flow and trading intent data. Detective: Continuously monitor execution timing, slippage, and ordering signatures across the L2 and associated bridge/L1 settlement path to identify front-running and sandwich patterns. Corrective: Trigger investigation and escalation procedures (e.g., freezes/holds where applicable); tighten route/venue allowlists; reroute away from

Mitigation strategies

Risk	Description	Mitigation strategies	
		Public blockchain ecosystems	Financial institutions
Privilege misconfiguration	Description: Risk that misconfigured or overly broad smart contract permissions enable unauthorized actions, leading to asset loss, operational disruption, or unintended changes to critical system behavior.		affected L2s or bridges; execute client notification and reporting playbooks when anomalies are confirmed.
Layer 1s	Driver: Overly permissive or incorrectly assigned smart contract permissions; insufficient oversight or complexity of decentralized governance. Event: Unauthorized exploitation of privilege misconfigurations leads to operational disruptions, unauthorized transactions, or compromised asset integrity. Impact: Unauthorized transfers, operational disruptions, increased regulatory scrutiny, loss of trust, and potential financial damage.	Preventive: Automated privilege-linting integrated in deployment processes; clearly defined permission standards and best practice documentation; standard patterns for privileged-role control (multi-party authorization, time-delayed changes, and halts). Detective: Continuous monitoring and auditing of smart contract privilege use; community oversight mechanisms for detecting unauthorized privilege escalations. Corrective: Coordinated smart contract updates to rectify misconfigurations promptly.	Preventive: Internal privilege audits and controls aligned to least privilege; continuous refinement of role-based and attribute-based access policies; controls for any upgrade / pause authorities. Detective: Real-time monitoring of privilege access patterns; periodic reviews of privilege assignments and access logs. Corrective: Immediate revocation and escalation of compromised privileges; transparent stakeholder communications and remediation; prompt reconfiguration and redeployment of affected contracts or applications.
Layer 2s	Driver: Overly permissive or incorrectly assigned privileges across L2 system contracts (e.g., upgrades, pauses) and canonical bridges, compounded by governance / emergency controls and concentrated operator roles. Event: Unauthorized exploitation of privilege misconfigurations enables unilateral upgrades, bridge manipulation, or unauthorized parameter changes, disrupting processing / impairing exits/withdrawals to L1. Impact: Unauthorized transfers, operational disruptions, impaired withdrawals or recovery paths to the L1, increased regulatory scrutiny, loss of trust, and potential financial damage.	Preventive: Extend automated privilege-linting to L2 system and bridge contracts; define clear permission standards; standardize privileged-role controls (multi-party authorization, time-delayed changes, and halts). Detective: Continuously monitor and audit privileged actions and role changes (upgrade events, admin changes, pause triggers); provide machine-readable logs and alerting. Corrective: Coordinate rapid updates to rectify misconfigurations; maintain tested procedures to revoke/rotate compromised roles and execute controlled halts; support migrations where redeployment is required.	Preventive: Map privileges across L2 system contracts and bridge dependencies used in products; enforce least privilege and segregation of duties for upgrade/pause keys; require clear privilege models in due diligence. Detective: Real-time monitoring of privilege access patterns; periodic reviews of privilege assignments and access logs for critical routes and contracts. Corrective: Revoke/rotate affected keys and permissions under control; halt or limit impacted integrations and routes; execute tested remediation/migration playbooks with stakeholder communications as required.

A.3. Financial crime risks and mitigation approaches

This section consolidates mitigation strategies for financial crime risks due to the substantial overlap in control measures, focusing on shared preventive, detective, and corrective practices for both public blockchain ecosystems and financial institutions.

Table A.3

		Mitigation strategies	
Risk	Description	Public blockchain ecosystems	Financial institutions
Risk of money laundering and terrorism financing			
Obfuscation via complex multistep transfers ⁶	Description: Risk that public blockchain transaction flows enable rapid “layering” across multiple wallets, protocols, and intermediaries in ways that obscure provenance and counterparties, reducing the effectiveness of AML monitoring and compliance controls, particularly when cross-domain routing is used.		
Layer 1s	Driver: Use of decentralized exchanges, cross-chain bridges, mixers, and smart contract automation without identity linkage or consistent transaction metadata. Event: Transactions are routed through multiple on-chain hops, services, and protocols to intentionally or unintentionally reduce the traceability of fund origin and counterparties. Impact: Reduced effectiveness of transaction monitoring and anti-money laundering (AML) measures; increased difficulty in meeting regulatory compliance obligations and identifying suspicious activity.	Preventive: Promote open transaction transparency standards, encourage integration with compliance analytics, and facilitate ecosystem-wide adoption of opt-in compliance tooling. Detective: Enable accessible blockchain data structures to support analytics, anomaly detection, and community-based transaction pattern monitoring. Corrective: Provide mechanisms for optional tagging, rapid asset isolation tools, and community-driven response frameworks. Preventive: Standardize L2/bridge transparency (identifiers/metadata for bridged assets and routing	Preventive: Implement robust KYC/KYT procedures, strictly restrict interactions to whitelisted counterparties, and integrate transaction profiling tools, including proliferation financing indicators where relevant and available. Detective: Conduct real-time analytics monitoring of transaction behaviors for suspicious activity and anomalous patterns. Corrective: Rapidly freeze implicated assets, escalate internally, initiate forensic investigations, and promptly report incidents to regulatory bodies.

⁶ Risk of money laundering and terrorism financing mitigation strategies consolidated

Mitigation strategies

Risk	Description	Public blockchain ecosystems	Financial institutions
Layer 2s	Driver: High-velocity, low-cost transfers and cross-layer bridging increase the feasible number of hops, while inconsistent identifiers, metadata, and observability across L2 venues and bridge representations reduce end-to-end traceability. Event: Illicit funds are routed through L2-native venues and cross-layer bridge routes in short time windows, optionally incorporating privacy pathways or automated smart-contract routing, producing fragmented traces across L1/L2 domains. Impact: Reduced KYT signal quality and higher investigation burden, delayed interdiction (freezes/halts), and increased probability that tainted funds reach institutional endpoints before alerts trigger or provenance is established.	events); make any admission/policy hooks explicit and auditable where screened gateways exist. Detective: Provide analytics-friendly access for L2 and bridge data plus basic route telemetry; support detection of cross-domain layering patterns (rapid bridging, fragmentation, privacy-path interactions where observable). Corrective: Enable cross-domain flagging/tagging and isolation that follows bridged representations; maintain clear route-control and escalation procedures (throttle/pause high-risk routes consistent with governance).	Preventive: Treat L2s/bridges as explicit risk objects in KYC/KYT and scoring; restrict activity to approved venues/wallets/routes (allowlists); set policy for high-risk pathways (e.g., privacy tools/unscreened routes) aligned to risk appetite. Detective: Run real-time cross-layer monitoring across L1/L2/bridges; validate data completeness and route behavior under stress; test alerting/investigation workflows against cross-domain typologies. Corrective: Execute cross-layer containment playbooks (pause routes, tighten allowlists, quarantine/freeze where feasible); escalate to relevant operators/providers; complete regulatory reporting using evidence that links L1, L2, and bridge context.
Illicit fund(s) integration⁷	Description: Risk that weaknesses in customer due diligence and inconsistent monitoring at issuance, trading, and on/off-ramp control points allow illicit actors to introduce funds into legitimate financial flows through blockchain-based assets, increasing regulatory exposure and traceability challenges.		
Layer 1s	Driver: Inconsistent or insufficient application of AML/CFT measures at critical control points such as token generation, listing, or trading — particularly in decentralized or cross-border environments. Event: Illicit actors acquire and exchange tokens through on-chain or off-chain venues to obscure the origin of funds and introduce them into legitimate financial flows. Impact: Reduced effectiveness of AML frameworks, increased difficulty in tracing fund provenance, heightened legal and regulatory exposure, and potential erosion of trust in blockchain-based financial products.		

Mitigation strategies

Risk	Description	Public blockchain ecosystems	Financial institutions
Layer 2s	Driver: Additional L2 entry points (bridges, L2-native venues, operator-mediated routes) can create uneven screening coverage, and bridged representations can bypass assumptions embedded in L1-only monitoring workflows. Event: Illicit actors enter via the least screened gateway (e.g., an L2 bridge or venue), swap or “wash” exposure across L2 liquidity, then bridge to L1 or an institutional venue where the tainted exposure is realized. Impact: Increased risk of prohibited exposure within institutional wallets/products, expanded regulatory and reporting burden, and greater operational disruption to quarantine, unwind, and remediate.		
Terrorist and proliferation financing⁷	Description: Risk that pseudonymous participation and privacy-enhancing mechanisms enable covert fundraising and transfers that support terrorist or proliferation activity, complicating detection and interdiction when controls are not consistently applied at access points and along routing pathways.		
Layer 1s	Driver: Public blockchains allow pseudonymous participation and may support privacy-enhancing tools (such as mixers, privacy coins, stealth addresses), which—if not monitored—can hinder the traceability of fund flows. Event: Terrorist financiers leverage public blockchains to transfer or conceal funds, exploiting gaps in oversight at on- and off-ramps or within decentralized protocols lacking embedded compliance measures. Impact: Regulatory breaches, failure to detect prohibited transactions, legal and reputational exposure for institutions interacting with tainted assets, and heightened scrutiny of blockchain-based financial services.		

Mitigation strategies

Risk	Description	Public blockchain ecosystems	Financial institutions
Layer 2s	Driver: Privacy-enhancing designs or operator-mediated pathways can reduce observable signals, while bridging accelerates dispersion across domains; where screened gateways exist, risk can be reduced inside the perimeter but shifts to admission and boundary controls. Event: Funds are raised and distributed through high-velocity L2 activity and cross-layer routing, using fragmentation (many small transfers) and, where available, privacy pathways, then bridged across domains to obscure origin and destination. Impact: Higher likelihood of delayed detection and regulatory breach, increased exposure through indirect interaction with tainted assets, and reputational risk if cross-layer tracing and containment are not executed.		
Risk of sanctions violation			
Sanctions evasion risk ⁷	Description: Risk that sanctioned individuals or entities use public blockchains to bypass international financial restrictions, exposing institutions interacting with these networks to regulatory non-compliance and enforcement actions.		
Layer 1s	Driver: Global, permissionless access to blockchain infrastructure without embedded identity verification; lack of consistent screening at decentralized access points such as smart contracts, peer-to-peer transfers, or decentralized exchanges. Event: Sanctioned actors transact via public blockchains using pseudonymous wallets, privacy-enhancing tools, or indirect intermediaries to move or convert assets, avoiding detection by traditional screening systems. Impact: Unwitting facilitation of prohibited transactions, breach of sanctions regulations, exposure to financial penalties, reputational harm, and potential regulatory scrutiny for institutions engaged with or building on such networks.	Preventive: Encourage address-screening mechanisms and transaction metadata standards, support third-party compliance integrations. Detective: Maintain transparent transaction data access and facilitate analytics for detecting sanctioned address interactions. Corrective: Foster community-led flagging of suspicious transactions and rapid intervention protocols.	Preventive: Perform real-time sanctions screening and rigorous due diligence during onboarding; screening of jurisdiction watchlists; limit transactions to vetted wallets and counterparties. Detective: Continuously monitor transaction flows, leverage blockchain analytics, and maintain watchlists to detect sanctioned interactions. Corrective: Swiftly freeze implicated assets, halt transactions associated with sanctioned activities, escalate internally, and notify regulatory authorities

⁷ Risk of sanctions violations mitigation strategies consolidated

Mitigation strategies

Risk	Description	Public blockchain ecosystems	Financial institutions
Layer 2s	Driver: Cross-layer routing and bridging enable rapid movement between domains, and sanctioned exposure can be introduced on an L2 or via a bridge representation even when base-layer controls exist; privacy tools and high-velocity venues can further reduce observable signals. Event: Sanctioned actor uses an L2 venue and bridge route to obfuscate identity and provenance, then deposits, swaps, or withdraws through representations that evade incomplete cross-layer screening. Impact: Prohibited transactions occur across L1, L2, or bridge pathways; screening gaps create delayed detection and more complex containment, increasing regulatory breach risk, remediation burden, and potential asset freezes and enforcement exposure.	Preventive: Extend screening and metadata standards across major L2s and bridges, including consistent identifiers for bridged representations; support opt-in allowlisting/screened gateway hooks where used. Detective: Publish route-level telemetry and incident logs for key L2/bridge components; support end-to-end tracing across L1/L2 and bridged representations (not per-domain only). Corrective: Define escalation and containment procedures for cross-layer sanctioned exposure (e.g., route pauses, operator coordination) with post-event reviews and remediation guidance.	Preventive: Apply sanctions screening to L2s and bridge routes as explicit objects; restrict activity to pre-screened wallets and approved routes (allowlists/controlled domains where appropriate). Detective: Monitor across L1/L2/bridged representations with watchlists and calibrated thresholds; validate bridged-asset mapping to avoid representation blind spots. Corrective: Freeze/quarantine assets and halt prohibited flows; execute cross-layer containment playbooks (pause specific routes where feasible); escalate and report promptly with evidence linking L1/L2/bridge context.
Insufficient screening of on-chain transactions and counterparties ⁸	Description: Risk that limitations in sanctions screening coverage and identity attribution on public blockchains allow sanctioned exposure to occur undetected through wallets, smart contracts, venues, or intermediaries used by the institution or its clients.		
Layer 1s	Driver: Pseudonymous nature of public blockchain transactions; absence of built-in identity verification or sanctions screening in decentralized protocols; limited integration of blockchain analytics or risk scoring into institutional compliance processes. Event: Sanctioned individuals or entities conduct transactions through the blockchain without detection, interacting with wallets, smart contracts, or token services used by the institution or its clients. Impact: Execution of prohibited transactions, inability to reverse or freeze illicit activity, breach of regulatory compliance obligations, legal exposure, and reputational damage.		

Mitigation strategies

Risk	Description	Public blockchain ecosystems	Financial institutions
Layer 2s	Driver: Screening integration can be uneven across L2-native venues, bridges, and cross-layer flows, and address/asset representations can change when bridged, creating “coverage gaps”. Event: Institution interacts with an L2 venue, application, or bridge route where sanctions screening is incomplete or not enforced consistently, allowing a sanctioned counterparty or tainted funds to touch institutional addresses before detection. Impact: Sanctioned exposure is introduced on one layer and realized on another (e.g., deposited on L2, withdrawn on L1), resulting in prohibited activity, potential client harm, and increased likelihood of reporting, enforcement action, and reputational damage.		
Risk of bribery and corruption			
Crypto-facilitated bribery	Description: Risk that pseudonymous, cross-border blockchain transfers are used to conceal improper payments to public officials or corporate insiders, reducing the effectiveness of traditional anti-corruption controls and increasing legal, regulatory, and reputational exposure.		
Layer 1s	Driver: Anonymity and international transfers facilitate concealed bribery. Event: Officials or executives accept token bribes, potentially bypassing traditional financial controls. Impact: Undetected bribery, legal exposure under anti-corruption statutes, reputational damage, and potential asset freezes.	Preventive: Provide infrastructure to integrate analytical tools. Detective: Enable analytics and monitoring tools to detect unusual or anomalous payment patterns across the blockchain. Corrective: Support community-based governance protocols to address bribery-oriented concerns	Preventive: Implement multi-party authorization processes for high-risk transactions; politically exposed person scans; conduct enhanced due diligence to detect anomalous behaviors. Detective: Utilize specialized blockchain analytics tools to flag unusual payments indicative of bribery or corruption risks. Corrective: Rapidly freeze affected transactions or accounts, conduct internal investigations, escalate incidents to compliance teams, and report to authorities.

Mitigation strategies

Risk	Description	Public blockchain ecosystems	Financial institutions
Layer 2s	Driver: Higher L2 velocity and bridging increase layering and fragment activity across venues and routes, reducing end-to-end observability. Event: Bribery payments move through L2 venues and bridges, creating cross-layer trails that are hard to trace when monitoring is not continuous across L1/L2. Impact: Delayed detection and heavier cross-layer investigations, with client/settlement disruption when assets are quarantined or exits are constrained.	Preventive: Enable analytics integration for bribery typologies; support opt-in perimeter controls/route policies where allowlisted domains exist. Detective: Provide monitoring and telemetry across major L2 venues and bridge routes; publish incident artefacts to support investigation. Corrective: Maintain cross-layer response playbooks (flagging, isolation, route restrictions) that work as assets move between L1/L2/bridges.	Preventive: Extend multi-party authorization, EDD, and PEP screening to L2/bridge workflows; restrict usage to approved venues/routes. Detective: Use analytics to detect bribery-linked anomalies across L1/L2/bridges; validate coverage across routing boundaries. Corrective: Freeze/quarantine suspicious activity, investigate, and report promptly; execute containment playbooks (pause routes, tighten allowlists, preserve evidence).
Risk of KYC / transaction monitoring control failures			
Absence of KYC and adequate monitoring	Description: Risk that weak identity linkage and inconsistent transaction monitoring allow illicit activity to enter or move through institutional blockchain workflows, with bridges and L2 venues creating additional screening gaps unless perimeter controls are consistently enforced.		
Layer 1s	Driver: Direct peer-to-peer transfers and onboarding flows that lack mandated KYC checks. Event: An unidentified user acquires, trades, or redeems tokens through the institution's services without passing appropriate due diligence controls. Impact: Regulatory penalties; compliance breaches; increased risk of illicit financial activity.	Preventive: Encourage adoption of optional identity verification standards and transaction monitoring integrations at the network and smart contract level. Detective: Facilitate ecosystem-wide access to real-time blockchain transaction data and compliance analytics tools. Corrective: Enable decentralized, community-driven flagging and incident reporting mechanisms for suspicious activities.	Preventive: Implement strict onboarding procedures involving robust identity verification (KYC/KYT); adopt comprehensive transaction monitoring solutions. Detective: Conduct continuous real-time transaction audits and monitoring, employing analytics tools to detect suspicious transaction patterns. Corrective: Immediately suspend implicated transactions, quarantine impacted accounts, initiate internal compliance reviews, escalate incidents, and report to regulatory bodies.

Mitigation strategies

Risk	Description	Mitigation strategies	
		Public blockchain ecosystems	Financial institutions
Layer 2s	Driver: Bridges, L2 gateways, and L2-native venues add access points and higher-velocity flows, increasing inconsistent screening/monitoring; allowlisting improves coverage inside the perimeter but concentrates risk at admission and boundary controls. Event: An illicit actor enters via an unscreened bridge or L2 venue and routes activity across L2 and back to L1, exploiting cross-layer monitoring gaps. Impact: Illicit exposure propagates across layers before detection, increasing enforcement risk, containment complexity, and reconciliation/remediation burden.	Preventive: Provide optional identity/allowlisting hooks at key entry points (gateways/bridges/major venues); standardize identifiers/metadata for cross-layer traceability. Detective: Publish L2/bridge telemetry and event logs to surface route gaps, abnormal conditions, and perimeter failures. Corrective: Support cross-layer containment patterns (flagging, isolation/quarantine where feasible, incident communications) that remain effective across L2/bridges/L1.	Preventive: Treat L2s/bridges as perimeter components; enforce approved bridges / venues / routes (allowlists); apply strong admission and boundary policies with controlled participation. Detective: Run cross-layer monitoring linking L1/L2/bridges; validate coverage for bridged representations and L2-native venues; review operator telemetry/logs for blind spots. Corrective: Pause impacted routes and isolate exposures (accounts/routes/assets); escalate with operators/providers where applicable; report promptly to regulators when breaches are suspected.

A.4. Business continuity risks and mitigations approaches

Table A.4

Risk	Description	Mitigation strategies	
		Public blockchain ecosystems	Financial institutions
Inadequate business continuity planning/event management			
Inadequate business continuity and recovery planning	Description: Risk that disruption affecting an L1 or an L2 stack cannot be recovered within required timeframes due to insufficient continuity planning, unclear recovery assumptions, and untested resynchronization and reconciliation procedures.		
Layer 1s	Driver: Limited integration of public blockchain-specific failure scenarios into the institution's business continuity management (BCM) framework; absence of coordinated recovery protocols with third-party infrastructure or service providers; reliance on external decentralized networks without clear fallback options. Event: A network disruption (e.g., blockchain halt, validator outage, or infrastructure failure) occurs, and the institution lacks predefined procedures, resources, or governance to switch to alternative systems or recover operations within acceptable timeframes. Impact: Inability to process or verify transactions, delays in settlement or asset transfers, breach of client SLAs, regulatory non-compliance, and reputational damage due to prolonged service interruption.	Preventive: Encourage open communication channels with ecosystem participants on upgrade schedules and fault scenarios; promote modular node architecture and stateless client options to support rapid redeployment. Detective: Monitor network health and validator availability in real-time; support open benchmarking and stress testing of protocol components. Corrective: Coordinate community-driven recovery documentation; provide tooling for rapid node state rehydration or resync after disruption.	Preventive: Integrate blockchain-specific scenarios into enterprise business continuity management planning; establish clear fallback systems and multi-network access strategies; operate institutional nodes or infrastructure components to reduce reliance on third-party providers; validate recovery strategies via real-time protocol monitoring and governance participation. Detective: Continuously assess network resilience indicators and dependency risks across connected service providers. Corrective: Activate pre-defined contingency playbooks including failover to alternate infrastructure, re-routing of workflows, or protocol migration plans; engage in protocol coordination (e.g., via working groups, open governance calls) to support timely network recovery.
Layer 2s	Driver: Reliance on L2 operational dependencies (e.g., sequencer, DA, canonical bridge/withdrawal paths, pause/upgrade controls) and on L1 liveness/finality for exits, without clearly defined and tested cross-layer recovery and resynchronization procedures.	Preventive: Define recovery procedures for critical L2 components and canonical routes; design credible degraded-mode behavior (including exit expectations); publish operator responsibilities and recovery assumptions.	Preventive: Incorporate L2 outage and exit-delay scenarios into BCP/DR; predefine fallback modes and reroute options (including L1 alternatives where feasible); document recovery assumptions per supported L2/route.

Mitigation strategies

Risk	Description	Public blockchain ecosystems	Financial institutions
	Event: Sequencer/DA disruption, bridge/withdrawal pause, or L1 degradation interrupts processing and delays exits, and recovery procedures are unclear or unexercised. Impact: Delayed processing and withdrawals, inability to meet settlement and client servicing expectations, prolonged reconciliation breaks between internal books and on-chain state, and heightened compliance and reputational exposure.	Detective: Publish service-health telemetry and incident communications for sequencer/DA/withdrawal paths, including queueing and latency indicators relevant to recovery. Corrective: Provide practical resynchronization and state-recovery guidance after restoration; exercise recovery scenarios and publish post-incident reviews to support institutional playbooks.	Detective: Monitor L1 and L2 conditions in parallel (liveness/finality, sequencer/DA health, bridge/withdrawal status, exit queues) with alerting aligned to impact tolerances. Corrective: Execute playbooks to pause intake and constrain routes during disruption; resynchronize and reconcile internal ledgers/positions after restoration; use tested client communication and escalation procedures.
Dependency on external governance for network recovery	Description: Risk that recovery from disruption is delayed because emergency actions depend on decentralized or operator-governed decision-making with limited escalation paths, extending downtime and impairing institutional operations.		
Layer 1s	Driver: Public blockchains are maintained by distributed communities with asynchronous or informal governance mechanisms that delay decision-making during emergencies. Event: A protocol bug, security incident, or liveness failure occurs, and the community requires time to coordinate and implement a fix or soft fork. Impact: Extended downtime, inability to process transactions, reputational and legal exposure due to failure to meet obligations.	Preventive: Foster transparent governance frameworks with clear emergency processes; encourage diverse participation and proactive coordination mechanisms. Detective: Monitor protocol governance forums and proposal pipelines for recovery-related activity; track responsiveness to incidents. Corrective: Support tooling for expedited patch distribution and node upgrade coordination; enable voluntary rollbacks or soft forks through opt-in mechanisms.	Preventive: Conduct due diligence on governance structures and responsiveness of selected networks; maintain relationships with ecosystem stakeholders to stay informed; directly participate in governance to strengthen resilience in the absence of centralized escalation paths. Detective: Track network governance activity and detect signs of delayed or contested incident responses. Corrective: Activate fallback infrastructure or multi-network contingency strategies; initiate internal communication and client management procedures during extended recovery periods.

Mitigation strategies

Risk	Description	Public blockchain ecosystems	Financial institutions
Layer 2s	Driver: Dependence on L2 governance and emergency authority for system contracts/bridges/operators, plus reliance on underlying L1 incident outcomes, with limited escalation paths and unclear cross-layer recovery assumptions. Event: A bug, security incident, or outage requires pause/upgrade/parameter action, but governance coordination is slow, contested, or unclear (and/or constrained by the L1's incident posture). Impact: Prolonged processing and withdrawal disruption, uncertain timelines/recourse, increased operational and compliance burden, and reputational harm from delayed restoration.	Preventive: Publish clear emergency authority and decision criteria for L2 components; define escalation paths; align cross-layer incident assumptions with the underlying L1. Detective: Provide observable governance/incident signals (status, logs, decision tracking) and monitor responsiveness to milestones. Corrective: Execute controlled emergency procedures (pause/upgrade); coordinate patching and recovery across operators; publish post-incident reviews with actions and timing.	Preventive: Diligence governance maturity and emergency mechanisms; establish escalation channels where identifiable; embed governance-delay assumptions into impact tolerances, route limits, and product terms. Detective: Monitor L2 and L1 incident and governance signals in parallel; flag indicators of delayed or contested recovery. Corrective: Activate playbooks to pause activity and constrain routes; execute client/regulator communications; adjust exposure/routes when responsiveness falls below risk appetite.
Withdrawal delay/exit-queue risk	Description: Risk that withdrawals or exits are delayed beyond expected timeframes due to congestion, throttling, or disruption on critical pathways, creating queued exits and temporary loss of timely access to funds that can impair liquidity management, settlement obligations, and client servicing.		
Layer 2s	Driver: Exit paths depend on L2 components and cross-layer routing (sequencing, bridge/withdrawal processing, and where applicable DA and proving), and may include protocol-defined withdrawal latency—creating queueing under stress even when the L1 remains live. Event: Disruption, throttling, or congestion in sequencer/bridge/exit processing creates withdrawal backlogs and delayed exits, often during elevated exit demand. Impact: Delayed access to funds and liquidity strain, missed settlement or client obligations, increased operational and reconciliation burden, and elevated conduct/compliance risk when timelines are not met.	Preventive: Publish expected withdrawal latency (normal and stressed); size and test exit-path capacity against “run on exits” scenarios; design degraded-mode behavior so a single component failure does not block exits. Detective: Provide real-time telemetry for exit-path health (queue depth, processing rate, bridge/exit liveness) with clear incident communications when thresholds are breached. Corrective: Prioritize restoring exit processing (including safe throttling/priority rules where applicable); publish guidance for safe exit handling during incidents; document outcomes to recalibrate tolerances.	Preventive: Treat exit latency as a core product and liquidity assumption; restrict critical activity to L2s/routes with transparent exit behavior; size liquidity and settlement buffers for credible exit delays. Detective: Monitor exit queues and withdrawal-path health alongside L1/L2 liveness and finality, with triggers tied to impact tolerances. Corrective: Pause intake or reduce exposure when delays breach tolerances; reroute to approved alternatives where feasible; manage client communications and settlement exceptions; reconcile positions once exit processing normalizes.

A.5. Third-party risks and mitigations approaches

Table A.5

Risk	Description	Mitigation strategies	
		Public blockchain ecosystems	Financial institutions
Third-party management control failure			
Reliance on public blockchains	Description: Reliance on a layered public-blockchain stack where base-layer performance and higher-layer operators and routes jointly determine availability, settlement assurance, and the institution’s ability to process, exit, and recover.		
Layer 1s	Driver: Decentralized operational model, absence of enforceable SLAs or contractual performance guarantees. Event: Network disruption, consensus failure, or performance degradation occurs, leading to operational impacts. Impact: Operational disruption, delays in settlement or transaction processing, breaches of client obligations, regulatory scrutiny, and potential reputational harm.	Preventive: Encourage broad validator decentralization and diversity, establish transparent governance structures and clear upgrade processes, and regularly publish network performance metrics. Detective: Continuously monitor and publish network health indicators including validator distribution, throughput levels, consensus liveness, and latency; track governance responsiveness and protocol upgrade activities. Corrective: Provide governance coordination mechanisms for rapid response, facilitate community-driven corrective actions and patches.	Preventive: Proactively develop and deploy multi-chain architectures or failover systems, embed blockchain-failure scenarios into business continuity planning, maintain documentation of failover plans; develop tiered third-party diagrams based on criticality to detail oversight requirements. Detective: Continuously monitor blockchain performance metrics, validator decentralization, and network health analytics. Corrective: Initiate immediate failover to alternative blockchains or backup infrastructure, promptly communicate impacts to clients, and execute pre-documented recovery processes.
Layer 2s	Driver: Reliance on an underlying L1 plus higher-layer control points (sequencing, DA where applicable, bridge/route policies), where end-to-end resilience is constrained by the dependency chain even if some components are contractually accountable. Event: Disruption at the L1 or a critical L2 operator/route component causes processing delays, service unavailability, or impaired withdrawal and recovery pathways. Impact: Halted or degraded processing, delayed settlement and client servicing, impaired ability to exit or recover via the L1, increased reconciliation burden, and potential regulatory and reputational exposure.	Preventive: Disclose material dependencies and resilience expectations for critical operators/routes; design operating models that tolerate single-operator/pathway failure without breaking exit and recovery assumptions. Detective: Publish service-health telemetry (and route health where applicable) with clear incident communications and post-event reporting. Corrective: Maintain and exercise degraded-mode and route-restoration procedures (including operator rotation/redeployment) and documented steps to restore credible exits under stress.	Preventive: Map the L1/L2 dependency chain; set impact tolerances; define fallbacks (pause, reroute, revert) aligned to client and settlement obligations. Detective: Monitor L1 and L2 dependencies in parallel via telemetry/incident feeds; track concentration and correlated operator exposure across routes. Corrective: Execute tested playbooks to pause intake, reroute, or fall back when dependencies degrade; reconcile and restore operations once stability and exit assumptions are re-established.

Mitigation strategies

Risk	Description	Public blockchain ecosystems	Financial institutions
Inability to effectively manage providers	Description: Reliance on specialized third-party providers and partially decentralized service layers that sit “around” the protocol and can fail, misbehave, or be difficult to replace, creating operational and compliance exposure even when the core network remains live.		
Layer 1s	Driver: Dependence on specialized service providers—some of which operate in a decentralized or non-corporate structure—limits the applicability of traditional third-party risk management approaches. Event: A critical service provider fails, is compromised, or acts outside expectations, resulting in loss of functionality, data integrity issues, or institutional non-compliance. Impact: Operational disruption, failed or delayed transactions, legal or regulatory exposure, and increased difficulty in replacing or remediating affected services.	Preventive: Promote standardized transparency practices for decentralized service providers; incentivize disclosure of operational status, governance structure, and resilience planning. Detective: Encourage community-led monitoring and evaluation of oracle networks, node services, and other key infrastructure contributors; support open reporting of outages or compliance failures. Corrective: Facilitate coordination mechanisms or forums to replace or deprecate underperforming services; provide fallback tools or community-supported alternatives.	Preventive: Conduct rigorous due diligence on third-party blockchain service providers; establish appropriate SLAs where available; favor providers with clearly defined governance and risk frameworks; diversify across multiple providers to reduce dependency. Detective: Continuously monitor provider performance, uptime, and compliance posture; assess adherence to contractual or public service-level commitments. Corrective: Activate contingency plans and pre-identified replacement providers in the event of failure; document and regularly update exit strategies for critical service relationships.
Layer 2s	Driver: Dependence on a broader L2 provider surface (e.g., bridge operators, sequencer infrastructure, DA services where applicable, and gateways), with shared dependencies that concentrate risk and limit enforceability and replacement. Event: A critical provider fails, is compromised, or misconfigured, disrupting a key service or route and creating loss of functionality, data integrity issues, or institutional non-compliance. Impact: Operational disruption, delayed or failed transfers and exits, increased reconciliation effort, legal or regulatory exposure, and increased difficulty in substituting or remediating affected services.	Preventive: Promote baseline security and resilience expectations for higher-layer operators; define roles and responsibilities; disclose material dependencies for sequencing, DA, and bridge pathways. Detective: Publish consistent incident reporting and operational transparency (status telemetry and dependency mapping) to detect degradation and concentration risks. Corrective: Provide documented substitution and recovery guidance for critical route components; coordinate ecosystem communications to enable timely provider replacement or route restriction.	Preventive: Extend third-party risk management to L2 operators and routes (governance/resilience diligence, diversification where practical, and pre-defined substitution and exit criteria). Detective: Monitor provider performance, incidents, and shared-dependency concentrations across routes; validate that control expectations remain effective as services evolve. Corrective: Activate tested contingency plans to replace providers or reroute flows; pause affected routes when remediation cannot meet impact tolerances; maintain updated exit strategies.

Mitigation strategies

Risk	Description	Mitigation strategies	
		Public blockchain ecosystems	Financial institutions
Shared infrastructure correlation risk	Description: Risk that apparent diversification across networks, applications, or providers still concentrates on the same underlying infrastructure or operator dependencies, creating correlated failure modes that degrade multiple venues simultaneously and reduce the effectiveness of redundancy.		
Layer 1s	Driver: Reliance on shared hosting, connectivity, access gateways (e.g., RPC/node access), and operational service providers, with limited transparency into common dependencies across “independent” integration paths. Event: An outage, cyber event, or misconfiguration at a dominant infrastructure or access provider simultaneously degrades multiple L1 access paths or supporting services. Impact: Concurrent disruption across venues, reduced ability to fail over as designed, delays in processing and settlement, increased reconciliation and client remediation workload, and reputational and compliance impact.	Preventive: Encourage diversity in critical infrastructure and avoid single shared gateways; disclose material shared dependencies where they create ecosystem-wide correlation. Detective: Monitor and publish service-health and concentration metrics for critical dependencies; provide timely incident communications identifying correlated failure drivers. Corrective: Provide tooling and guidance for rapid substitution/redeployment (e.g., alternative endpoints, redeploy to different providers); coordinate recovery playbooks when shared dependencies fail.	Preventive: Perform dependency mapping across access, connectivity, and tooling; set correlation limits where dependencies are shared; design redundancy that does not rely on the same providers. Detective: Monitor shared-provider exposure and correlated incident signals; periodically validate independence assumptions through resilience and failover testing. Corrective: Execute tested failover to shift away from shared dependencies; pause or throttle activity when correlation events breach tolerances; reconcile and reprocess flows after restoration.
Layer 2s	Driver: “Diversified” L2 exposure can still share critical operator/service layers (e.g., common sequencer stacks, DA providers, bridge pathways, or shared infrastructure vendors), clustering risk across venues. Event: Failure, degradation, or compromise of a shared sequencer/DA/bridge/routing dependency simultaneously disrupts multiple L2s or major routes, including deposits, withdrawals, and exit processing. Impact: Correlated L2 halts or degraded performance, delayed exits and liquidity constraints, reduced ability to reroute as planned, and increased operational burden to contain, reconcile, and communicate cross-route impacts.	Preventive: Disclose shared-dependency concentrations across critical operators and routes; design operating models that support substitution and recovery when shared dependencies fail. Detective: Publish route-level telemetry and service-health indicators (sequencer liveness, DA availability, bridge queue health) with incident communications highlighting correlated impacts. Corrective: Support rapid substitution / redeployment; activate documented degraded-mode behavior and exit recourse where applicable; publish post-event reviews causes and remediation actions.	Preventive: Validate redundancy independence via dependency mapping and testing; set exposure limits by dependency cluster; restrict critical workflows to approved routes with credible independent fallbacks. Detective: Monitor shared dependencies across L1/L2/routes in parallel; track concentration and incident history for common operators; run correlation-focused resilience exercises (e.g., multi-L2 outage scenarios). Corrective: Execute playbooks to pause intake/bridging and reroute to independent pathways (including direct L1 where appropriate); reduce exposure when correlated incidents breach tolerances; reconcile and communicate during multi-route disruption.

A.6. Legal risks and mitigation approaches

Table A.6

Risk	Description	Mitigation strategies	
		Public blockchain ecosystems	Financial institutions
Lack of attributable counterparty (ORX Level-2 risk category - Mishandling of legal processes)	Description: Risk that absence of an accountable legal counterparty and clear escalation path limits enforceability, dispute resolution, and remediation for unexpected blockchain or operator behavior, including cross-layer boundary events		
Layer 1s	Driver: Public blockchains operate without a central legal entity responsible for performance or accountability; governance is decentralized or pseudonymous; no general contractual relationships or service-level agreements exist between the actors in a public blockchain ecosystem. Event: A service disruption, protocol failure, or dispute arises, and affected users cannot identify a legally recognized counterparty for recourse, enforcement, or liability. Impact: Inability to resolve disputes or enforce claims; legal and regulatory uncertainty; loss of user trust and institutional adoption barriers; increased exposure to jurisdictional risk and systemic enforcement gaps.	Preventive: Promote clear governance frameworks and community governance escalation mechanisms. Detective: Maintain transparent logs of governance activity and protocol changes; monitor developments related to accountability structures and jurisdictional relevance. Corrective: Support opt-in dispute resolution mechanisms (e.g., on-chain arbitration agreements); facilitate community-led response pathways to resolve incidents.	Preventive: Conduct legal and governance due diligence; identifying and utilizing contractable counterparties for ancillary services where possible, assess view of prudential regulator Detective: Participate in or monitor protocol governance and development activity; track operational performance of key contributors; evaluate ongoing risk exposures based on ecosystem behavior and responsiveness. Corrective: Execute escalation and dispute-resolution processes (e.g., arbitration) with contractable counterparties where relevant, and document and disclose control measures to regulators.
Layer 2s	Driver: Reliance on L2 systems with identifiable but not always contractable roles (operators, contract administrators, bridge pathways), with unclear allocation of responsibilities and recourse across the L1/L2 stack. Event: A disruption or disputed outcome arises from L2 operator actions (pause/upgrade), bridge decisions, or L1 incident propagation, and the institution cannot establish clear liability or escalation expectations across layers.	Preventive: Publish governance, escalation, and emergency-action authority for L2 components (including bridges) and clear boundary assumptions for cross-layer incidents. Detective: Provide transparent artefacts (operational logs, incident reports, decision records) that support investigation and dispute handling.	Preventive: Extend legal due diligence across the L1/L2 dependency chain; use contractual wrappers where identifiable parties exist to define responsibilities, escalation, and dispute resolution. Detective: Monitor operator actions, governance changes, and emergency controls (e.g., bridge/admin); retain logs to support audits and disputes.

Mitigation strategies

Risk	Description	Public blockchain ecosystems	Financial institutions
	Impact: Delayed or ineffective dispute resolution, unclear enforceability of obligations, heightened legal and regulatory uncertainty, increased burden to evidence events, and elevated client remediation and disclosure risk.	Corrective: Maintain defined escalation paths and cross-layer recovery playbooks, including consistent communications and post-incident reporting.	Corrective: Execute predefined escalation and dispute processes; pause or constrain affected activity and apply contingency routing; coordinate client and regulator communications based on documented evidence.
Risks that arise from contractual rights / obligations failure	Description: Risk that smart contract execution diverges from legal intent and is difficult to remediate due to immutability and complex dependencies, including higher-layer components that affect settlement, exits, and recovery.		
Layer 1s	Driver: Complex logic, limited pre-deployment legal review Event: A latent bug, drafting error, or false implementation causes a smart contract to perform contrary to the legal intentions, and the immutability of the chain delays or prevents correction. Impact: Permanent asset loss, stalled business processes, costly legal disputes, and reputational damage.	Preventive: Encourage best practices and standardized, audited templates and promote independent security and legal reviews. Detective: Support on-chain metadata and event logging that simplify continuous monitoring of contract execution and anomaly detection. Corrective: Publish tooling for rapid migration to patched contract versions.	Preventive: Perform rigorous multidisciplinary audits of smart contracts; favor upgrade-enabled designs and vetted code libraries; ensure documentation defines contractual rights (e.g., escalation / dispute-resolution procedures). Detective: Monitor smart contract events versus expected business logic and track external vulnerability disclosures. Corrective: Documented failover plan; pause interactions, migrate assets to replacement contracts, notify stakeholders, and pursue legal remediation.
Layer 2s	Driver: L2 smart contracts and cross-layer components rely on upgrade authority and settlement/exit assumptions that may not align with legal intent. Event: A defect, misconfiguration, upgrade, or emergency intervention causes contract behavior or cross-layer outcomes to diverge from intended rights and obligations, including impaired exits or inconsistent outcomes. Impact: Failure to meet contractual commitments, prolonged disputes, operational disruption, and potential client harm and regulatory exposure.	Preventive: Promote standardized, audited templates for common L2 components and cross-domain patterns; document expected behavior and upgrade authority for critical contracts and routes. Detective: Support monitoring and disclosure of contract behavior changes and cross-layer inconsistencies via transparent change management and observable operational signals. Corrective: Provide procedures and tooling to pause, patch, or migrate affected components, with incident reporting that clarifies amendments .	Preventive: Extend legal reviews and documentation to cover cross-layer dependencies (defect handling, emergency interventions, settlement/exit assumptions) and remediation rights. Detective: Monitor contract execution and cross-layer outcomes against expected business logic; track disclosures and incident signals indicating divergence. Corrective: Execute playbooks to pause activity, adjust routing, or migrate contracts/routes when outcomes diverge; issue clear client disclosures and remediation steps.

A.7. Transactions and process execution risks and mitigations approaches

Table A.7

Risk	Description	Mitigation strategies	
		Public blockchain ecosystems	Financial institutions
Processing/execution failure relating to clients and products	Description: Risk that irreversible transaction execution and cross-domain routing errors cause permanent or hard-to-remediate client and operational impacts.		
Layer 1s	Driver: Weak front-end validation, unclear user interface cues, or contract parameter mishandling. Event: A client submits an erroneous transfer that cannot be rolled back. Impact: Permanent asset loss, customer complaints, and reputational damage.	Preventive: Define strict transaction-format standards and reference user interface code; developing and encouraging best practices for data checks. Detective: Facilitating anomaly alerts for technical errors. Corrective: Rapid governance responses to explore “pause”/freeze hooks where applicable.	Preventive: Require dual approval or strong user confirmation for high-value transfers; train users on common errors. Detective: Flag transactions breaching preset limits. Corrective: Run off-chain remediation (client notice, compensating payment) or insurance claims where contractual, re-issuance where applicable.
Layer 2s	Driver: Cross-layer routing and execution introduce additional failure points (bridge parameters, route selection, sequencing behavior, and mismatched L1/L2 confirmation assumptions). Event: A routing or bridge execution error causes misrouting, partial completion, or delayed settlement across the L1–L2 boundary, with errors detected late due to asynchronous anchoring and exit mechanics. Impact: Irreversible or hard-to-remediate client harm, delayed settlement and reconciliation breaks, and higher risk of client disputes and control failures.	Preventive: Define clear cross-domain transaction and message standards; publish confirmation and failure-mode guidance for settlement assumptions. Detective: Provide real-time telemetry for sequencing, bridging, and exits; expose error states and queue conditions to support monitoring. Corrective: Maintain credible degraded-mode and recovery procedures (e.g., safe pauses for affected routes, reprocessing rules, and reconciliation).	Preventive: Extend strong validation to L2/bridge workflows; enforce route allowlists and pre-execution simulation for higher-risk paths. Detective: Monitor execution outcomes across L2, bridge, and L1 anchoring in parallel; alert on partial completion, unexpected route changes, or delayed settlement signals. Corrective: Execute playbooks to pause affected routes; reconcile outcomes across L1/L2; complete client notification and remediation steps; shift activity to approved fallback routes or direct L1 processing.

Mitigation strategies

Risk	Description	Mitigation strategies	
		Public blockchain ecosystems	Financial institutions
Challenge-window liquidity freeze	Description: Risk that protocol-defined withdrawal latency and dispute or challenge windows delay access to funds, creating temporary liquidity freezes that can breach settlement and client servicing tolerances under stress		
Layer 2s	Driver: Protocol-imposed exit delays combined with constraints in exit processing (withdrawal queues, sequencer disruption, bridge throttling, or congestions). Event: Elevated withdrawal demand or incident conditions increase exit queues or degrade routes, extending withdrawal time beyond expected even when L1 is live. Impact: Liquidity and settlement strain, delayed client withdrawals, increased operational and reputational risk, and potential exposure from funding or prefunding needs.	Preventive: Publish expected withdrawal latency under normal and stressed conditions; design exit paths so a single component failure does not block credible exits; define operating rules for throttling and degraded modes. Detective: Provide transparent telemetry for exit queues and withdrawal-path health, with incident communications that support threshold calibration. Corrective: Maintain workable recovery procedures with clear resumption criteria and post-incident reporting; preserve user recourse through documented forced-exit or fallback mechanisms where applicable.	Preventive: Embed exit-latency assumptions in product terms and liquidity planning; size buffers to withstand stress delays; restrict reliance to approved routes and “fast exit” arrangements. Detective: Monitor exit queues and route health alongside L1/L2 liveness and finality; set impact-tolerance thresholds and escalation triggers for withdrawal delays. Corrective: Execute playbooks to pause intake and constrain higher-risk routing; shift processing to approved alternatives; deliver client communications and reconciliation steps when delays breach tolerance thresholds.

A.8. Data management risks and mitigations approaches

Table A.8

Risk	Description	Mitigation strategies	
		Public blockchain ecosystems	Financial institutions
Inadequate data architecture/IT infrastructure	Description: Risk that sensitive, personal, or confidential information is exposed through on-chain payloads or related metadata, where transparency and immutability make remediation difficult once published.		
Layer 1s	Driver: Insufficient safeguards, lack of anonymization and privacy practices at protocol or node-level architecture. Event: Personal data, banking secrets, or proprietary trade information inadvertently disclosed or publicly visible. Impact: Breaches of data privacy laws (e.g., GDPR), compromised confidentiality, and reputational damage.	Preventive: Provide standards and best practices for data privacy and anonymization; encourage privacy-preserving tooling integration. Detective: Facilitate transparent monitoring of data leakage risks; publish anonymization efficacy metrics. Corrective: Support community-led privacy enhancements; enable emergency protocol adjustments to mitigate inadvertent disclosures.	Preventive: Perform thorough risk assessments on data exposure risks of specific public blockchain use-cases; adopt privacy-preserving technologies, hybrid on/off-chain data storage, and private batch-processing methods. Detective: Continuously monitor data interactions; utilize analytics for early warning of breaches. Corrective: Implement documented failover plans; quarantine sensitive data; execute predefined incident response and reporting protocols.
Layer 2s	Driver: Weak data-handling controls and unclear “what is posted to L1” assumptions allow sensitive data or linkable metadata to enter L2 payloads/logs or bridge messages (and DA layers where applicable). Event: Sensitive fields are embedded in L2 calldata / state / logs or bridge payloads and become publicly visible (including via L1 calldata where applicable) or exposed through degraded DA/access-control mechanisms. Impact: Irreversible confidentiality breach (e.g., personal data, banking secrecy, trade secrets), regulatory and client impact, and forced remediation (route restrictions, address rotation, workflow migration).	Preventive: Publish safe L2/cross-layer data patterns (including what is posted to L1); support privacy-preserving tooling to prevent sensitive-data embedding; set expectations for DA and access-control design where applicable. Detective: Scan L2 payloads/logs and associated L1 data (where applicable) for sensitive-data patterns; disclose posting/retention behavior; provide telemetry to support investigation. Corrective: Maintain disclosure incident playbooks and communications; support rapid fixes (tooling, patched contracts where possible); publish containment and migration guidance.	Preventive: Apply privacy-by-design to L2/bridge workflows (classification, minimization, prohibitions); diligence L2 data exposure, and recovery protocols. Detective: Monitor payloads/logs/bridge messages pre-submission; run periodic audits; consume ecosystem telemetry/alerts for suspected disclosure. Corrective: Pause affected routes/products; contain exposure (address rotation, route restrictions); execute notifications/reporting where required; migrate workflows when exposure cannot be acceptably contained.

Glossary

Below are standard definitions for terminology used throughout the document.

Term	Definition
51% attack	When a malicious actor compromises more than half of the validators of a blockchain infrastructure.
Atomic settlement	Instant exchange of two assets, such that the transfer of one occurs only upon transfer of the other one.
Blockchain	A blockchain is a distributed digital ledger that is immutable for the individual user that stores data in "blocks" linked together chronologically using cryptographic tools.
Bridge	Technique used to transfer assets between ecosystems by, typically, creating a synthetic representation of a blockchain-specific asset on a different blockchain and locking the original asset while the representation is used.
Bug bounty program	Initiative where developers offer rewards to ethical hackers to find and report security vulnerabilities.
Consensus mechanism	The process by which data validators on a blockchain infrastructure agree on the state of a distributed ledger.
Digital asset	Digital representation of value that can be used for payment or investment purposes or to access a good or service.
Digital tokens	Entries in a database that are recorded digitally and that can contain information and functionality within the token itself
Digital twin	An electronic controllable record representing an asset that has been immobilized on another system of record, and reconciled with that original system of record to ensure ownership is reflected precisely.
Digital wallet	An application or interface that allows users to interact with a blockchain infrastructure for transactions e.g., in stablecoins or other tokens.
Distributed ledger	Database that runs on computers around the world; it is shared and synchronized among network participants so there is no single point of failure.
Distributed ledger technology (DLT)	The processes and related technologies that enable nodes in a network (or arrangement) to securely propose, validate and record state changes to a synchronized ledger that is distributed across the network's nodes.
Financial market infrastructure (FMI)	A multilateral system among participating institutions, including the operator of the system, used for the purposes of clearing, settling or recording payments, securities, derivatives or other financial transactions.
Hardware wallet	Noncustodial physical single-purpose storage devices.
Interoperability	The technical, semantic and business compatibility that enables a system or mechanism to be used in conjunction with other systems; allows participants in different systems to conduct, clear and settle transactions across systems without participating in multiple systems.
Linting	Automated process of analyzing smart contracts to identify and flag potential privilege misconfigurations or permission-related issues.
Ledger	A ledger is a record-keeping system used to track financial transactions.
Ledger fork	Split in a single blockchain or distributed ledger into two or more independent paths, each maintaining a valid but different history of transactions. Can be the result of disagreement among network participants about the ledger's rules or when two blocks are created simultaneously, which is usually resolved by the network.
Memory pool	Holding area where in a blockchain network where unconfirmed transactions are stored prior to being included in a block.
Off-chain	Any activity that takes place outside blockchain infrastructure.
On-chain	Any activity that takes place on blockchain infrastructure.

Term	Definition
Operator	Those who can create new data blocks and interact with a blockchain for that purpose.
Oracle	An institutional middleware layer providing secure data delivery, interoperability, compliance controls, privacy, and workflow orchestration for blockchain applications.
Private key	A private key is a secret cryptographic code that is used to decrypt data encrypted by its corresponding public key, or to create a digital signature. It forms one half of a public-private key pair.
Public blockchain ecosystem	A decentralized network of nodes that operates on an open and transparent blockchain infrastructure, allowing anyone to participate as a user, validator, or developer.
Public key	A cryptographic code that can be openly shared and is used to encrypt data or verify digital signatures. It forms one half of a public-private key pair, where the corresponding private key is kept secret and used for decryption or creating digital signatures.
Public permissioned blockchains	Retain public visibility of data and activity but restrict participation in key roles (such as validation or governance) to approved or identified entities.
Public permissionless blockchains	Fully open networks where anyone can read data, submit transactions, or participate in validation without prior approval.
Relayer	Intermediary that facilitates transmission of data or transactions between parties and blockchain networks.
Security token	A token that satisfies the applicable regulatory definition of a security or financial instrument under local law.
Smart contract	Computer program that is stored and runs on a blockchain infrastructure; it may incorporate the elements of a binding contract.
Stablecoin	Privately issued, digital token that aims to maintain a stable value relative to a peg specified by a reference asset(s) and designed to minimize value fluctuations relative to these reference assets(s).
Staking	The process of locking up blockchain assets for a set period to help secure and support the operation of a blockchain infrastructure, typically in return for a share of transaction fees or other incentives.
Tokenization	The process of generating and recording a digital representation of traditional assets on a blockchain infrastructure.
Tokenized security	A token that represents an underlying security or financial instruments issued on a different platform (such as a traditional CSD or registrar).
Transaction	A record of an event or exchange, such as the transfer of cryptocurrency or data, which is cryptographically signed and submitted to the blockchain infrastructure for validation and inclusion.
Validator	An entity that verifies data for a blockchain.
Wallet	Application or device for storing private keys.
Whitelisted	A predefined list of approved wallets or counterparties that an institution permits for transactions or interactions; activity outside the whitelist is often blocked and restricted.

About Global Blockchain Business Council

Global Blockchain Business Council (GBBC) is the largest leading non-profit association for the blockchain, digital assets, and emerging technologies community. Founded in 2017 in Davos, Switzerland, GBBC comprises more than 500 institutional members and 251 Ambassadors across 119 jurisdictions and disciplines.

GBBC furthers adoption of digital technologies by engaging regulators, business leaders, and global changemakers to harness these transformative tools for more secure and functional societies.

GBBC industry verticals: Financial Services, Global Commerce/Supply Chains, and Commodities, underpinned by AI, digital identity, governance, hardware, infrastructure, policy, regulation, and security.

GBBC initiatives: BITA Standards Council (BITA), GBBC Digital Media, Global Standards Mapping Initiative (GSMI), International Journal of Blockchain Law (IJBL), InterWork Alliance (IWA), and U.S. Blockchain Coalition (USBC).

For more information, visit <https://www.gbbs.io/>

About Oliver Wyman

Global leader in management consulting. With offices in more than 70 cities across 30 countries, Oliver Wyman combines deep industry knowledge with specialized expertise in strategy, operations, risk management, and organization transformation. The firm has more than 6,000 professionals around the world who work with clients to optimize their business, improve their operations and risk profile, and accelerate their organizational performance to seize the most attractive opportunities.

Oliver Wyman has a dedicated Digital Assets platform that supports industry powerhouses including i) regulators and public policy makers who are setting transformative requirements and norms, ii) traditional finance companies that are pioneering the digital asset landscape with blockchain-driven products and services, iii) trailblazing crypto natives that have established themselves as leaders in crypto and digital assets, and iv) investors. The team's unparalleled industry experiences have also positioned us as thought leaders, evidenced by a series of publications on digital assets including centerpieces in collaboration with leading institutions in the domain.

For more information, visit <https://www.oliverwyman.com/our-expertise/hubs/digital-assets.html>

Copyright ©2026 Oliver Wyman, and GBBC

Oliver Wyman was commissioned by GBBC to curate the RMF. All rights reserved. This publication may not be reproduced or redistributed, in whole or in part, without the written permission of Oliver Wyman, and GBBC. Oliver Wyman, and GBBC accept no liability whatsoever for the actions of third parties in this respect. Institutions should consult their own legal, compliance, risk, and regulatory advisors before making any decisions relating to blockchain infrastructure or digital assets. The information and opinions in this publication were prepared by Oliver Wyman, and GBBC. This publication is not investment advice and should not be relied on for such advice or as a substitute for consultation with professional accountants, tax, legal or financial advisors. Oliver Wyman, and GBBC have made every effort to use reliable, up-to-date and comprehensive information and analysis, but all information is provided without warranty of any kind, express or implied. Oliver Wyman, and GBBC disclaim any responsibility to update the information or conclusions in this publication. Oliver Wyman, and GBBC accept no liability for any loss arising from any action taken or refrained from as a result of information contained in this publication or any publication or sources of information referred to herein, or for any consequential, special or similar damage even if advised of the possibility of such damages. The publication is not an offer to buy or sell securities or a solicitation of an offer to buy or sell securities. This publication may not be sold without the written consent of Oliver Wyman, and GBBC.